

SCaLE 22x

Pasadena, CA | March 6-9, 2025

Securing Web Application Against OWASP Top 10 Threats in AWS Cloud

Murat Aydemir

(he/him)

Security Delivery Associate Manager

Accenture Prague, Czechia

About the Speaker

Focus on AppSec and Cloud Security



Murat Aydemir

Security Delivery Associate Manager

About the Speaker

Focus on AppSec and Cloud Security

Vulnerability researcher (30+ CVE/0-day vuln.)



Murat Aydemir

Security Delivery Associate Manager

About the Speaker



Murat Aydemir

Security Delivery Associate Manager

Focus on AppSec and Cloud Security

Vulnerability researcher (30+ CVE/0-day vuln.)

Big fan of Serverless

About the Speaker



Murat Aydemir

Security Delivery Associate Manager

Focus on AppSec and Cloud Security

Vulnerability researcher (30+ CVE/0-day vuln.)

Big fan of Serverless

Enjoy to reproduce 1-day vulnerabilities

<https://github.com/murataydemir>

AGENDA



What to expect from this session

AGENDA

What to expect from this session

01 Security topics in cloud era

02 OWASP and OWASP Top 10

03 Core architecture

04 Architecting exercises for enhanced appsec

05 Detection-based defensive strategies

Security topics in Cloud Era

Security topics in Cloud Era



Security of the codebase

How can I adopt secure coding standards to develop more secure and bug-free source code?

Security topics in Cloud Era



Security of the codebase

How can I adopt secure coding standards to develop more secure and bug-free source code?



Security in the cloud

How can I design my application to minimize vulnerabilities, threats, and risks and respond faster?

Security topics in Cloud Era



Security of the codebase

How can I adopt secure coding standards to develop more secure and bug-free source code?



Security in the cloud

How can I design my application to minimize vulnerabilities, threats, and risks and respond faster?



Security of the cloud

How can I build secure, robust and reliable cloud infrastructure using cloud-native services?

Security topics in Cloud Era



Security of the codebase

How can I adopt secure coding standards to develop more secure and bug-free source code?



Security in the cloud

How can I design my application to minimize vulnerabilities, threats, and risks and respond faster?

Our focus today



Security of the cloud

How can I build secure, robust and reliable cloud infrastructure using cloud-native services?

OWASP

OWASP

Stands for Open Worldwide Application Security Project

OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:

OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:

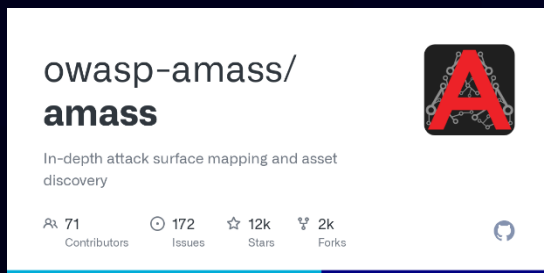


OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:



OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:

OWASP/
CheatSheetSeries



The OWASP Cheat Sheet Series was created to provide a concise collection of high value information on specific application security...

502

19

29k

4k

Contributors

Used by

Stars

Forks

OWASP/**ASVS**



Application Security Verification Standard

107

6

19

3k

677

Contributors

Used by

Discussions

Stars

Forks

owasp-amass/
amass



In-depth attack surface mapping and asset discovery

71

172

12k

2k

Contributors

Issues

Stars

Forks

OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:

OWASP/
CheatSheetSeries



The OWASP Cheat Sheet Series was created to provide a concise collection of high value information on specific application security...

👤 502

🔗 19

★ 29k

🍴 4k

Contributors

Used by

Stars

Forks

OWASP/**ASVS**



Application Security Verification Standard

👤 107

🔗 6

💬 19

★ 3k

🍴 677

Contributors

Used by

Discussions

Stars

Forks

owasp-amass/
amass



In-depth attack surface mapping and asset discovery

👤 71

🕒 172

★ 12k

🍴 2k

Contributors

Issues

Stars

Forks

OWASP/**owasp-mastg**



The Mobile Application Security Testing Guide (MASTG) is a comprehensive manual for mobile app security testing and reverse engineering. It...

👤 234

🔗 19

💬 83

★ 12k

🍴 2k

Contributors

Used by

Discussions

Stars

Forks

OWASP

Stands for Open Worldwide Application Security Project

Operates under “open community” model

Many active open-source projects:

**OWASP/
CheatSheetSeries**



The OWASP Cheat Sheet Series was created to provide a concise collection of high value information on specific application security...

👤 502 Contributors 📄 19 Used by ⭐ 29k Stars 🍴 4k Forks

OWASP/ASVS

Application Security Verification Standard



👤 107 Contributors 📄 6 Used by 💬 19 Discussions ⭐ 3k Stars 🍴 677 Forks

**owasp-amass/
amass**



In-depth attack surface mapping and asset discovery

👤 71 Contributors 🗨️ 172 Issues ⭐ 12k Stars 🍴 2k Forks

**OWASP/owasp-
mastg**



The Mobile Application Security Testing Guide (MASTG) is a comprehensive manual for mobile app security testing and reverse engineering. It...

👤 234 Contributors 📄 19 Used by 💬 83 Discussions ⭐ 12k Stars 🍴 2k Forks

OWASP/Top10



Official OWASP Top 10 Document Repository

👤 141 Contributors 🗨️ 75 Issues ⭐ 4k Stars 🍴 844 Forks



OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

Coming soon: OWASP Top 10:2025 in H125

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

Coming soon: OWASP Top 10:2025 in H125

Flagship project

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

Coming soon: OWASP Top 10:2025 in H125

Flagship project

Focus on **security risks**, not Top 10 impacts, likelihoods or vulnerabilities

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

Coming soon: OWASP Top 10:2025 in H125

Flagship project

Focus on **security risks**, not Top 10 impacts, likelihoods or vulnerabilities

OWASP Top 10 represents →

OWASP Top 10

AKA “OWASP Top 10 for Web Apps” —there are other Top 10s as well—

First released in 2003, latest release 2021 (7th update)

Coming soon: OWASP Top 10:2025 in H125

Flagship project

Focus on **security risks**, not Top 10 impacts, likelihoods or vulnerabilities

OWASP Top 10 represents → **bare minimum** to cover AppSec

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access Control

A02-21

Cryptographic Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security Misconfiguration

A06-21

Vulnerable and Outdated Components

A07-21

Identification & Authentication Failures

A08-21

Software and Data Integrity Failures

A09-21

Security Logging and Monitoring Failures

A10-21

Server-Side Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injections

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access Control

A02-21

Cryptographic Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security Misconfiguration

A06-21

Vulnerable and Outdated Components

A07-21

Identification & Authentication Failures

A08-21

Software and Data Integrity Failures

A09-21

Security Logging and Monitoring Failures

A10-21

Server-Side Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

OWASP Top 10 Security Risks for Web Apps

A01-21

Broken Access
Control

A02-21

Cryptographic
Failures

A03-21

Injectons

A04-21

Insecure Design

A05-21

Security
Misconfiguration

A06-21

Vulnerable and
Outdated
Components

A07-21

Identification &
Authentication
Failures

A08-21

Software and
Data Integrity
Failures

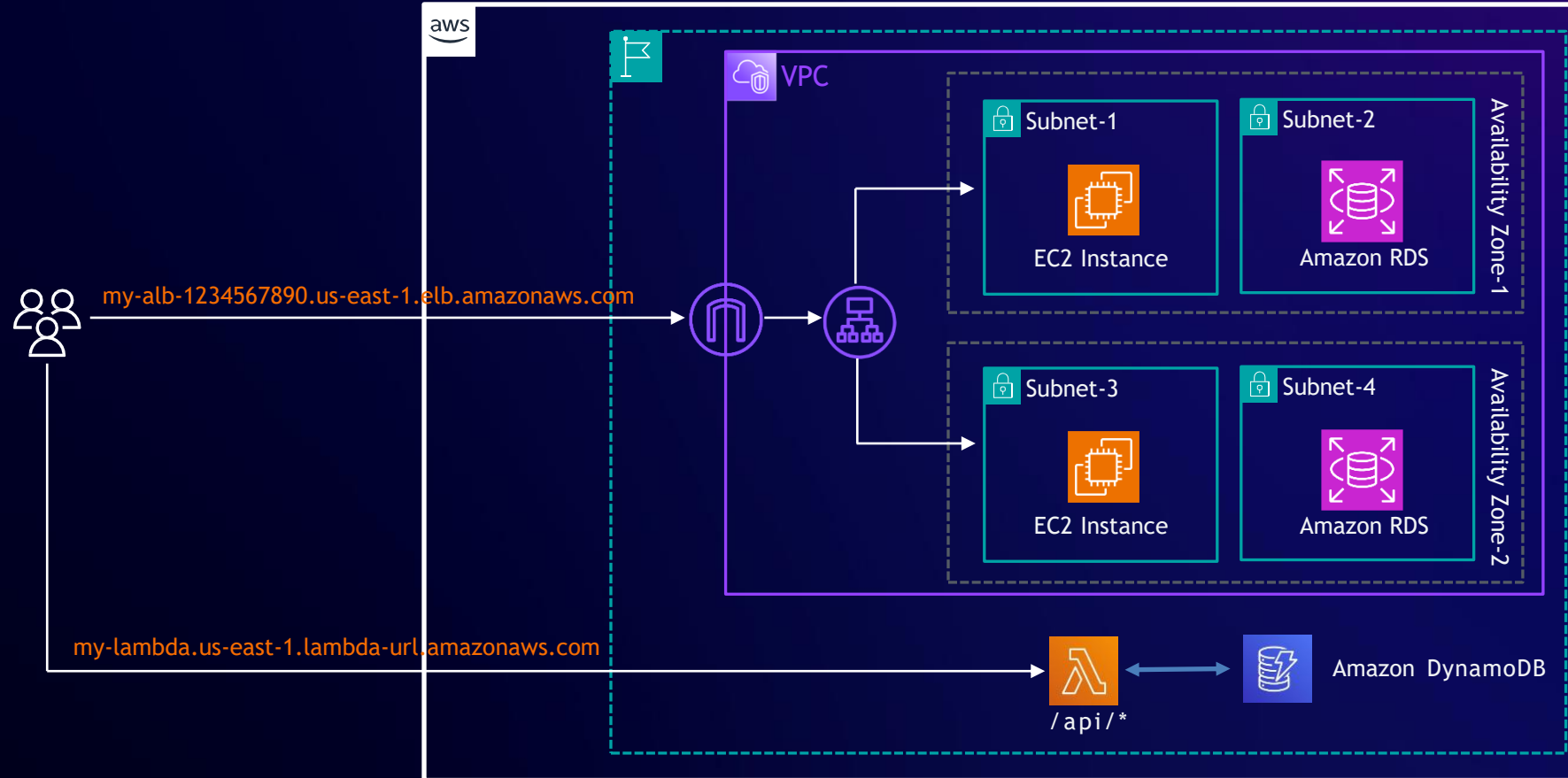
A09-21

Security Logging
and Monitoring
Failures

A10-21

Server-Side
Request Forgery

Core Architecture

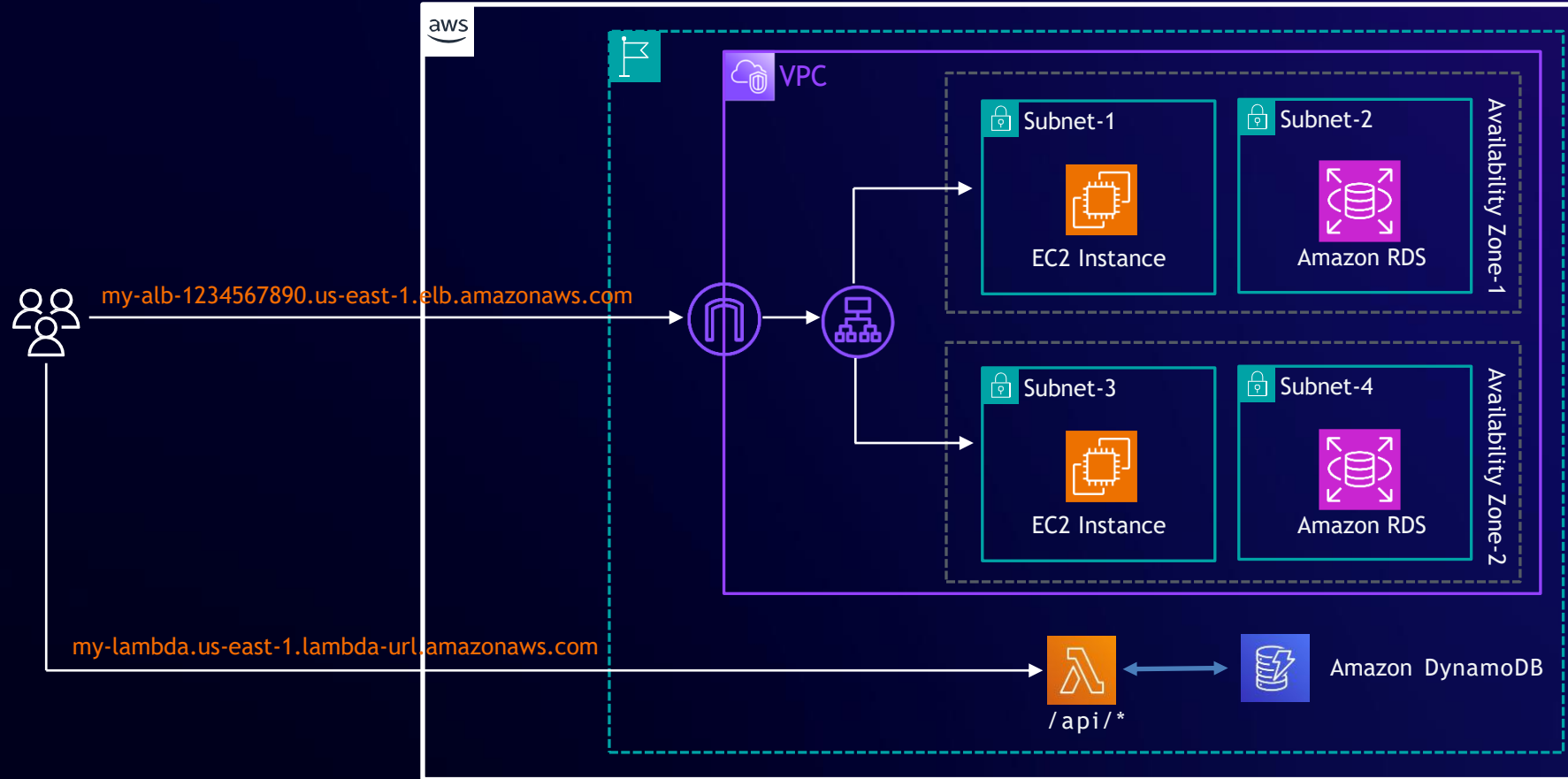


Q: How can we make this architecture more secure and resilient?

Amazon API Gateway

Design Challenges

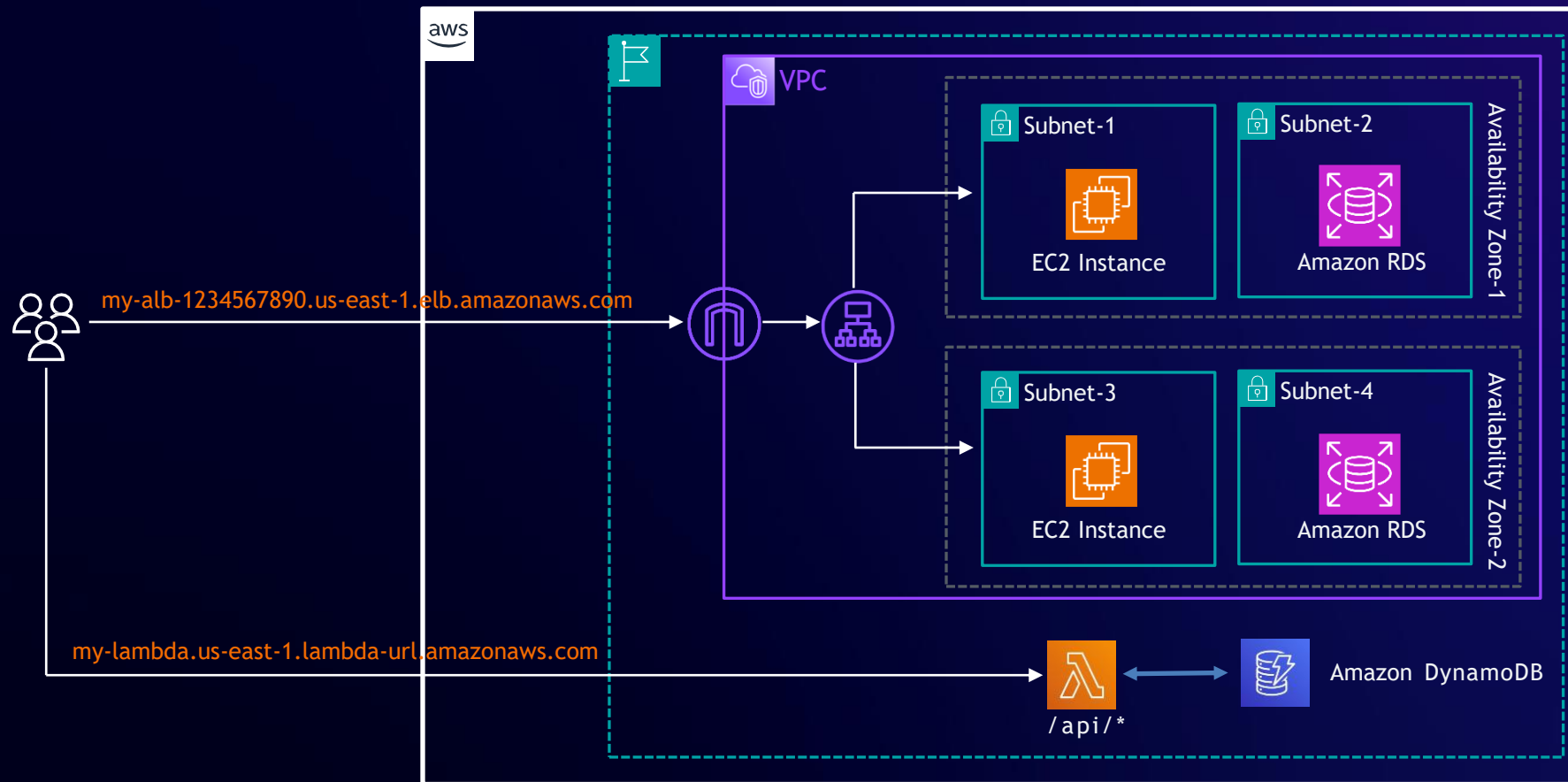
Different domains



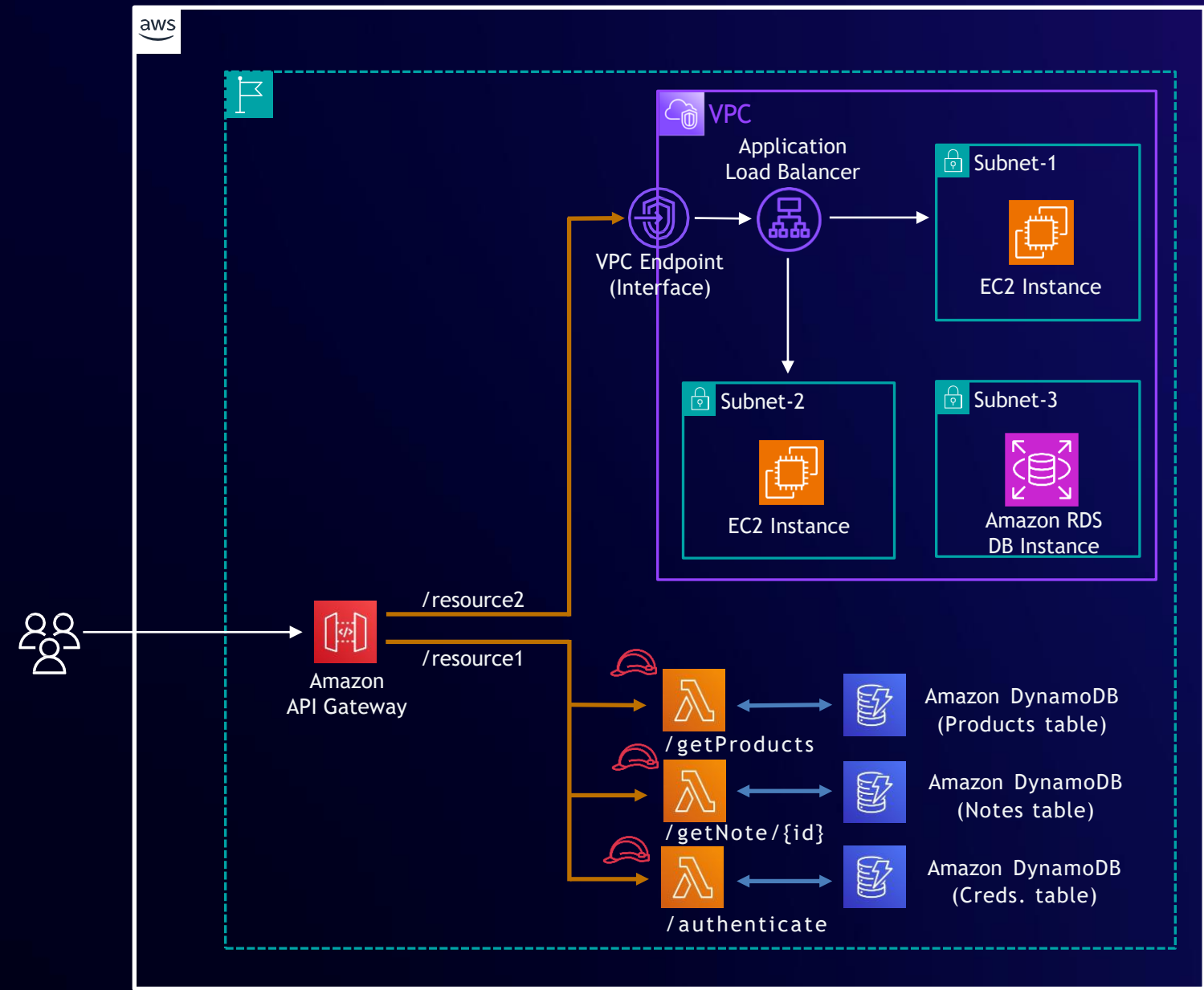
Design Challenges

Different domains

AuthN and AuthZ

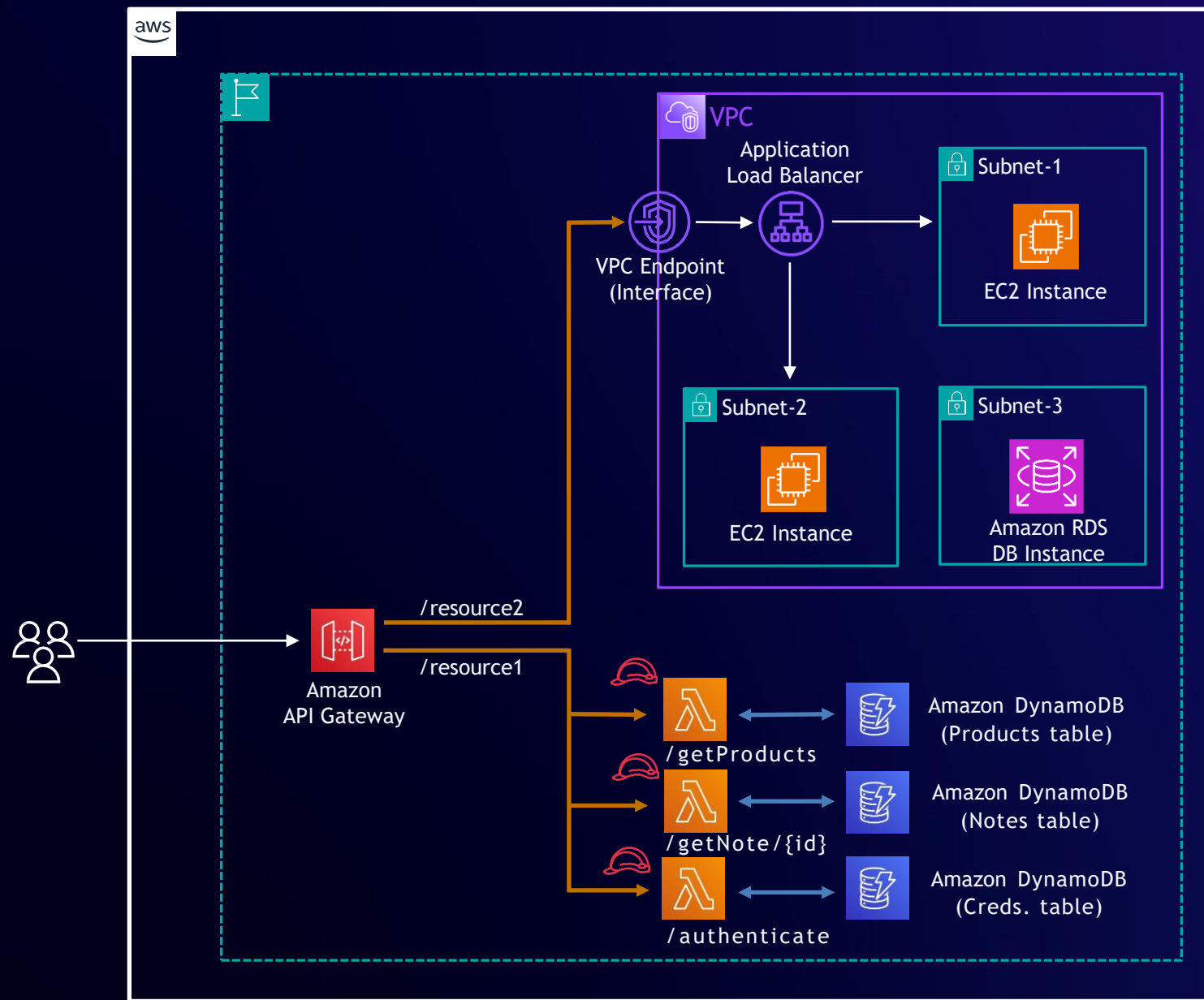


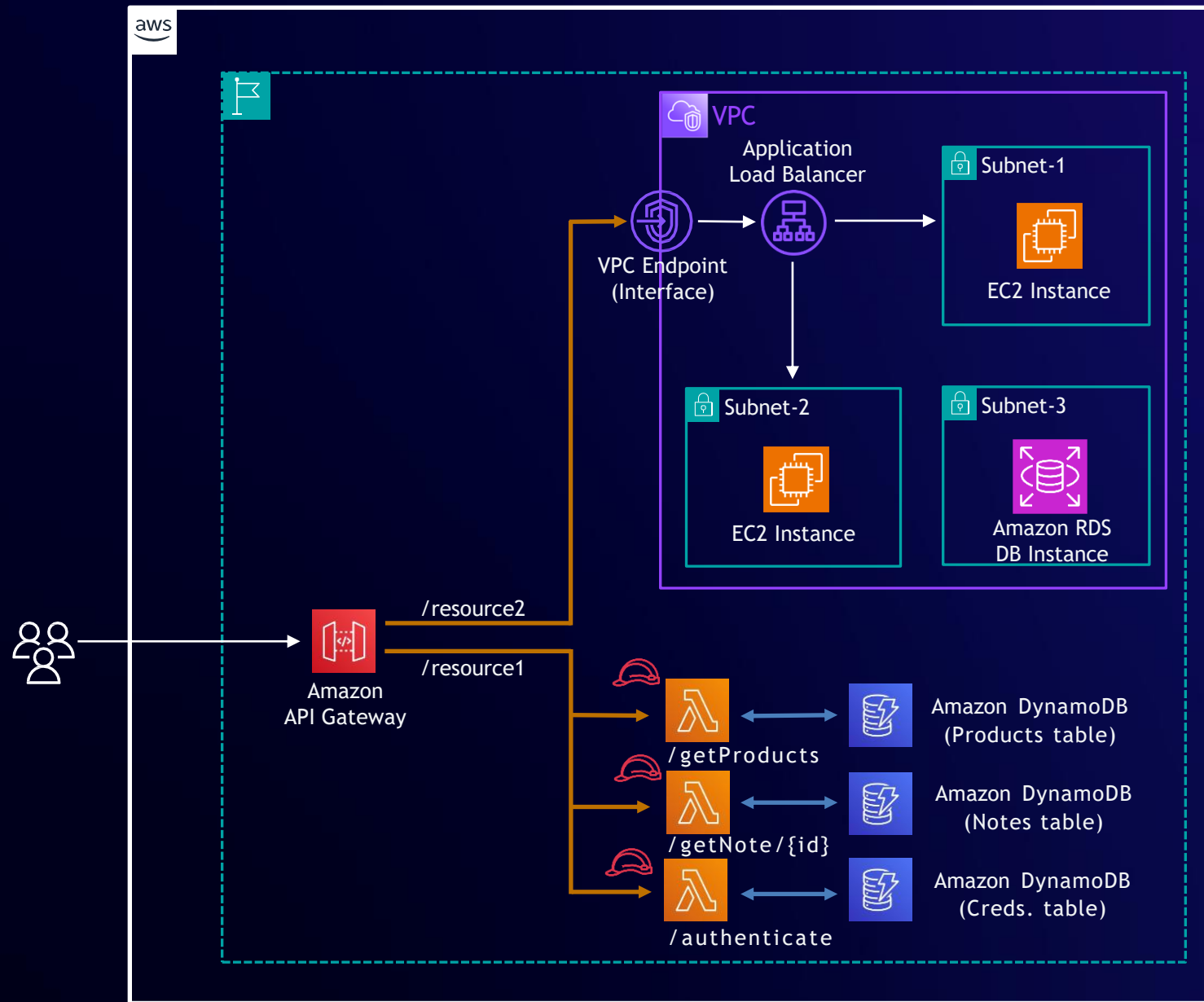
Amazon API Gateway



Amazon API Gateway

AuthN and AuthZ

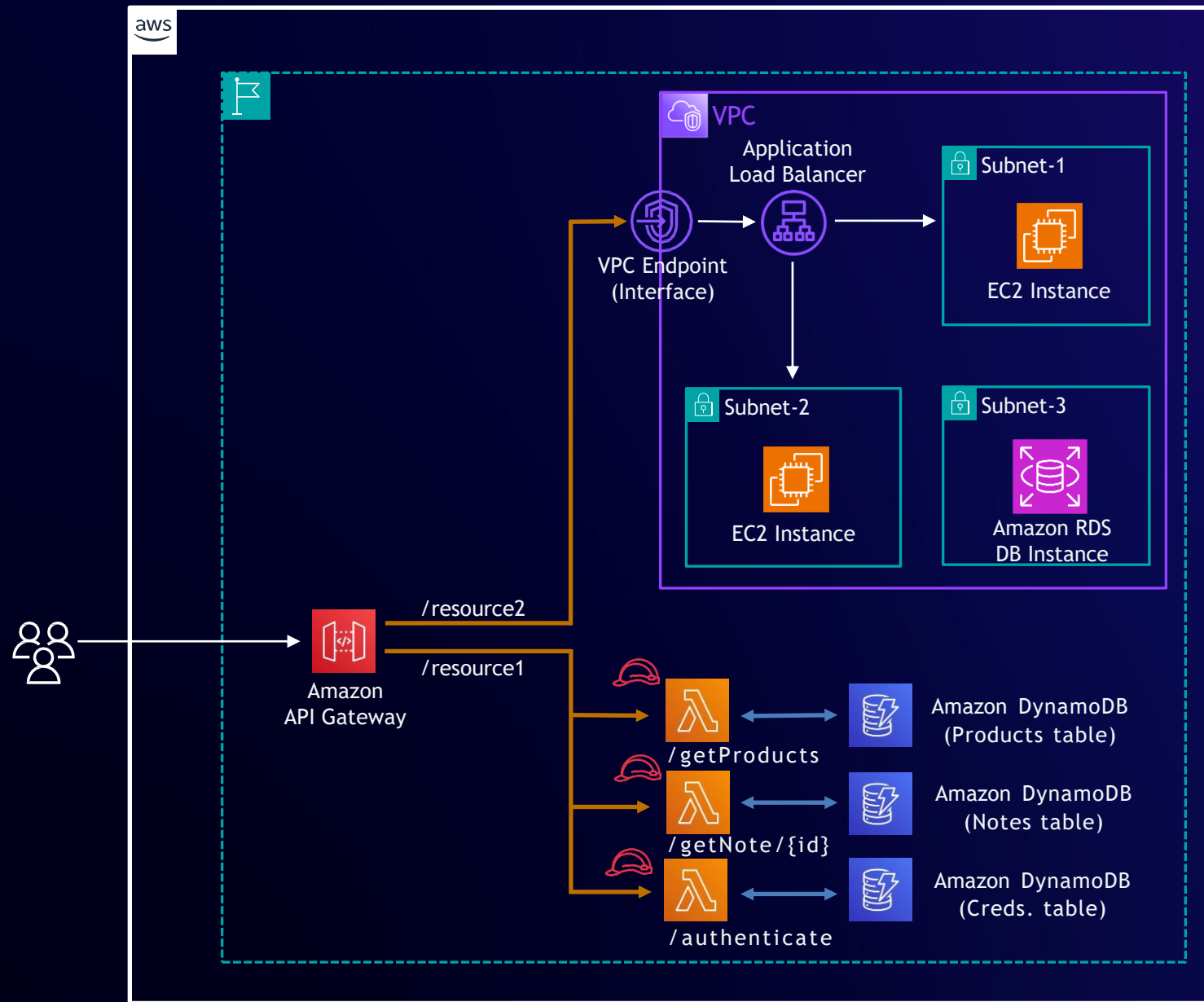




Amazon API Gateway

AuthN and AuthZ

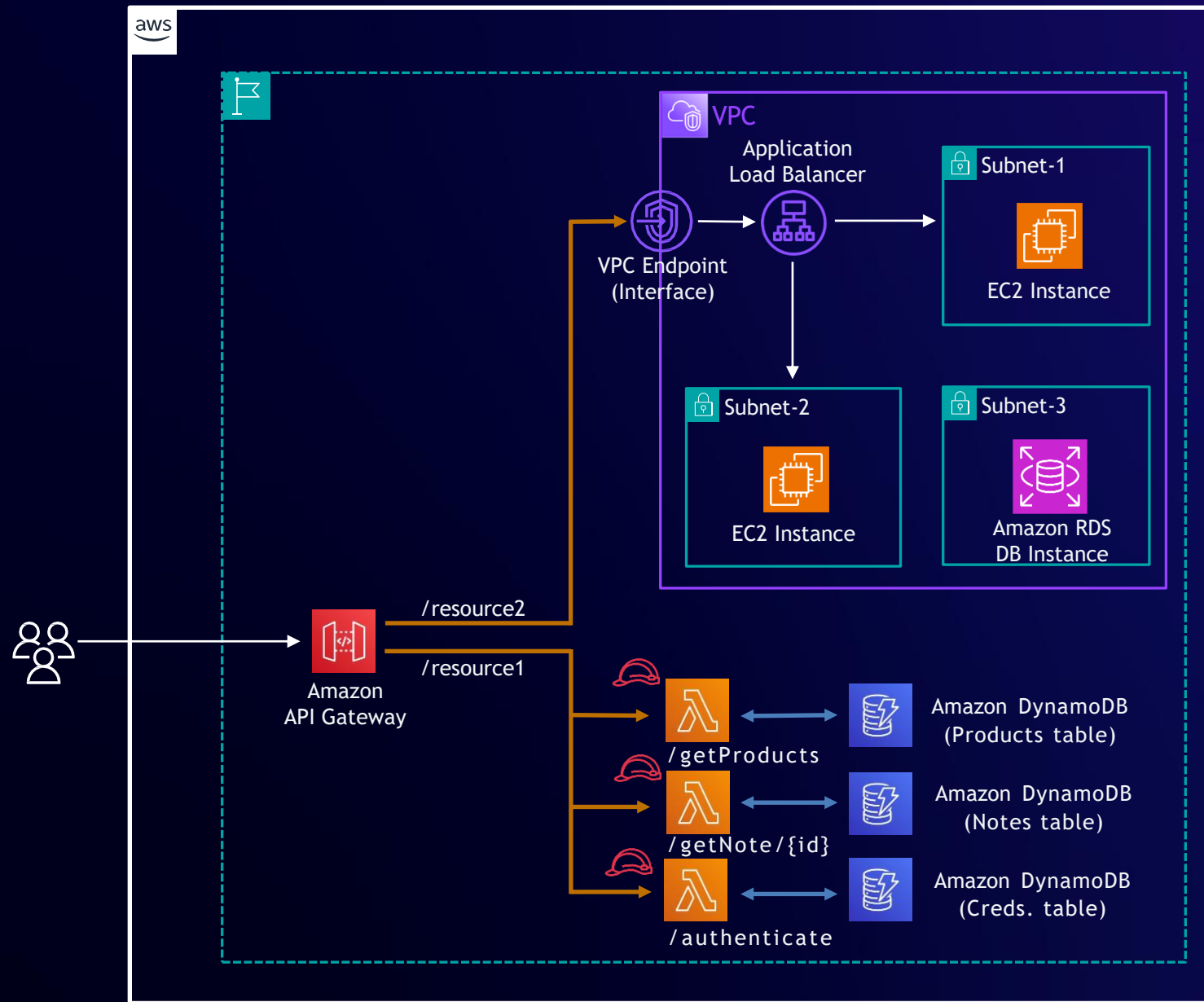
- IAM Authorization



Amazon API Gateway

AuthN and AuthZ

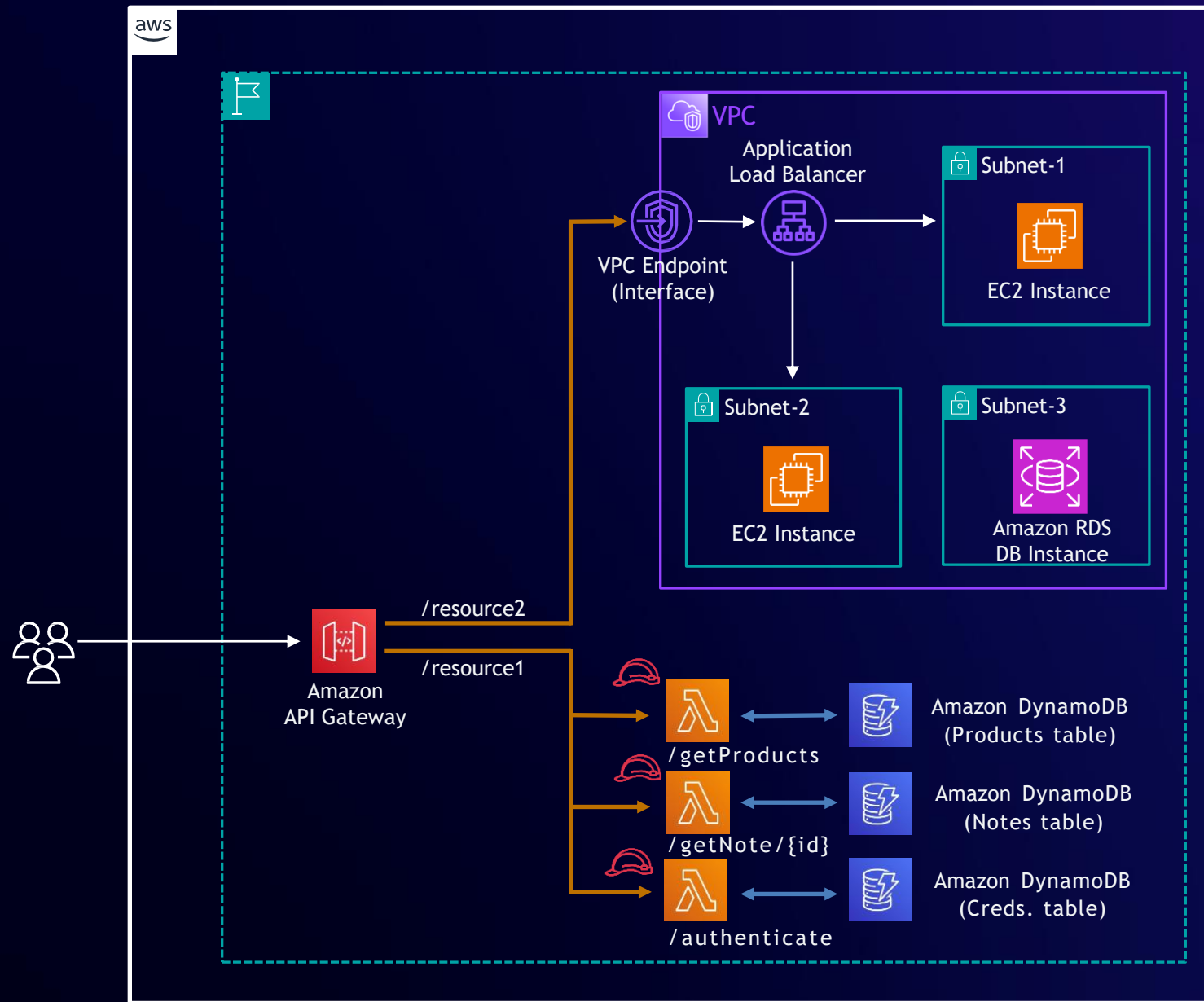
- IAM Authorization
- Cognito User Pools



Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pools
- **Lambda Authorizers**

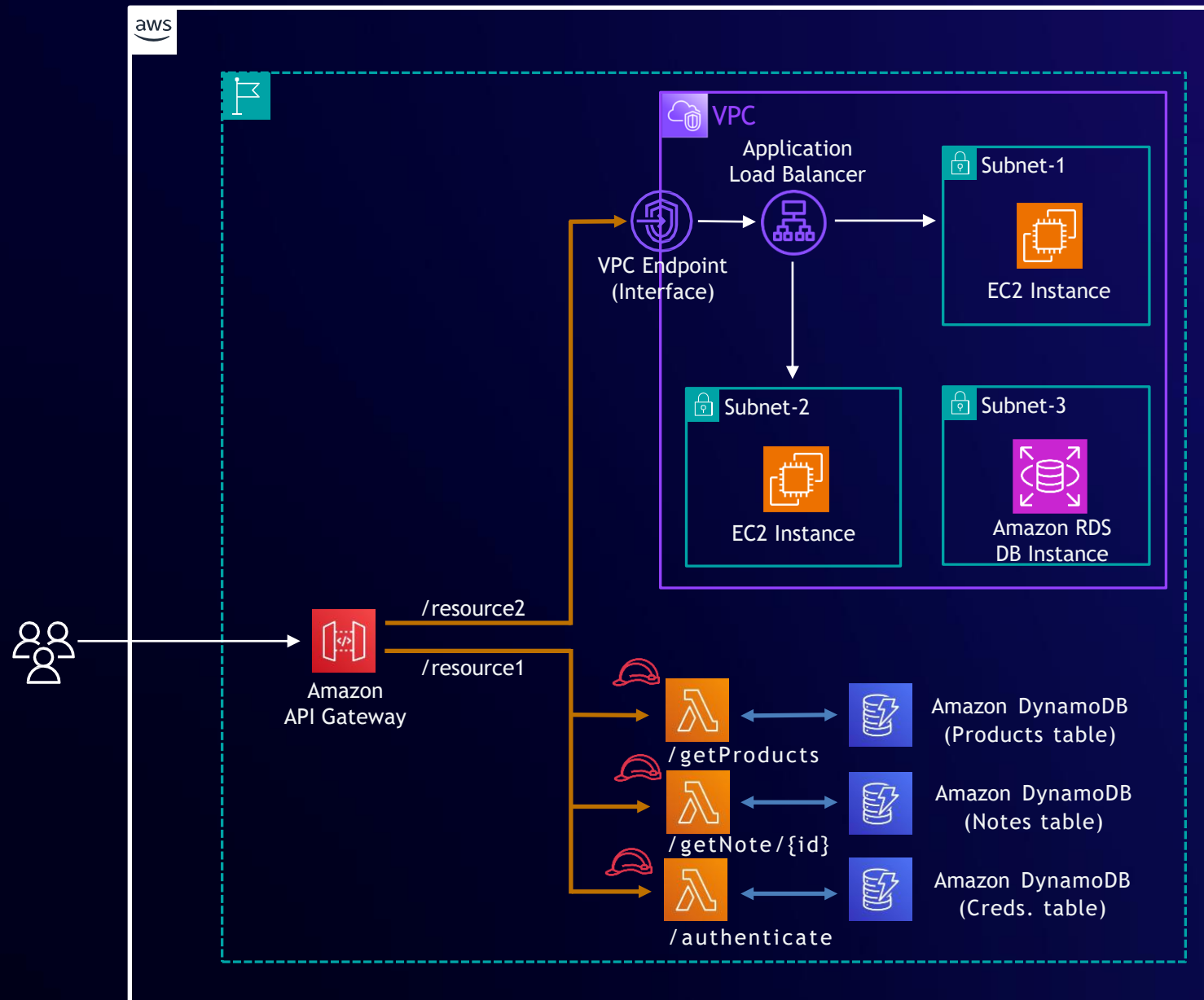


Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

TLS support



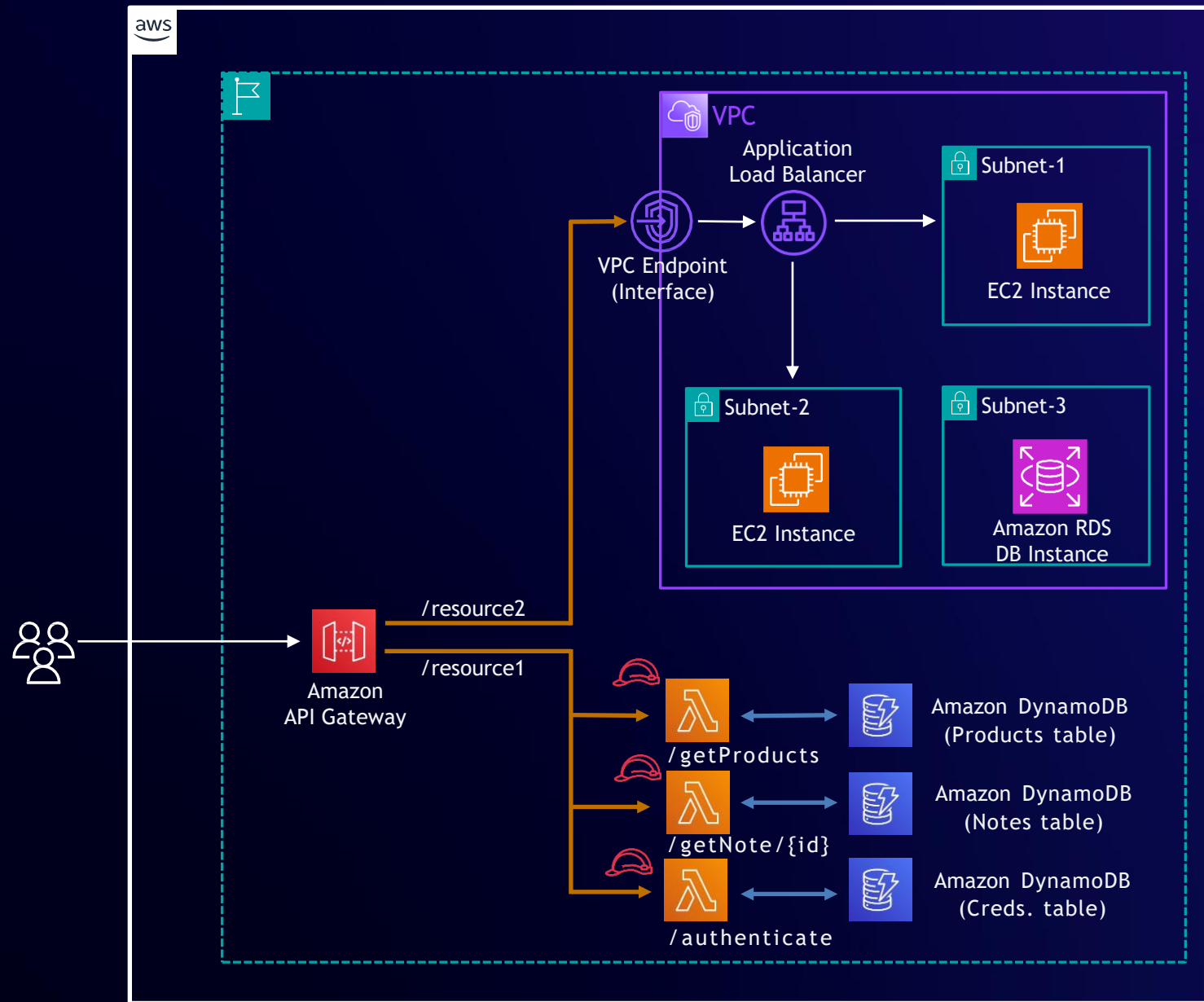
Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

TLS support

API Keys



Amazon API Gateway

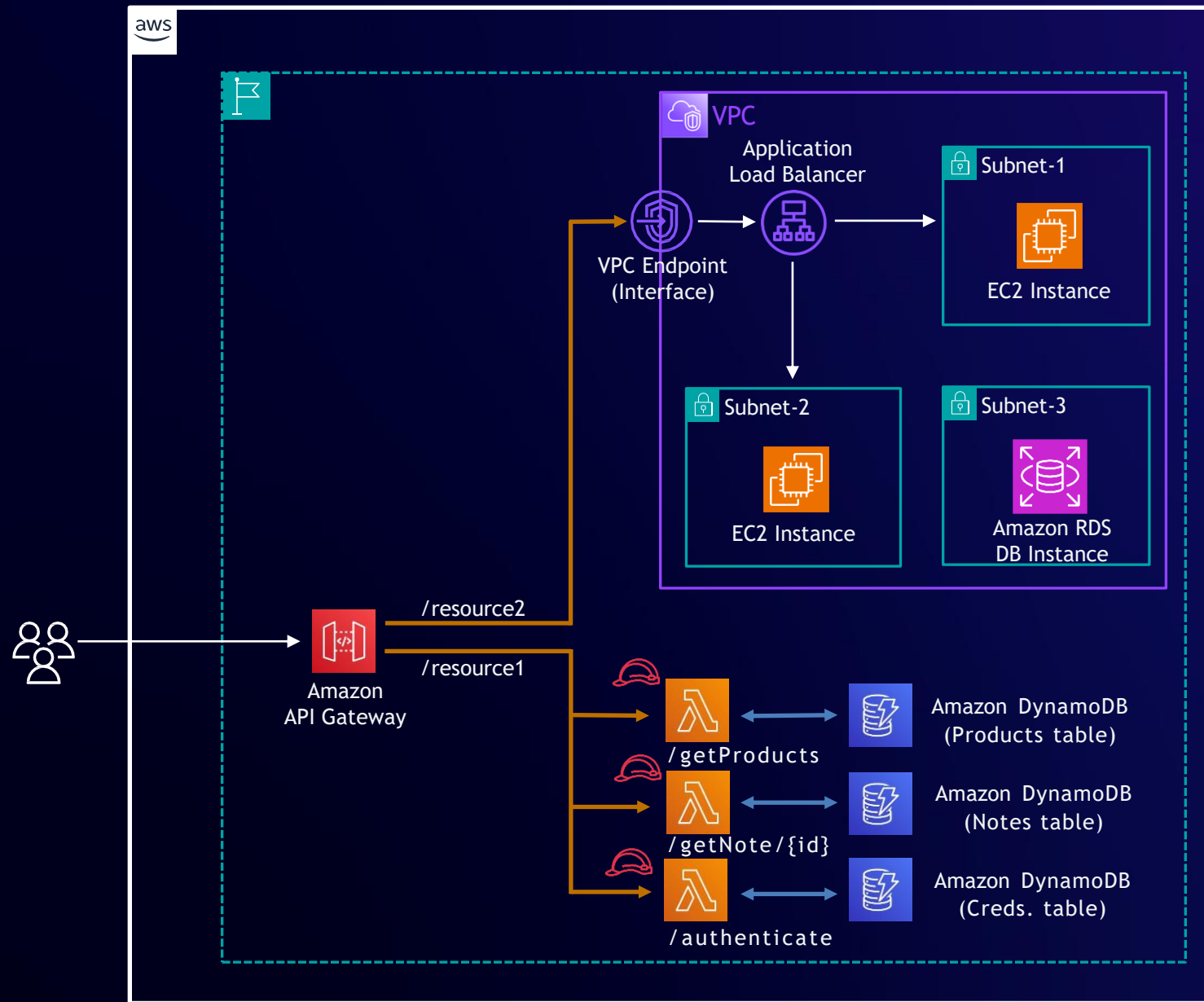
AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

TLS support

API Keys

Throttling and Quotas



Amazon API Gateway

AuthN and AuthZ

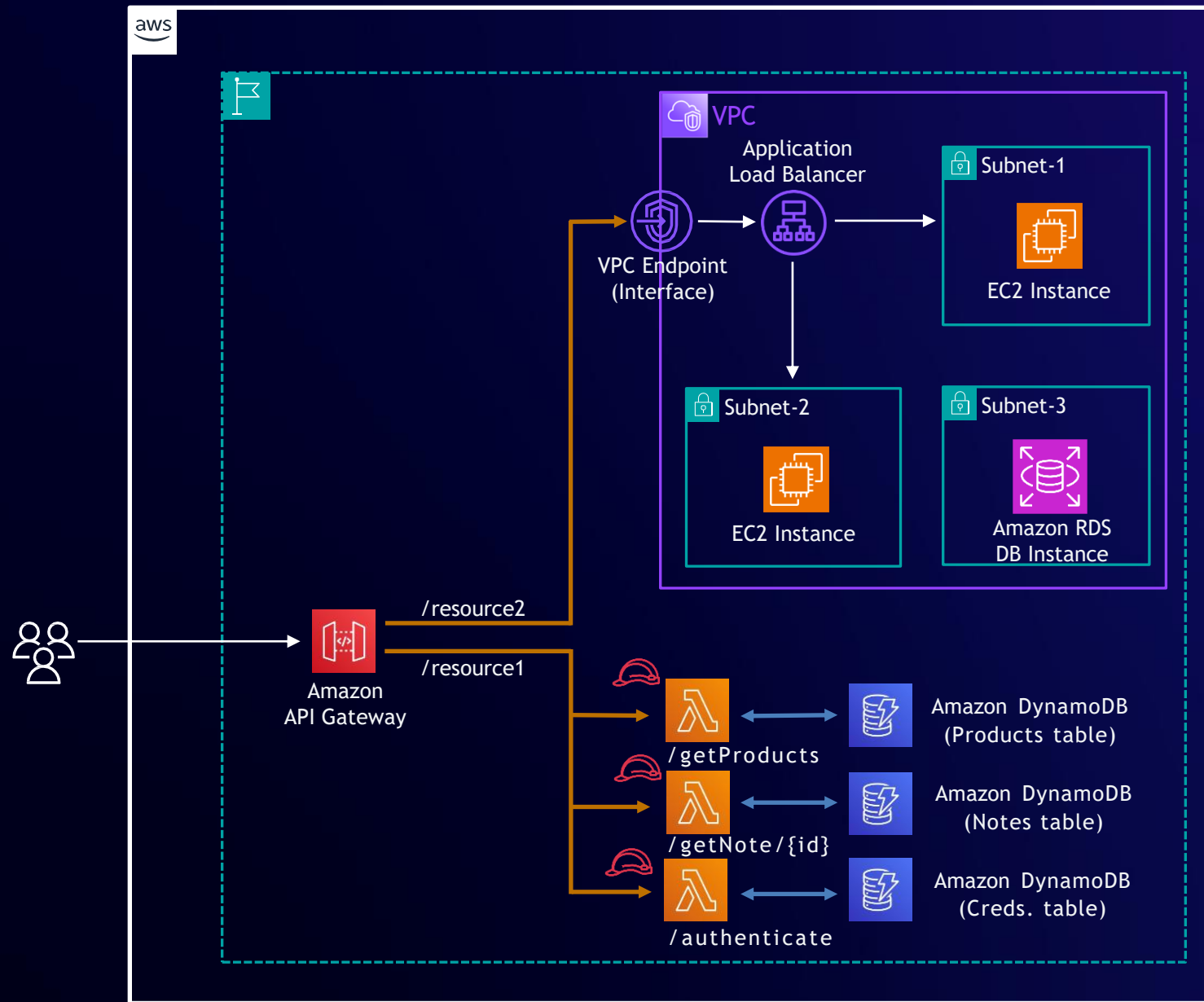
- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

TLS support

API Keys

Throttling and Quotas

Encryption



Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

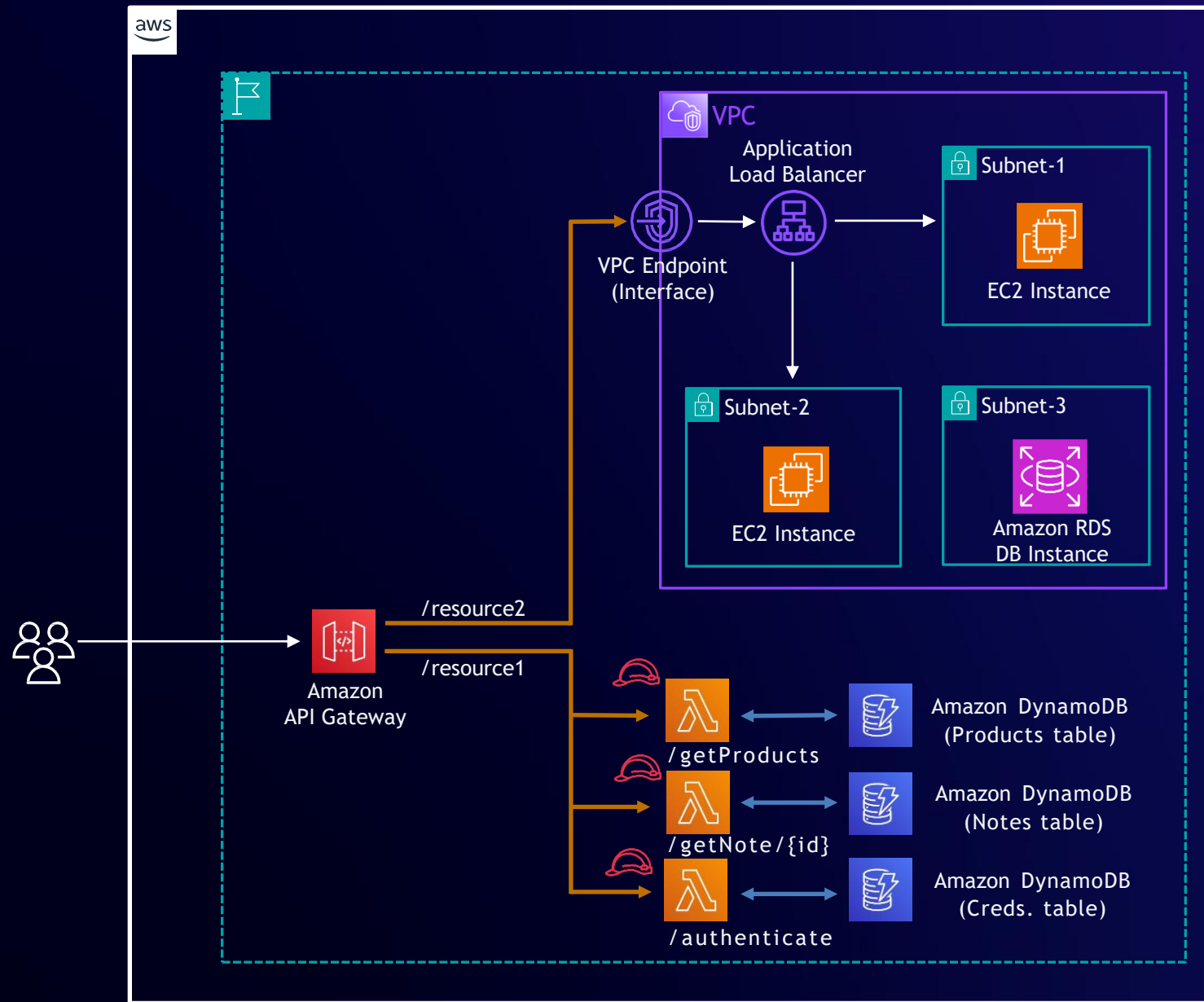
TLS support

API Keys

Throttling and Quotas

Encryption

- VPC Integration



Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

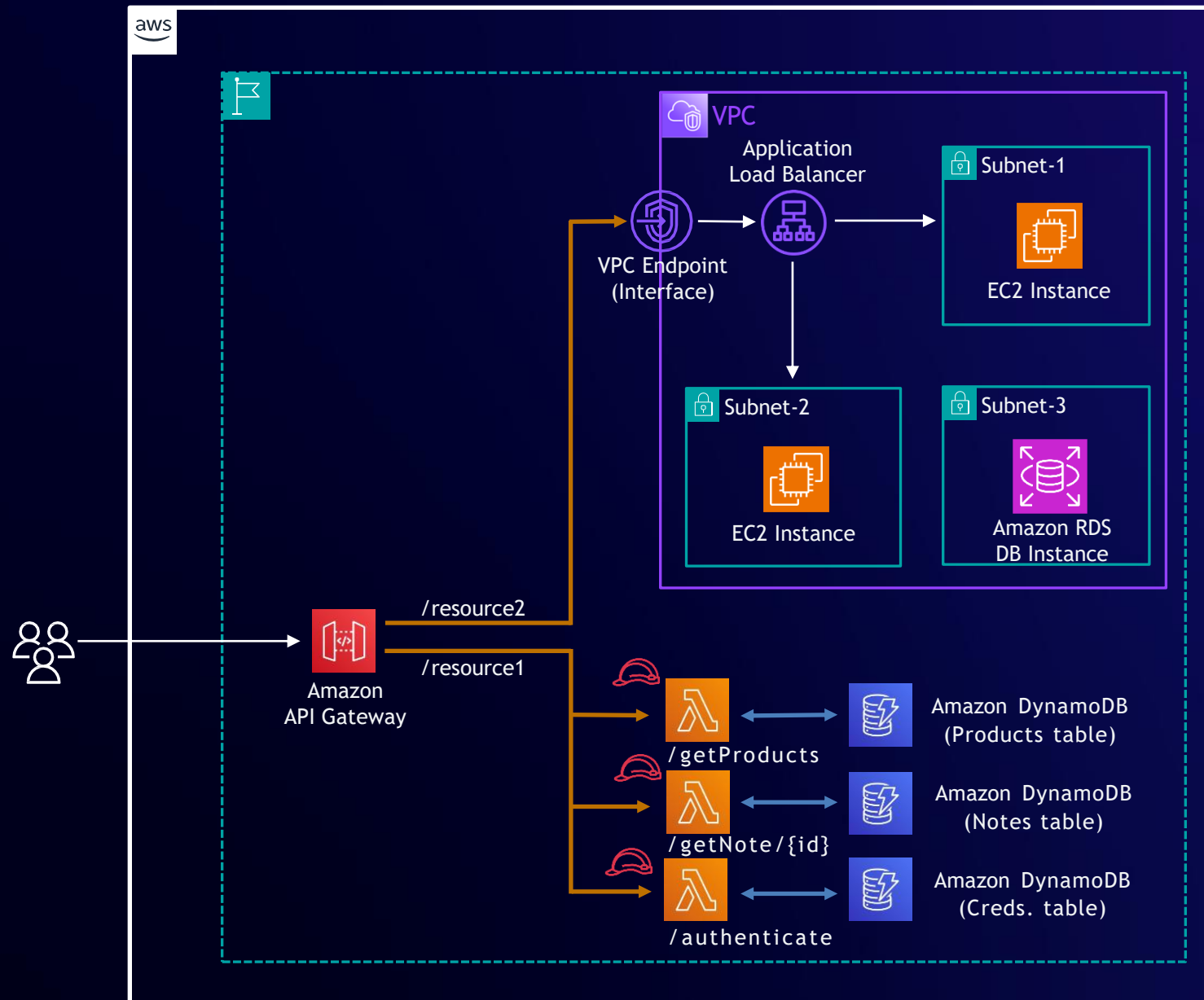
TLS support

API Keys

Throttling and Quotas

Encryption

- VPC Integration
- **KMS Integration**



Amazon API Gateway

AuthN and AuthZ

- IAM Authorization
- Cognito User Pool
- Lambda Authorizers

TLS support

API Keys

Throttling and Quotas

Encryption

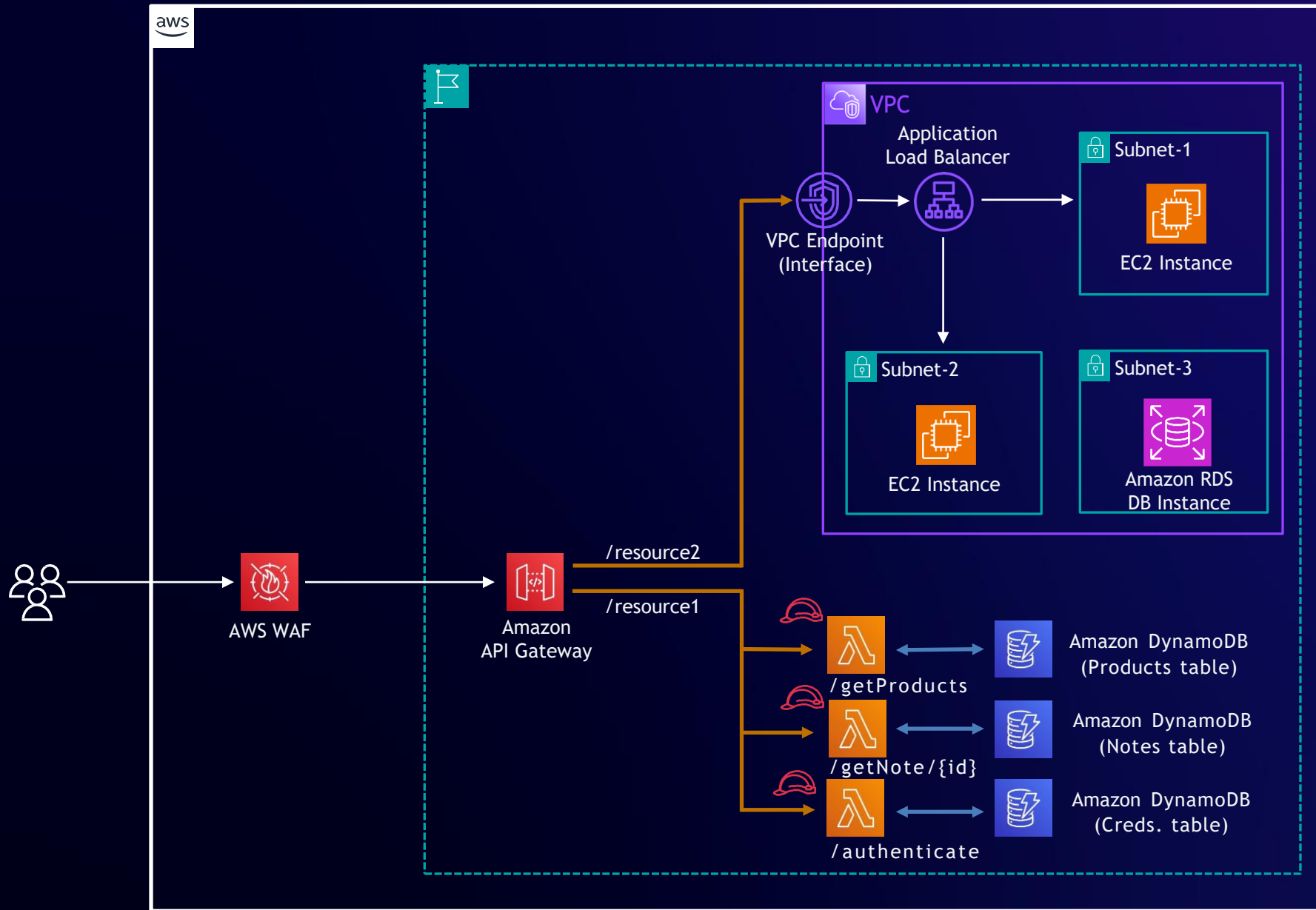
- VPC Integration
- KMS Integration

CORS

Q: How can we protect this architecture against Layer 7 attacks?

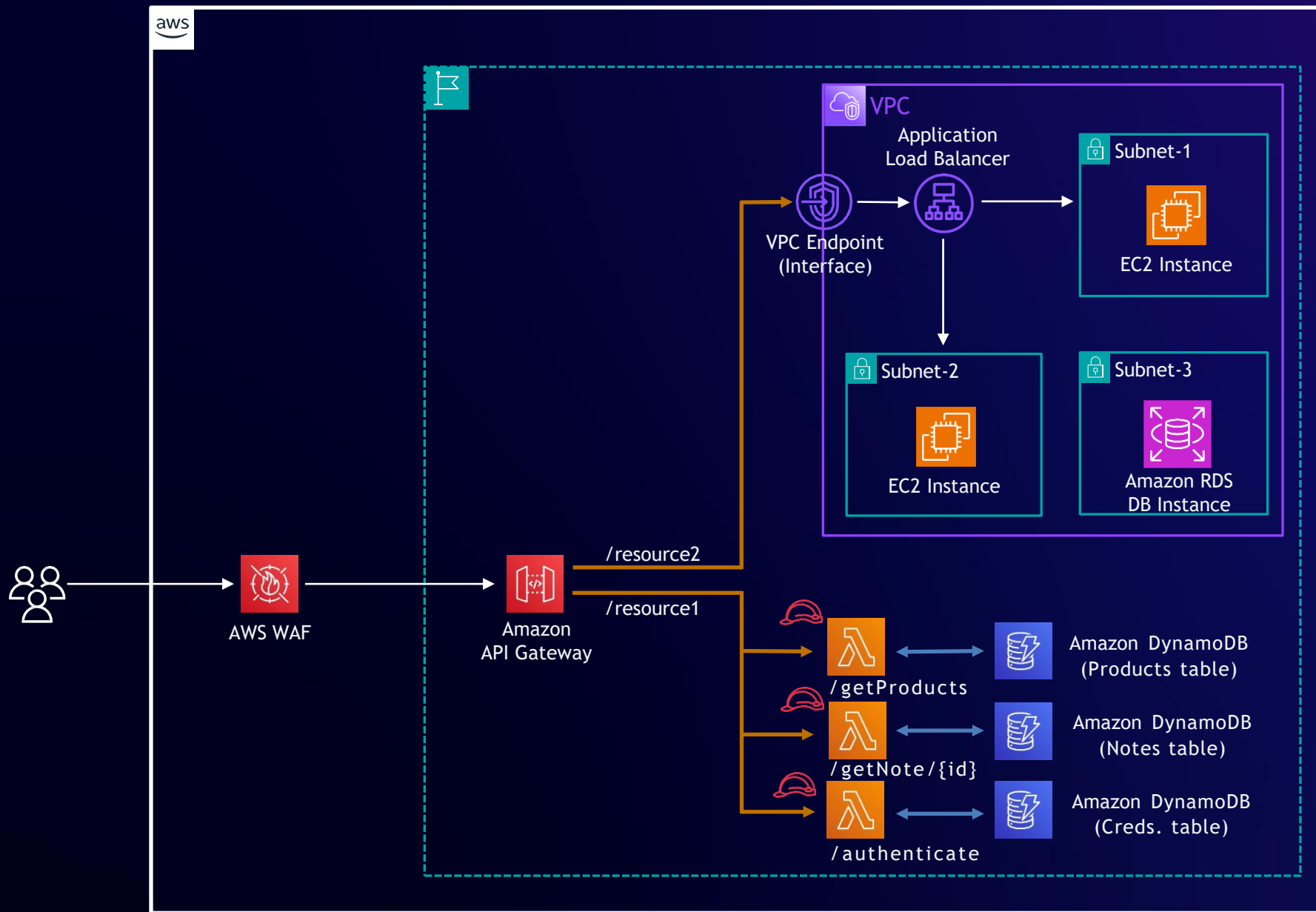
AWS Web Application Firewall (AWS WAF)

AWS WAF



AWS WAF

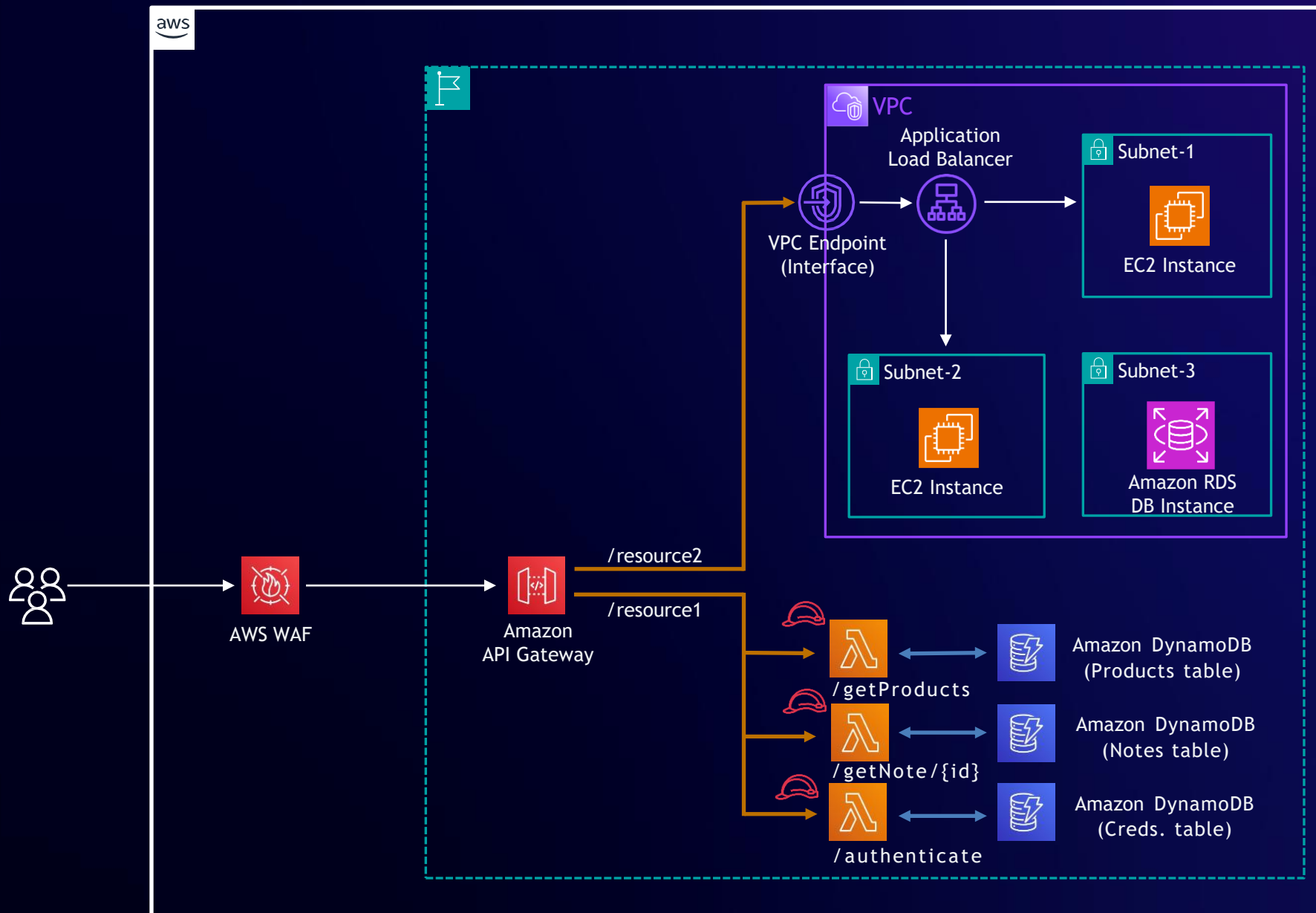
Web Security Rules

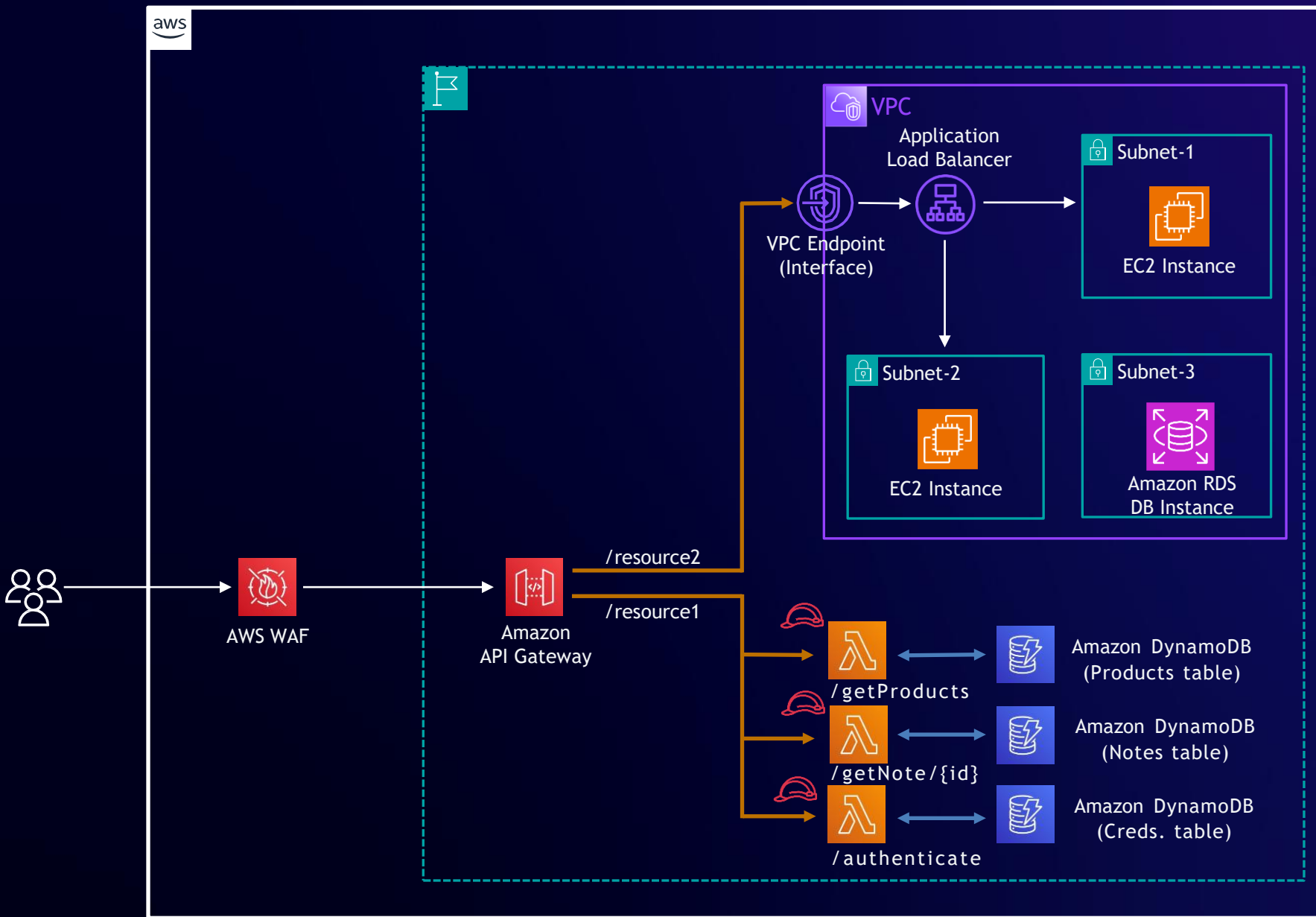


AWS WAF

Web Security Rules

- Customizable Rules

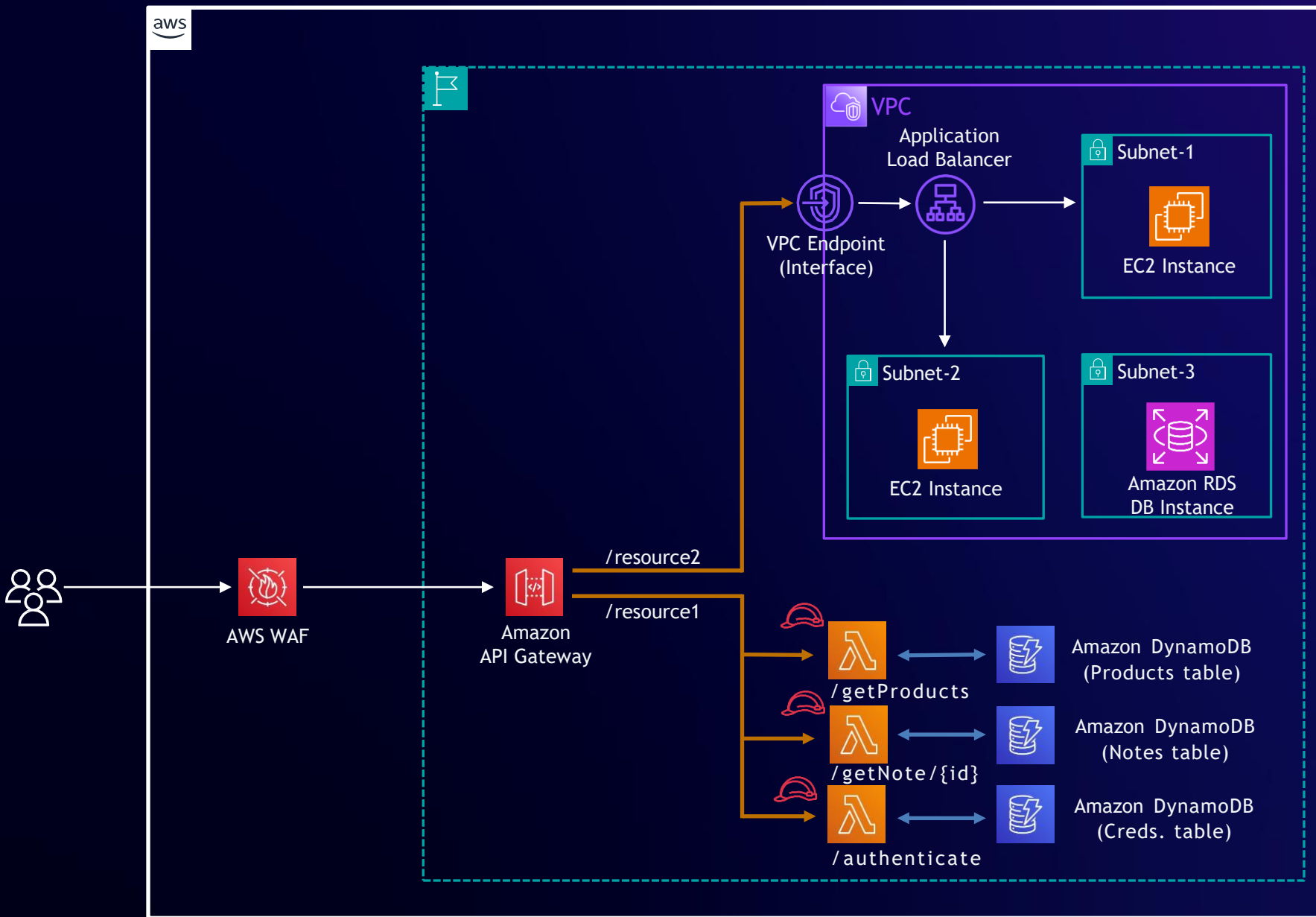




AWS WAF

Web Security Rules

- Customizable Rules
- **AWS Managed Rule**

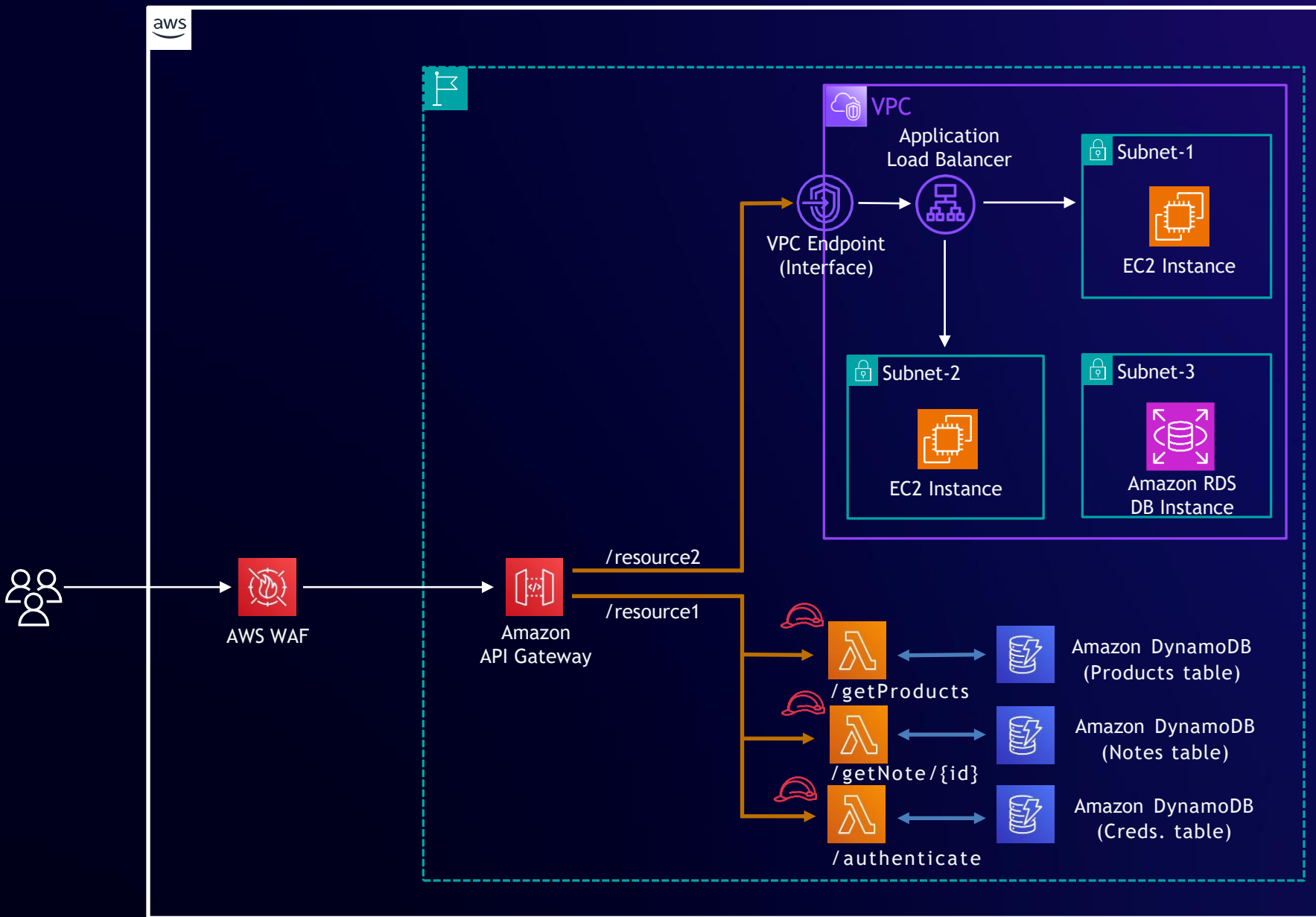


AWS WAF

Web Security Rules

- AWS Managed Rules
- AWS Managed Rule

Bot Control



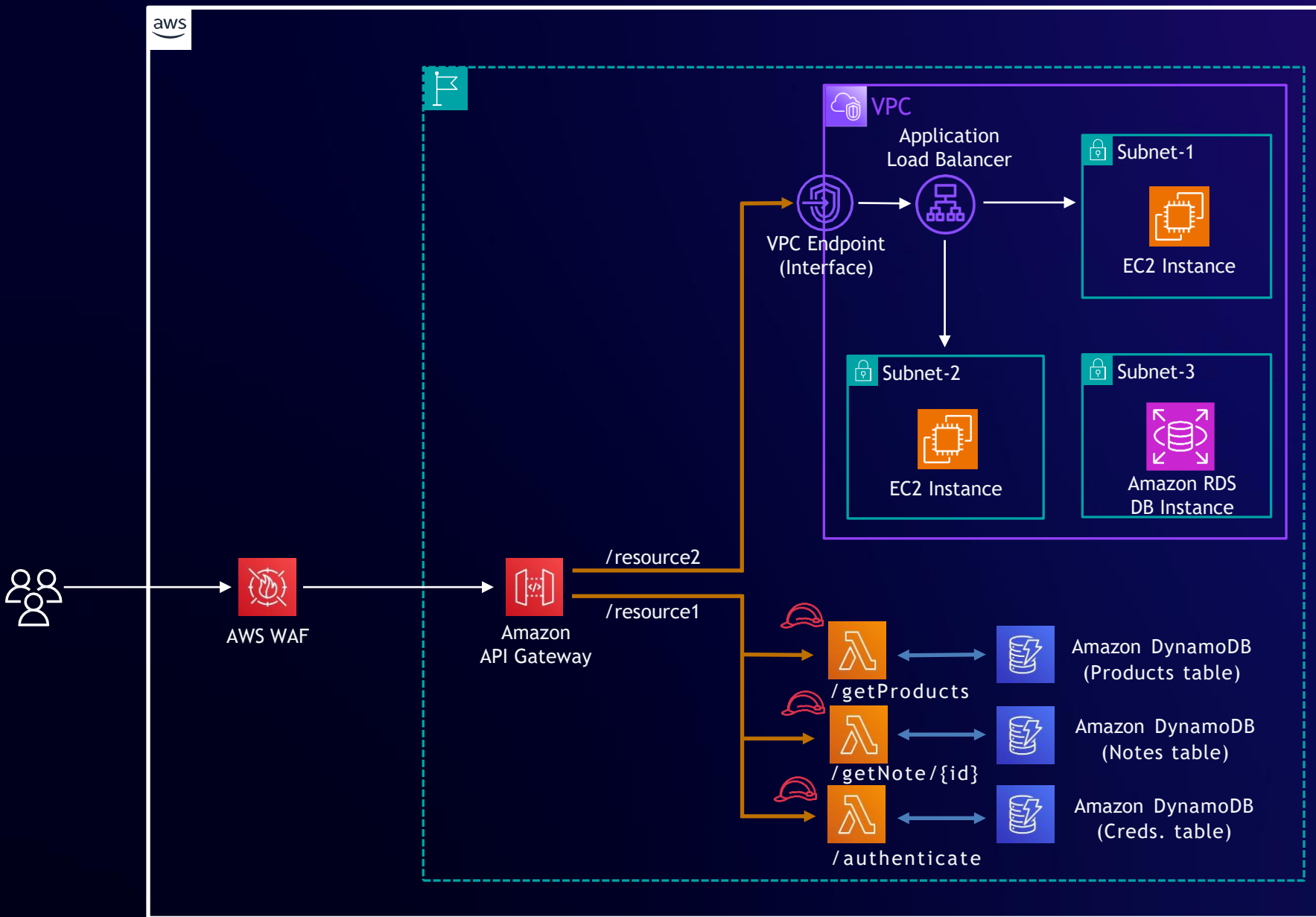
AWS WAF

Web Security Rules

- AWS Managed Rules
- AWS Managed Rule

Bot Control

IP Rate Limiting



AWS WAF

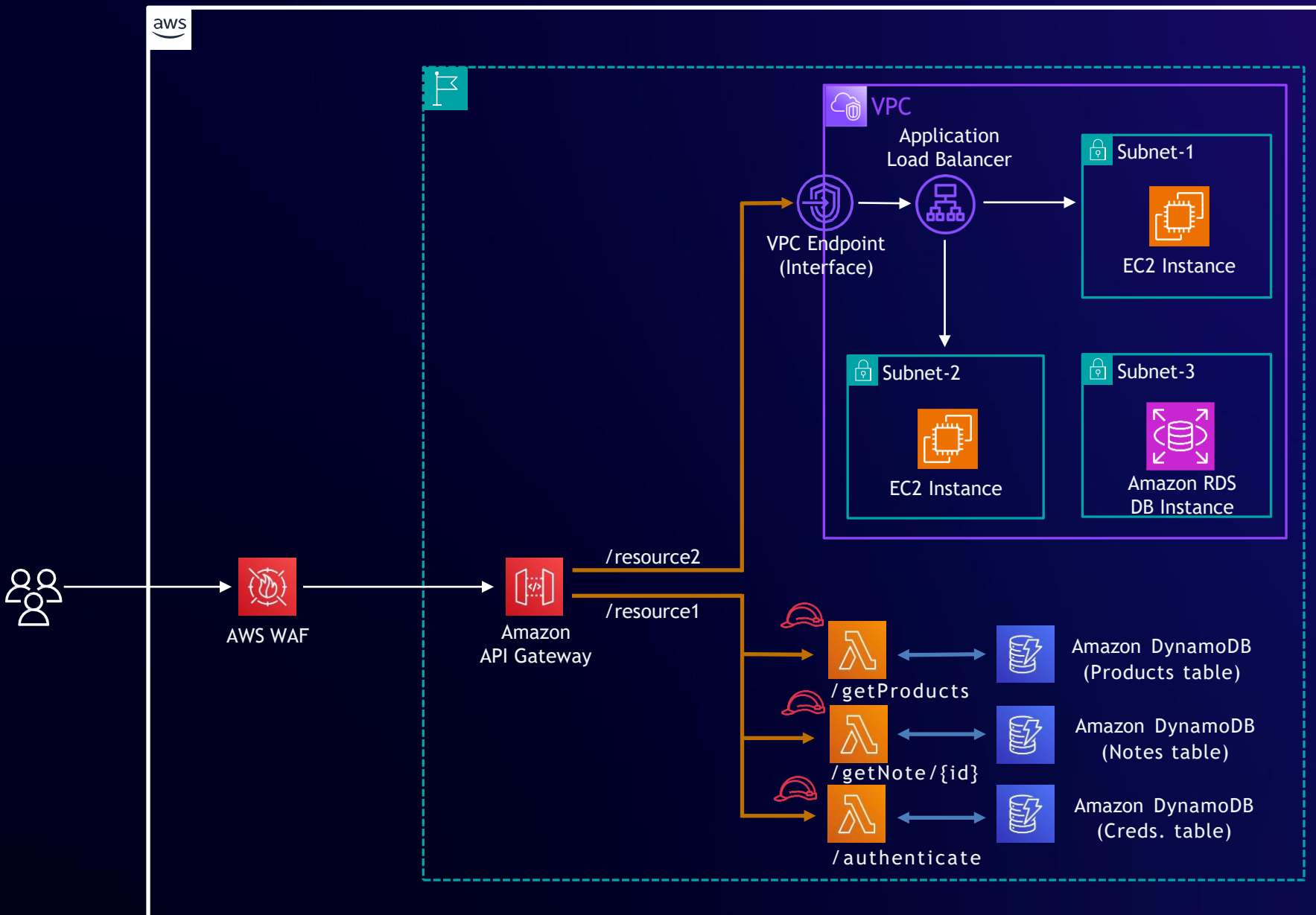
Web Security Rules

- AWS Managed Rules
- AWS Managed Rule

Bot Control

IP Rate Limiting

Geo-restriction



AWS WAF

Web Security Rules

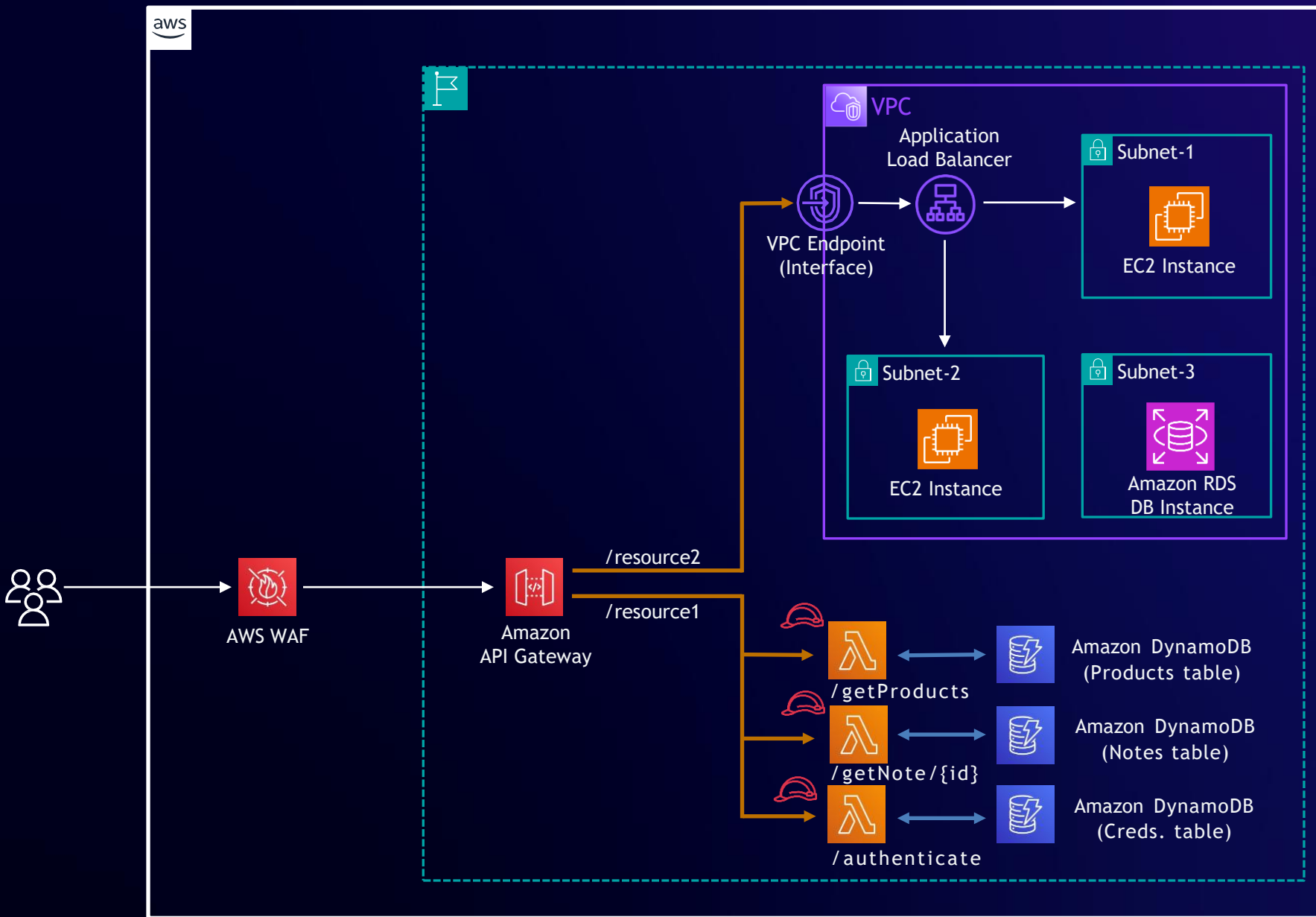
- AWS Managed Rules
- AWS Managed Rule

Bot Control

IP Rate Limiting

Geo-restriction

Logging and Monitoring



AWS WAF

Web Security Rules

- AWS Managed Rules
- AWS Managed Rule

Bot Control

IP Rate Limiting

Geo-restriction

Logging and Monitoring

- CloudWatch Metrics

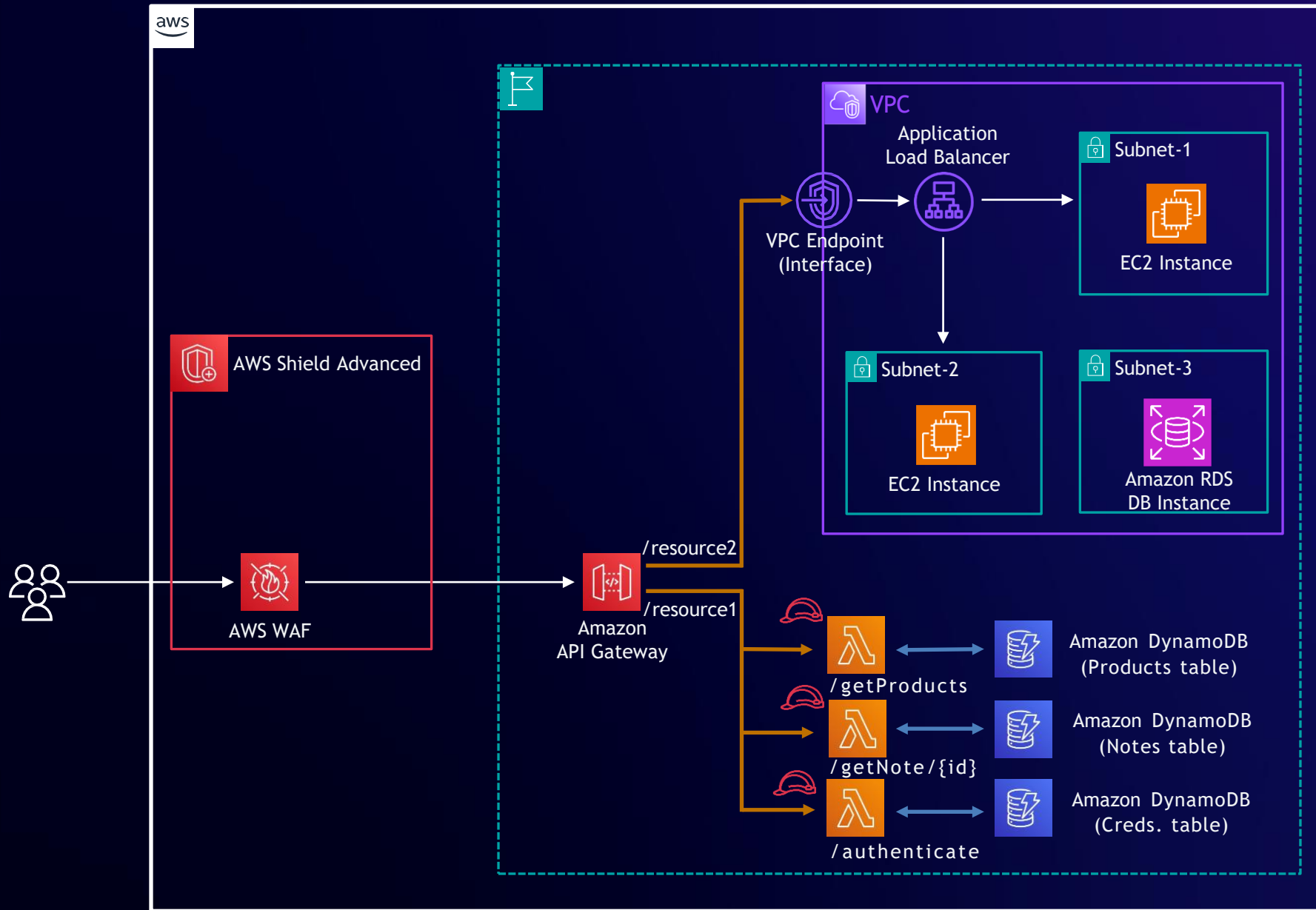
Where WAF Fits in Your Architecture



**Q: How can we protect this
architecture against Layer 3/4
attacks?**

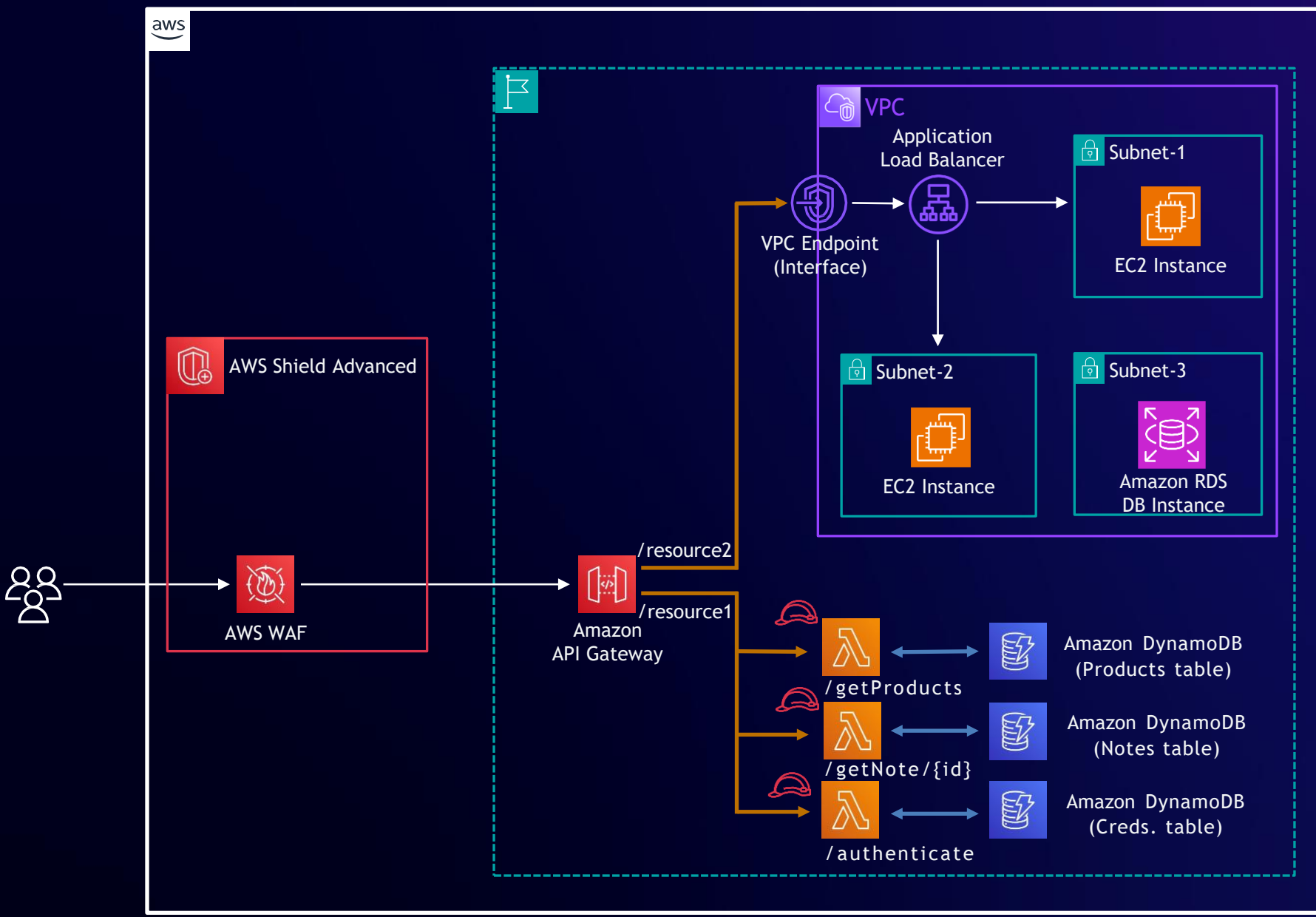
AWS SHIELD ADVANCED

AWS Shield Advanced



AWS Shield Advanced

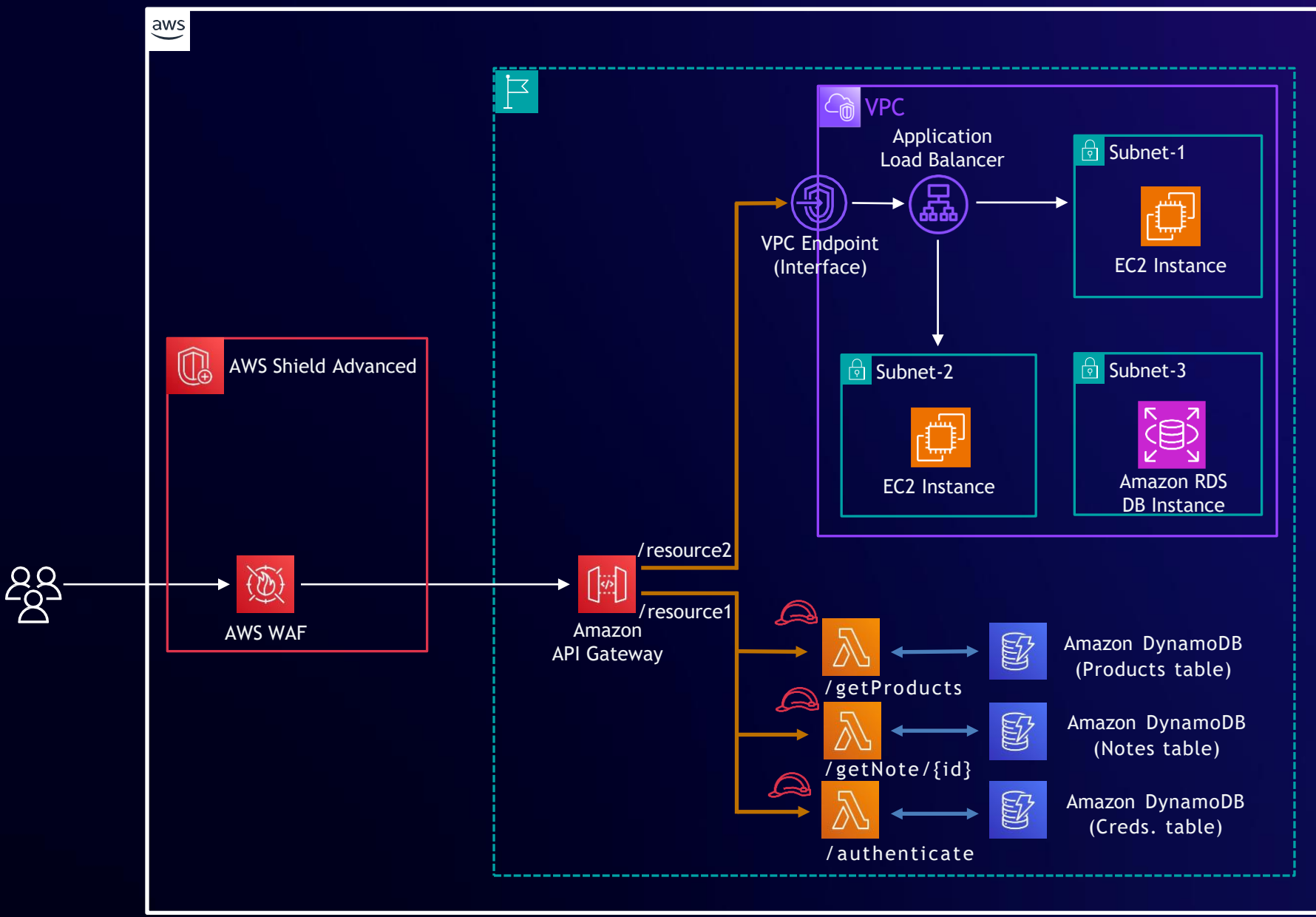
DDoS Protection



AWS Shield Advanced

DDoS Protection

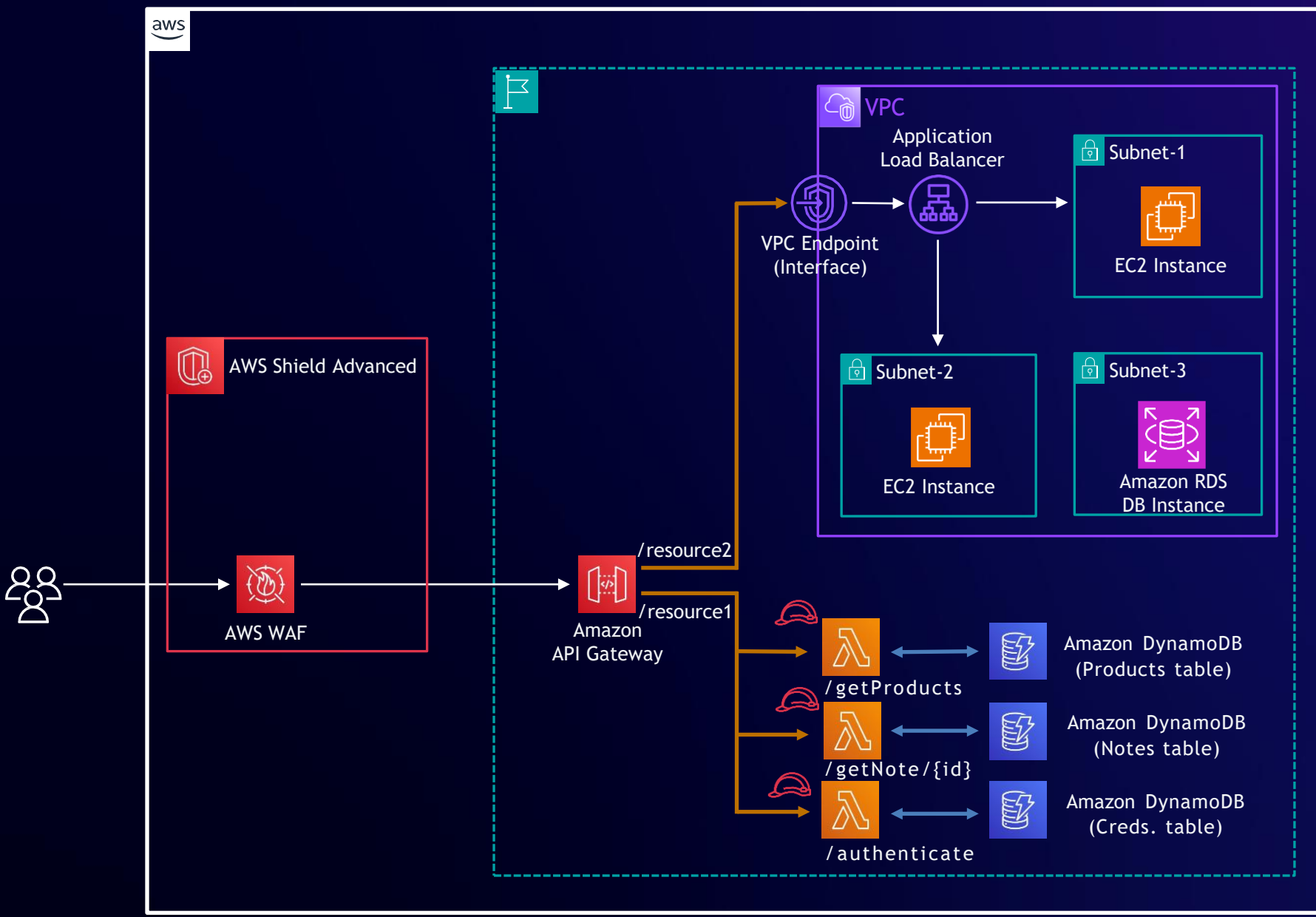
- at Layer 3/4

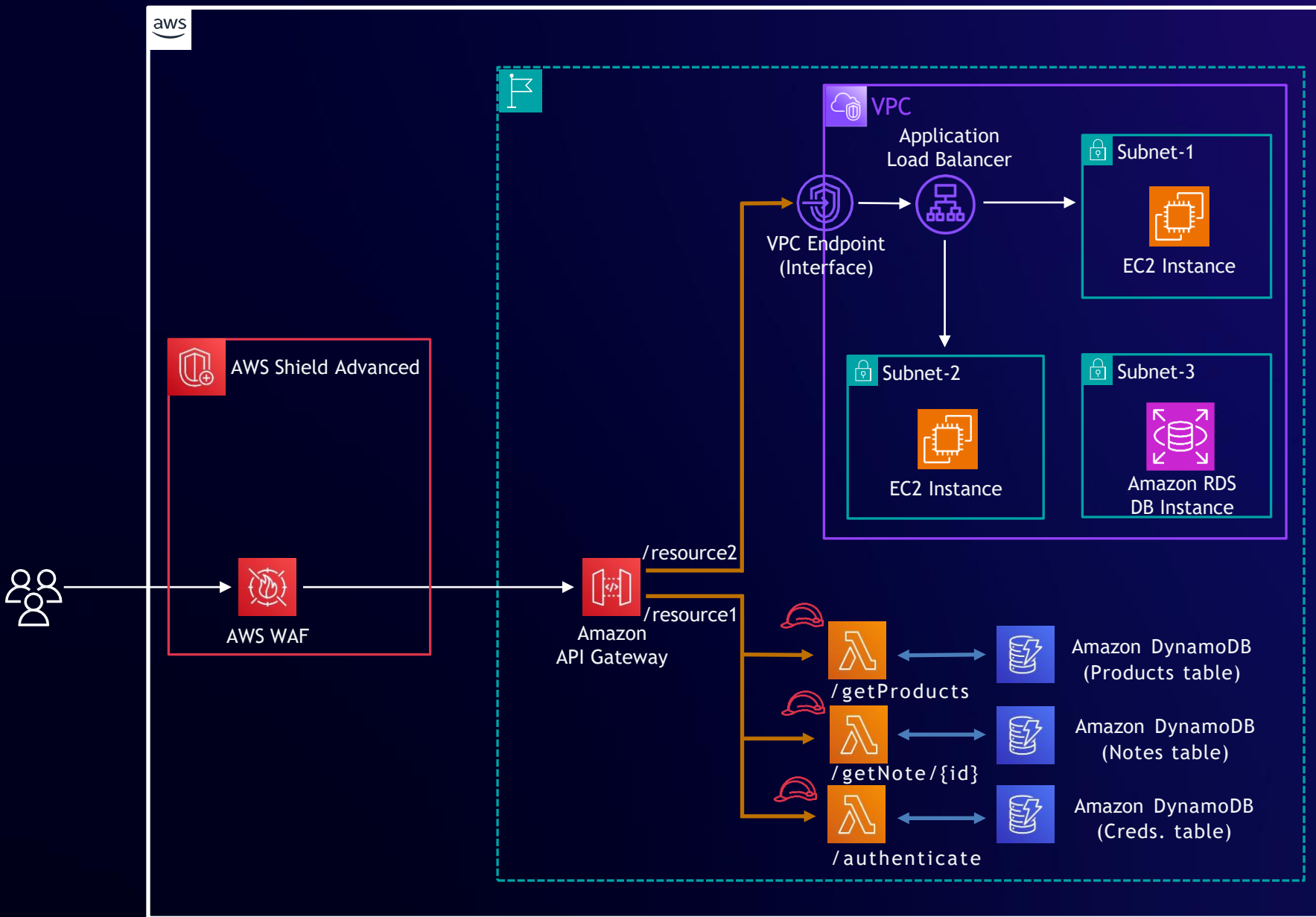


AWS Shield Advanced

DDoS Protection

- at Layer 3/4
- at Layer 7



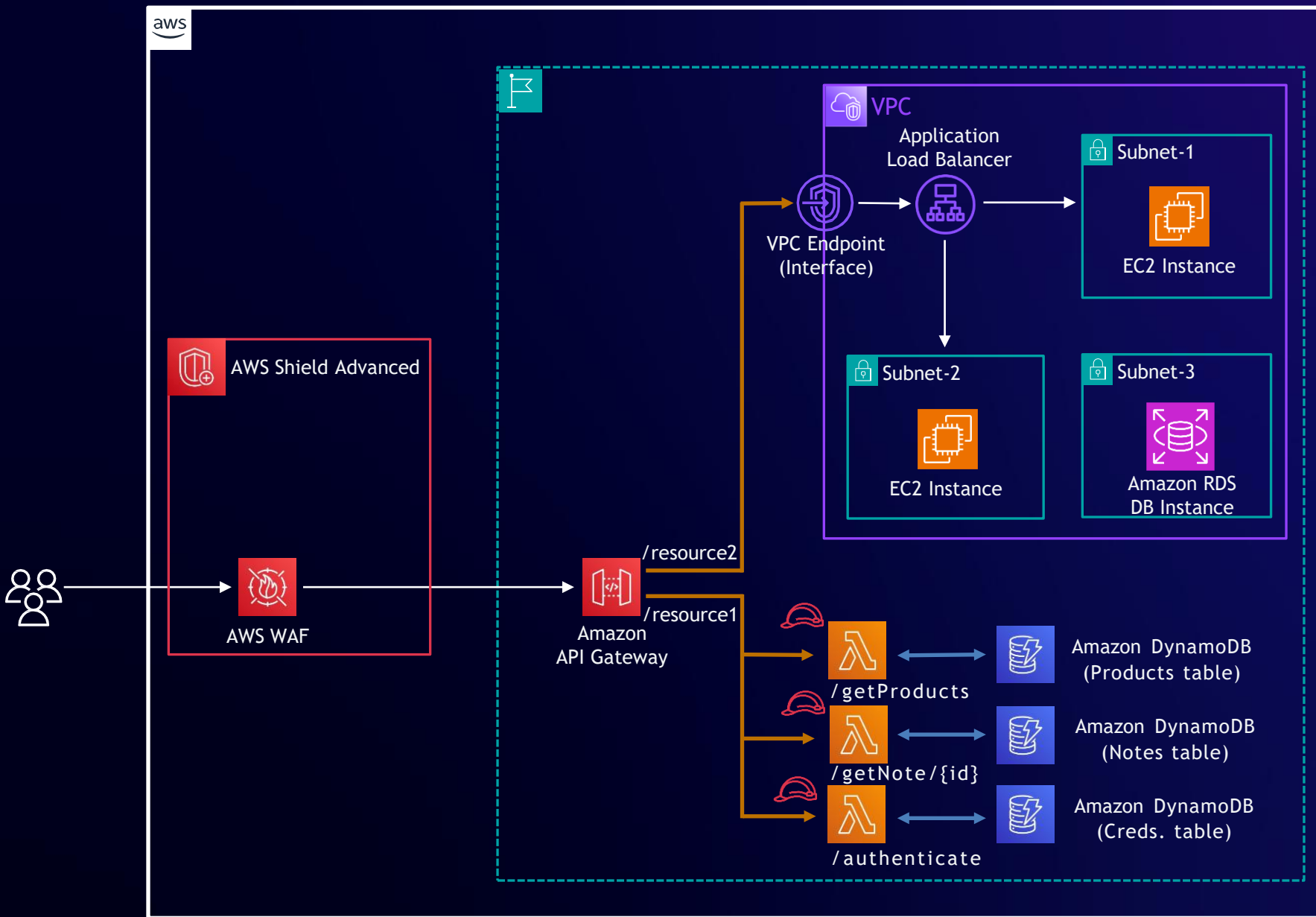


AWS Shield Advanced

DDoS Protection

- at Layer 3/4
- at Layer 7

Real-time Insights



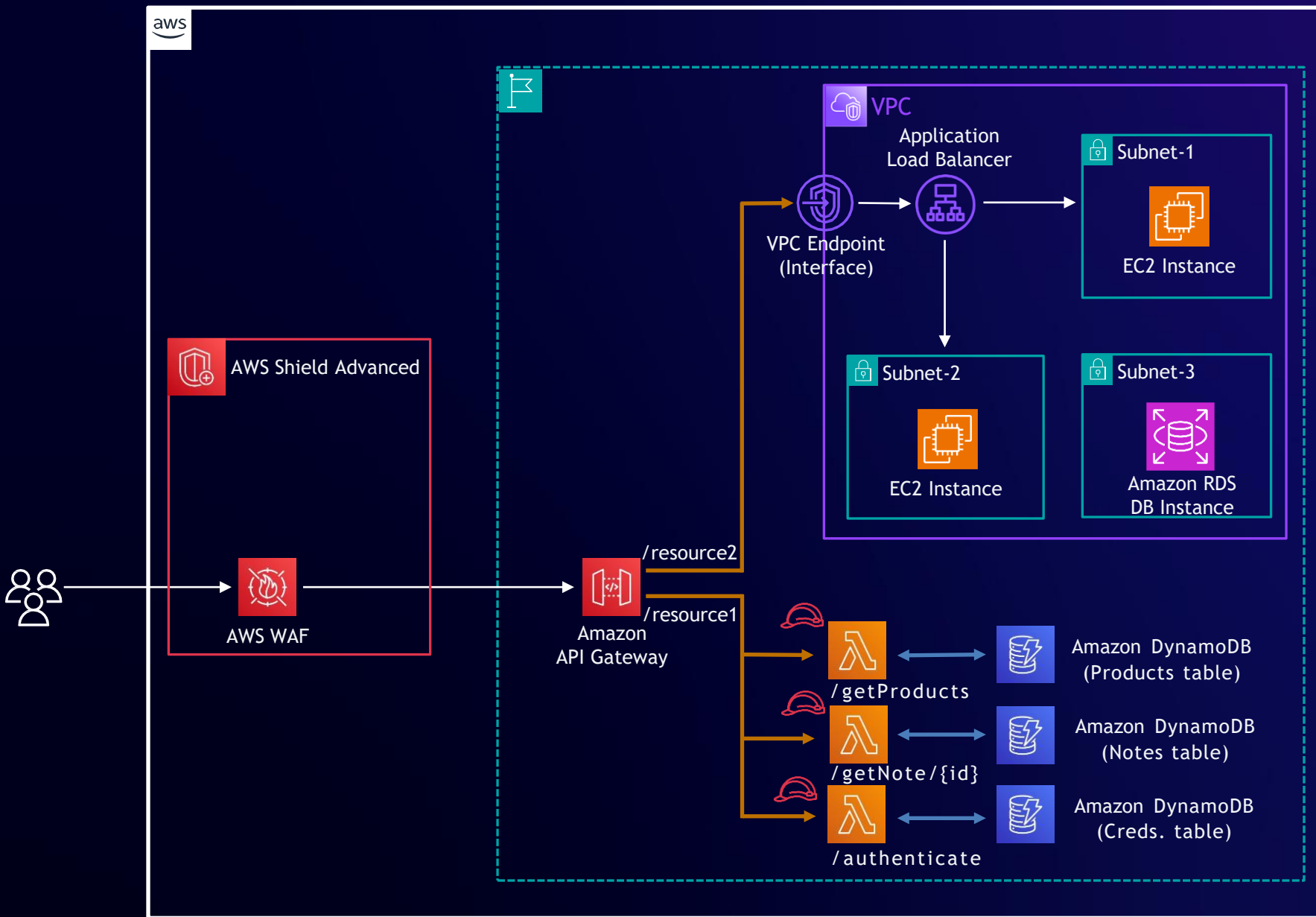
AWS Shield Advanced

DDoS Protection

- at Layer 3/4
- at Layer 7

Real-time Insights

AWS WAF Integration



AWS Shield Advanced

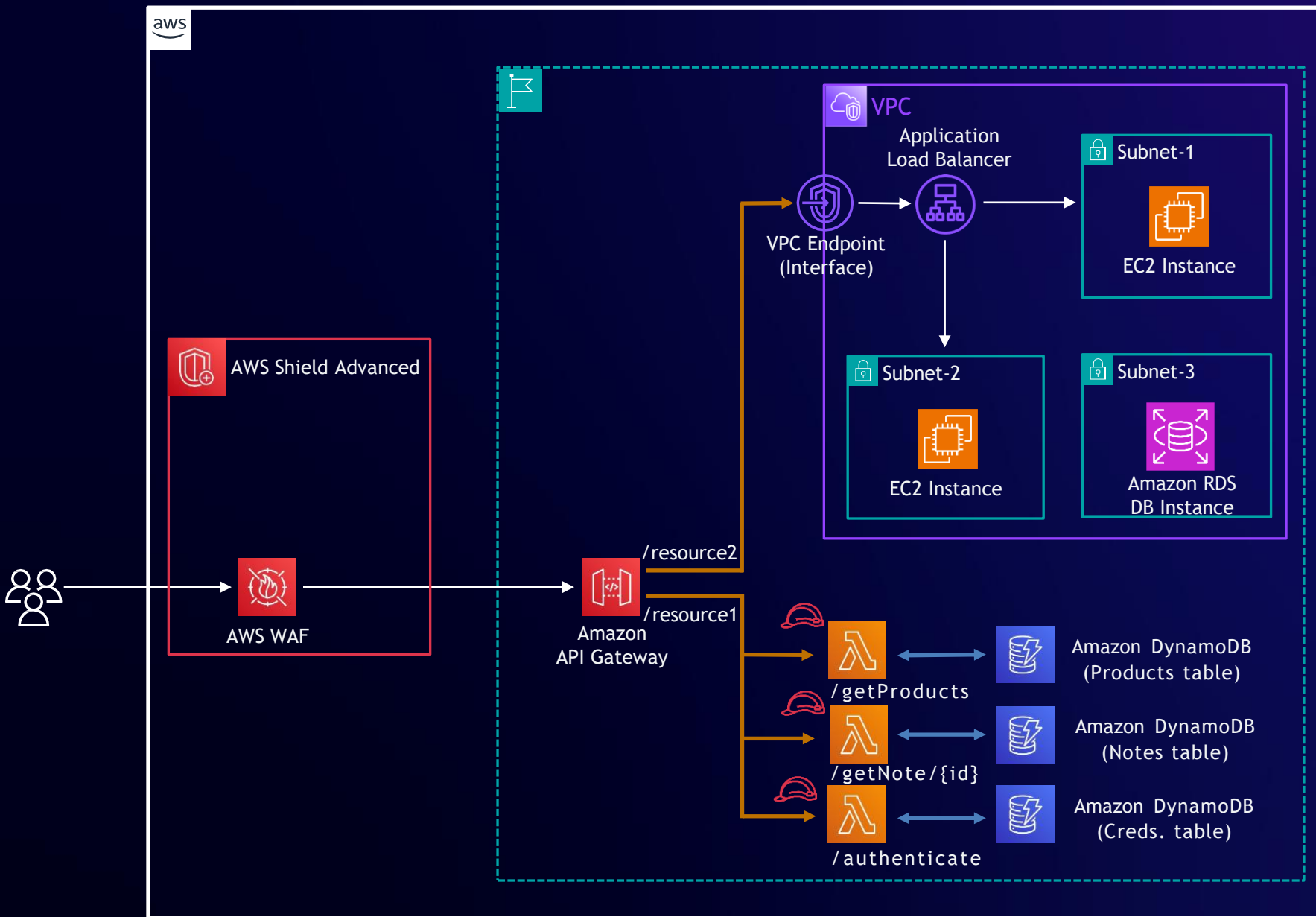
DDoS Protection

- at Layer 3/4
- at Layer 7

Real-time Insights

AWS WAF Integration

AWS DDoS Response Team (DRT)



AWS Shield Advanced

DDoS Protection

- at Layer 3/4
- at Layer 7

Real-time Insights

AWS WAF Integration

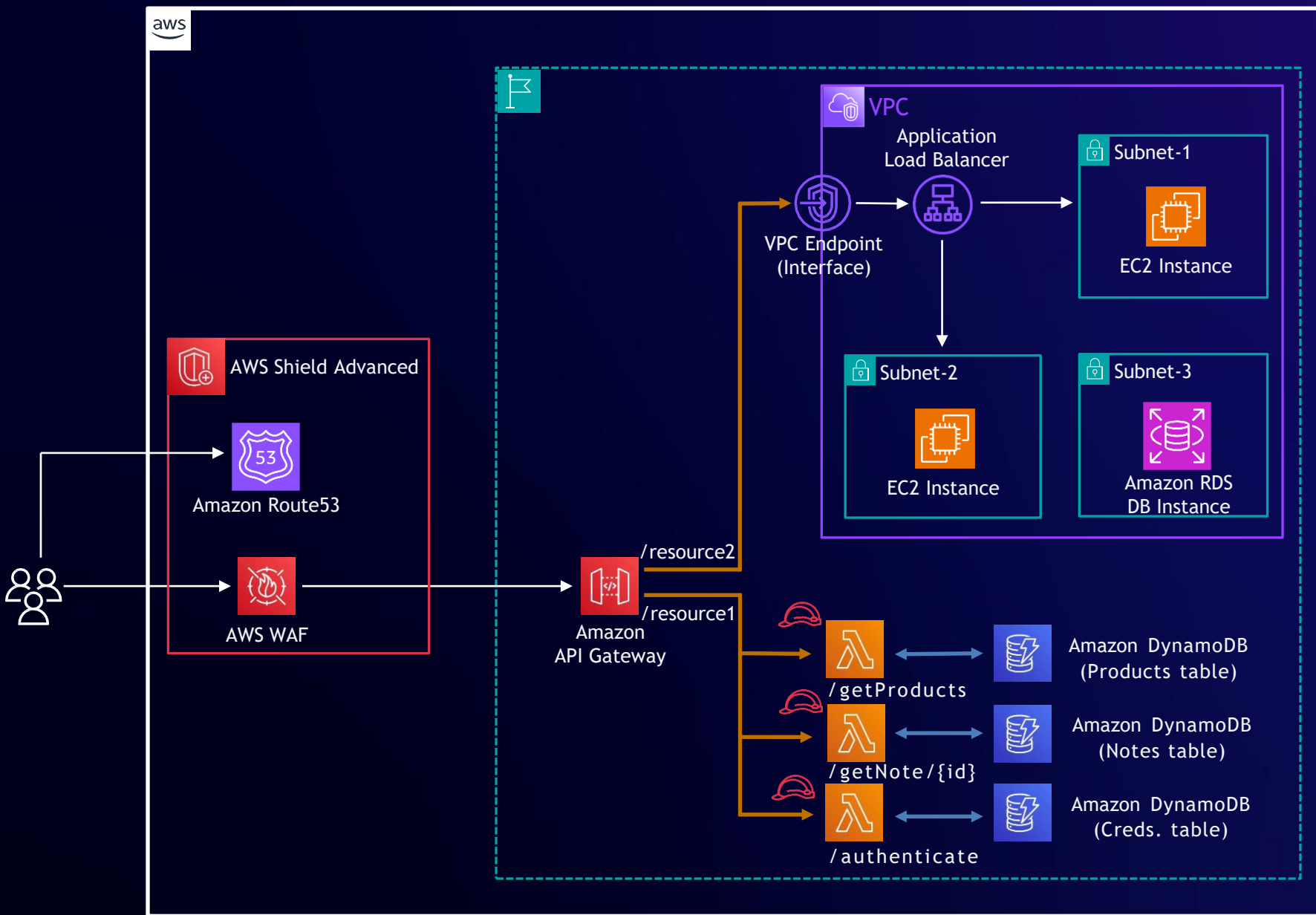
AWS DDoS Response Team (DRT)

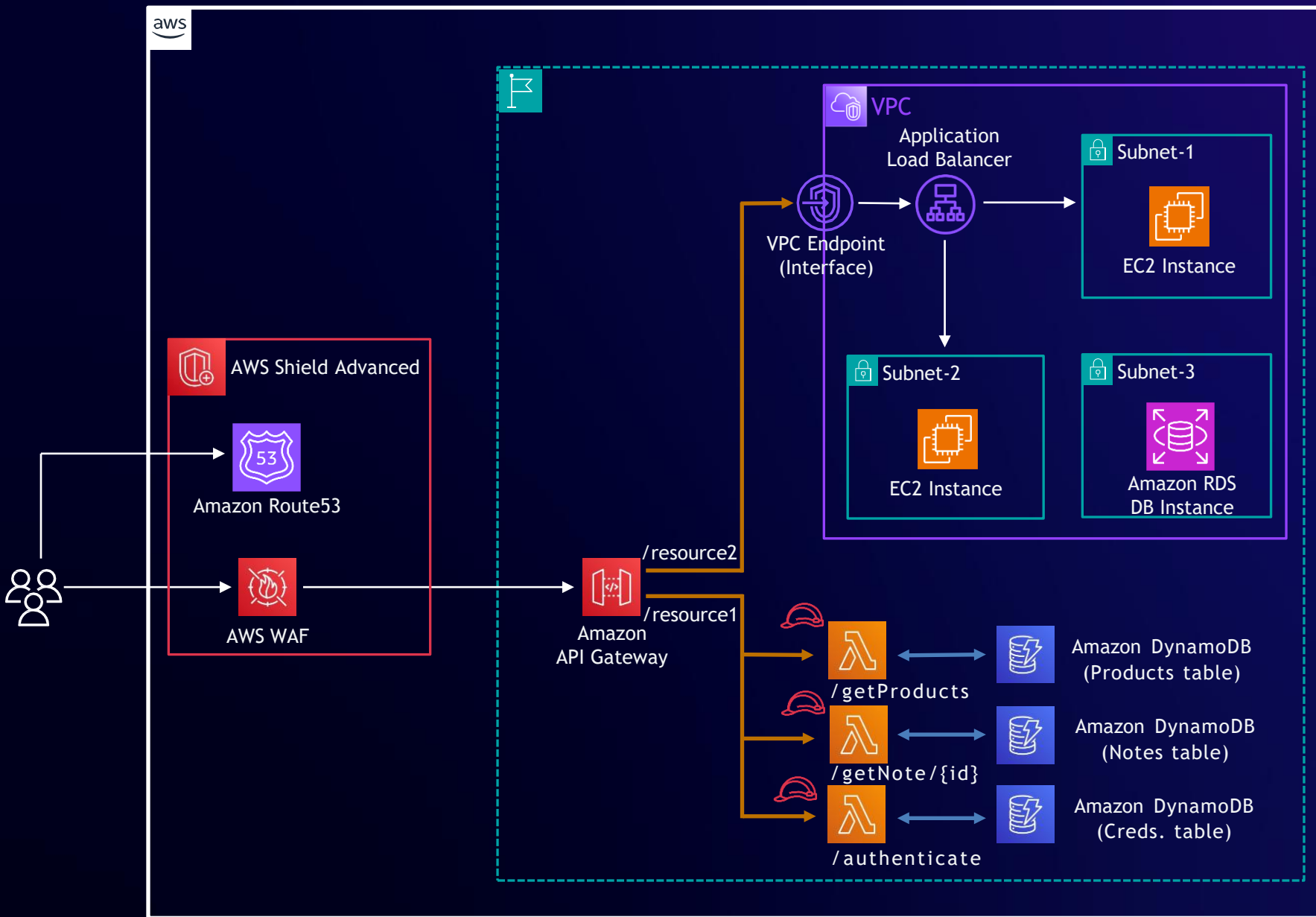
DDOS Cost Protection

Q: How can we protect this architecture against DNS based attack vectors?

AMAZON ROUTE53

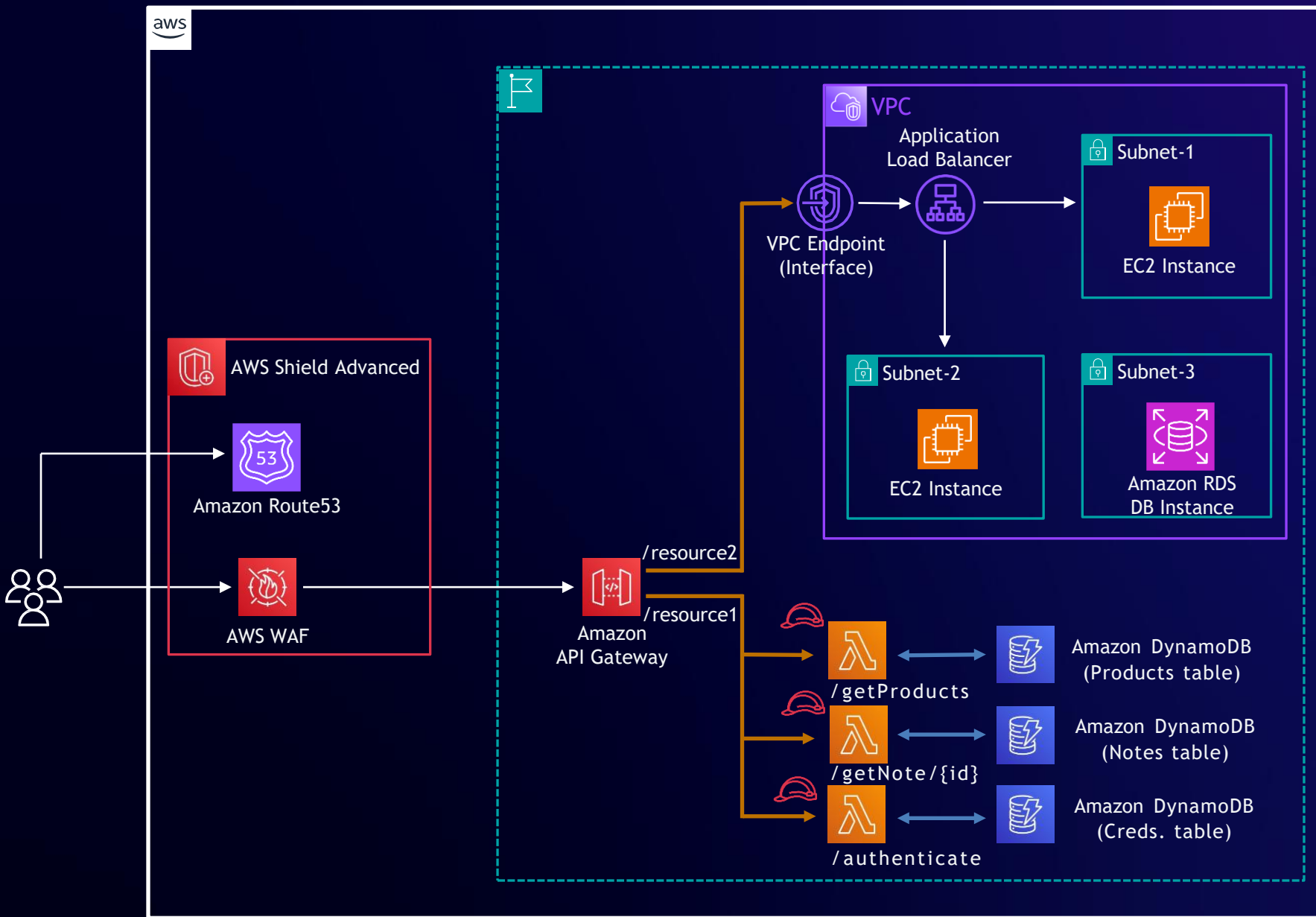
Amazon Route53





Amazon Route53

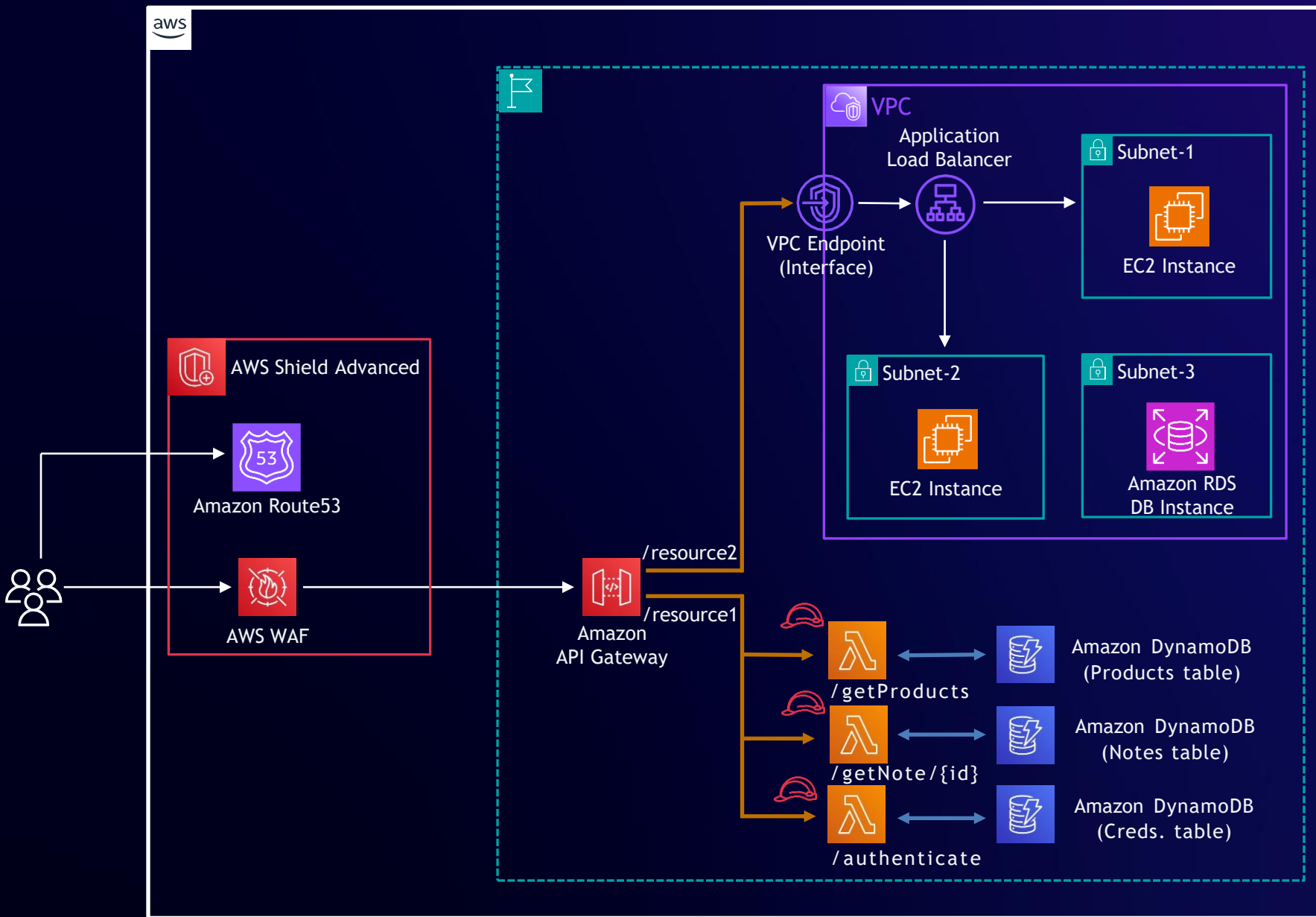
DNSSEC (KSK or ZSK)



Amazon Route53

DNSSEC (KSK or ZSK)

Anycast stripping

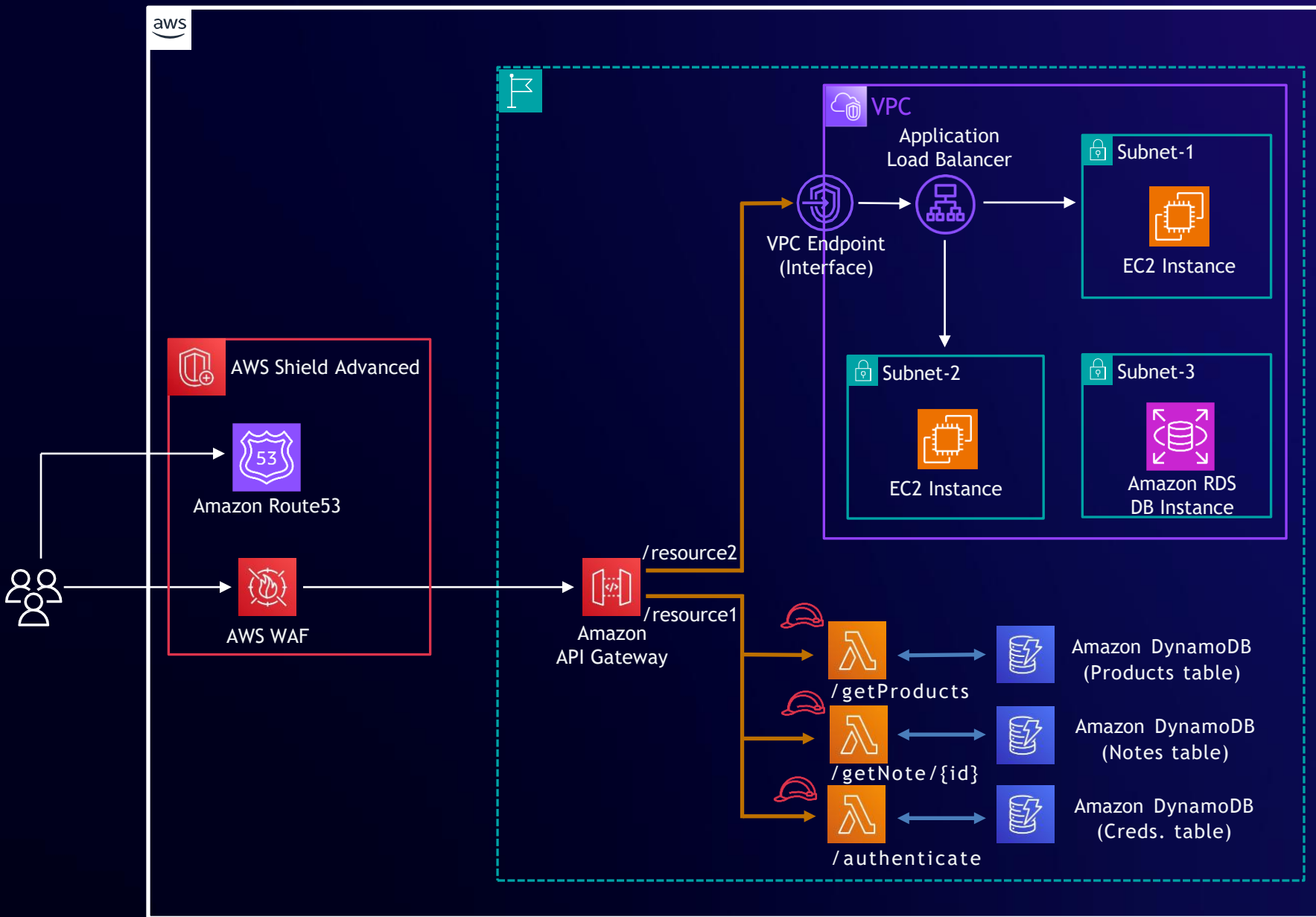


Amazon Route53

DNSSEC (KSK or ZSK)

Anycast striping

Route53 Resolver
Endpoints



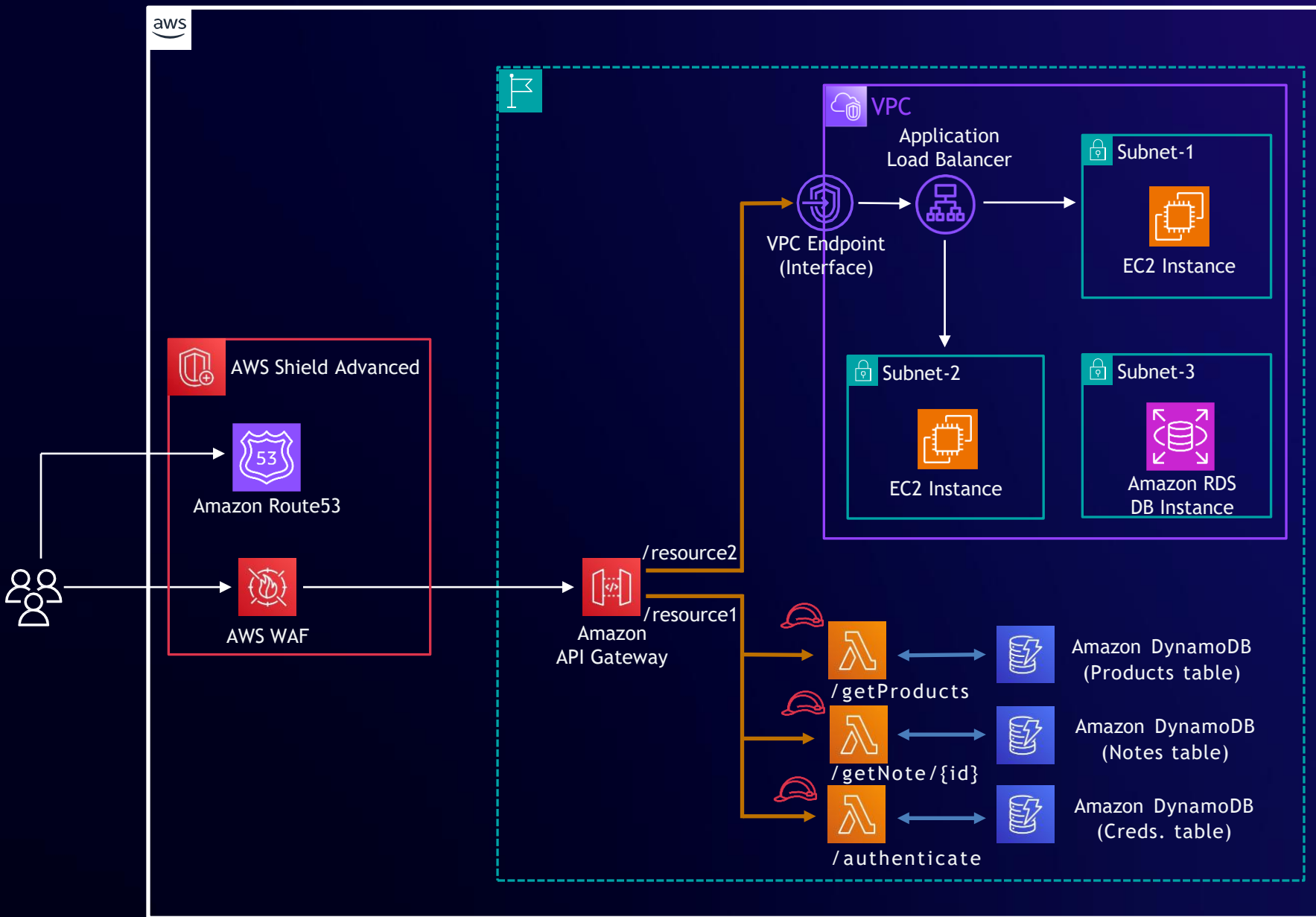
Amazon Route53

DNSSEC (KSK or ZSK)

Anycast striping

Route53 Resolver
Endpoints

Shuffle sharding for
fault isolation



Amazon Route53

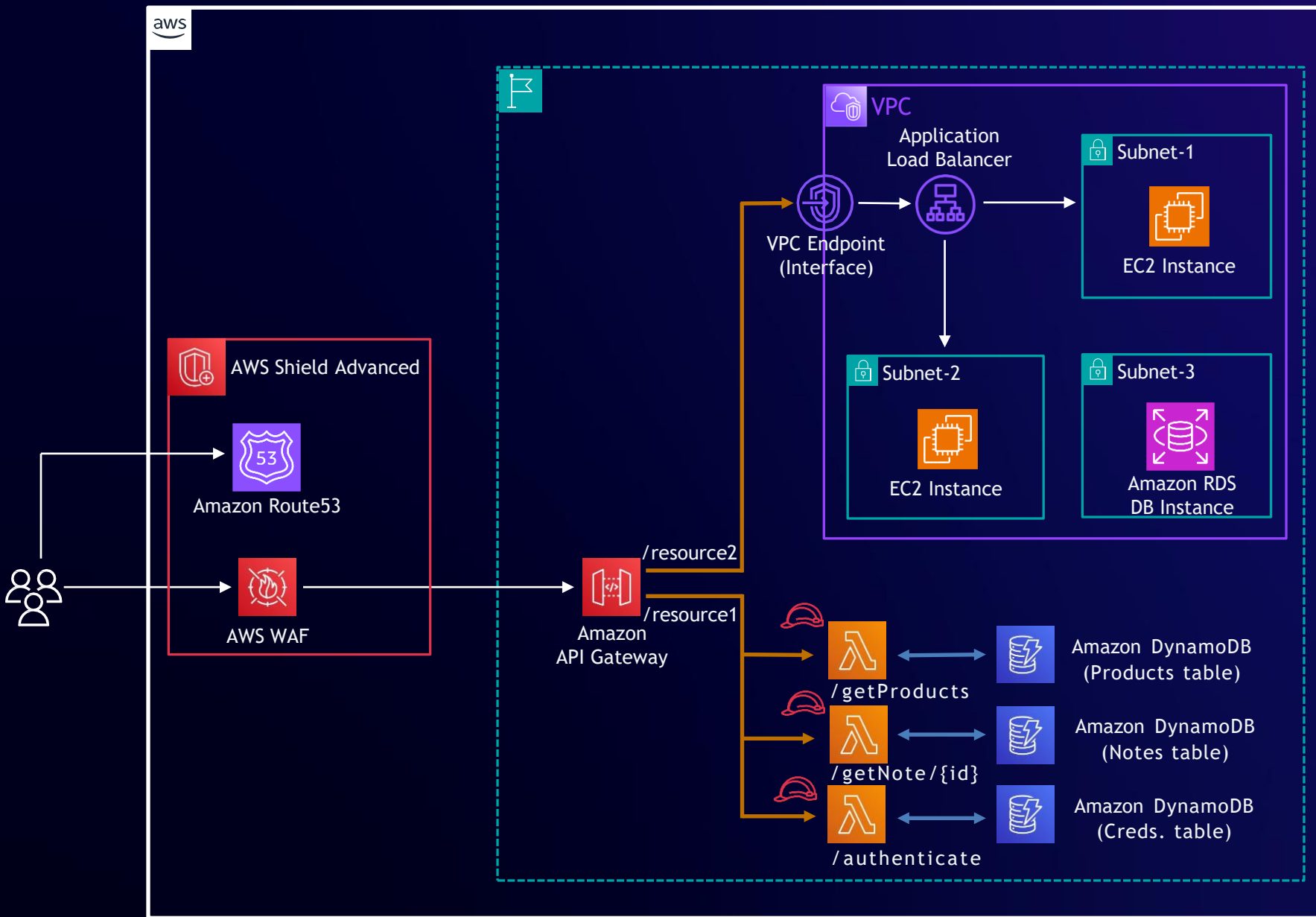
DNSSEC (KSK or ZSK)

Anycast striping

Route53 Resolver
Endpoints

Shuffle sharding for
fault isolation

Geoproximity routing
policies



Amazon Route53

DNSSEC (KSK or ZSK)

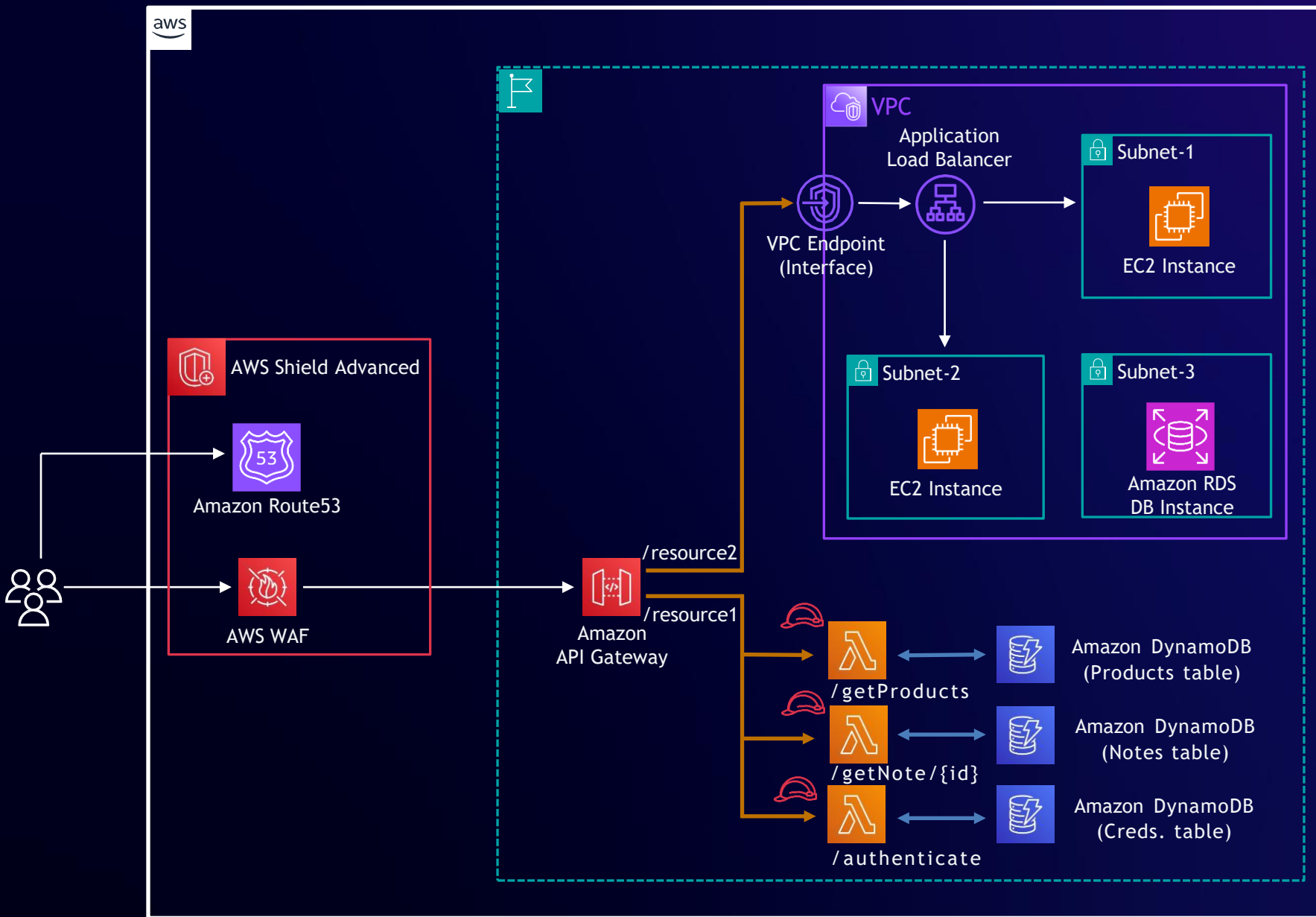
Anycast striping

Route53 Resolver
Endpoints

Shuffle sharding for
fault isolation

Geoproximity routing
policies

Integration with AWS
Shield



Amazon Route53

DNSSEC (KSK or ZSK)

Anycast striping

Route53 Resolver
Endpoints

Shuffle sharding for
fault isolation

Geoproximity routing
policies

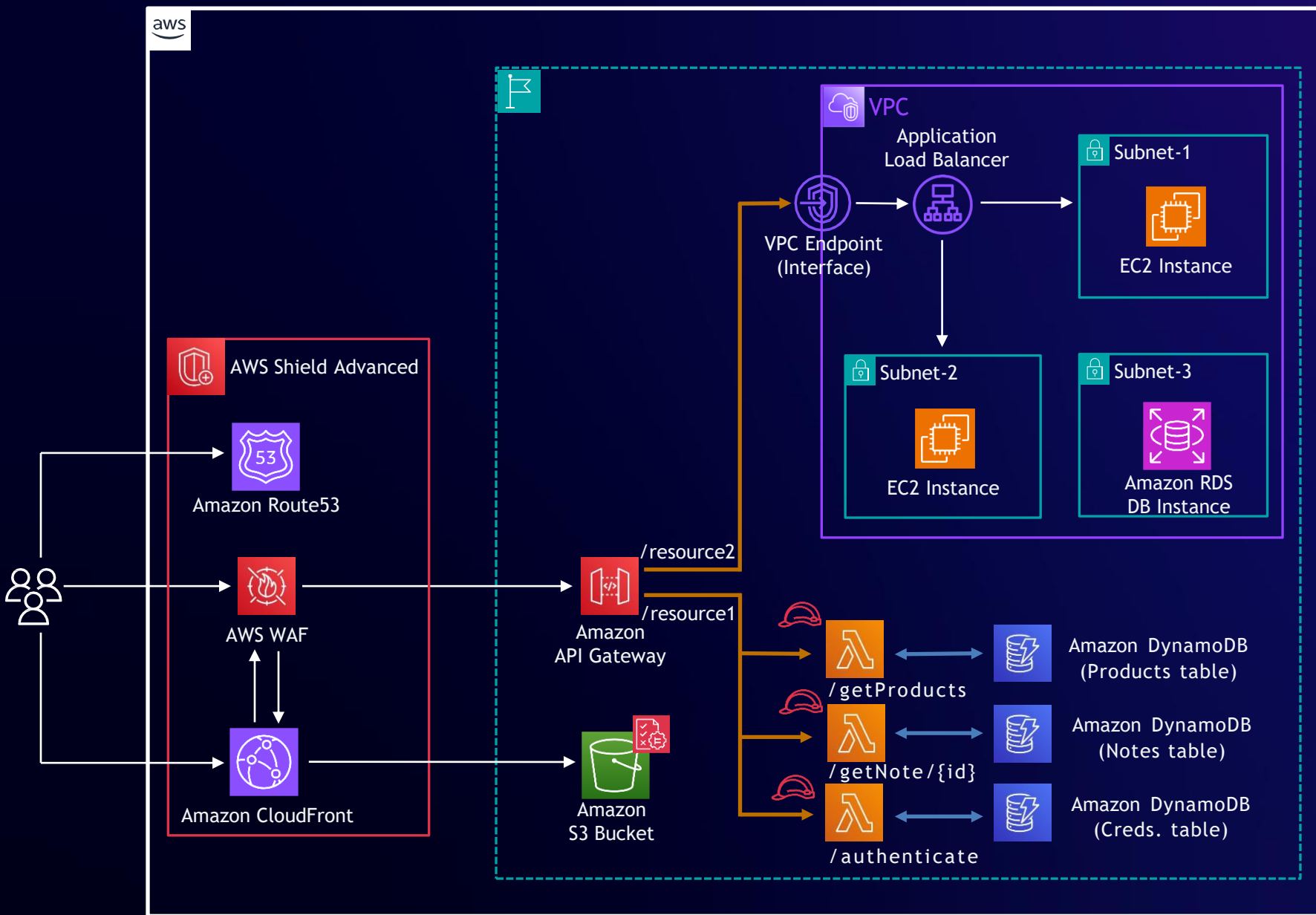
Integration with AWS
Shield

- fans out traffic

**Q: What about safer content delivery
and securing static contents?**

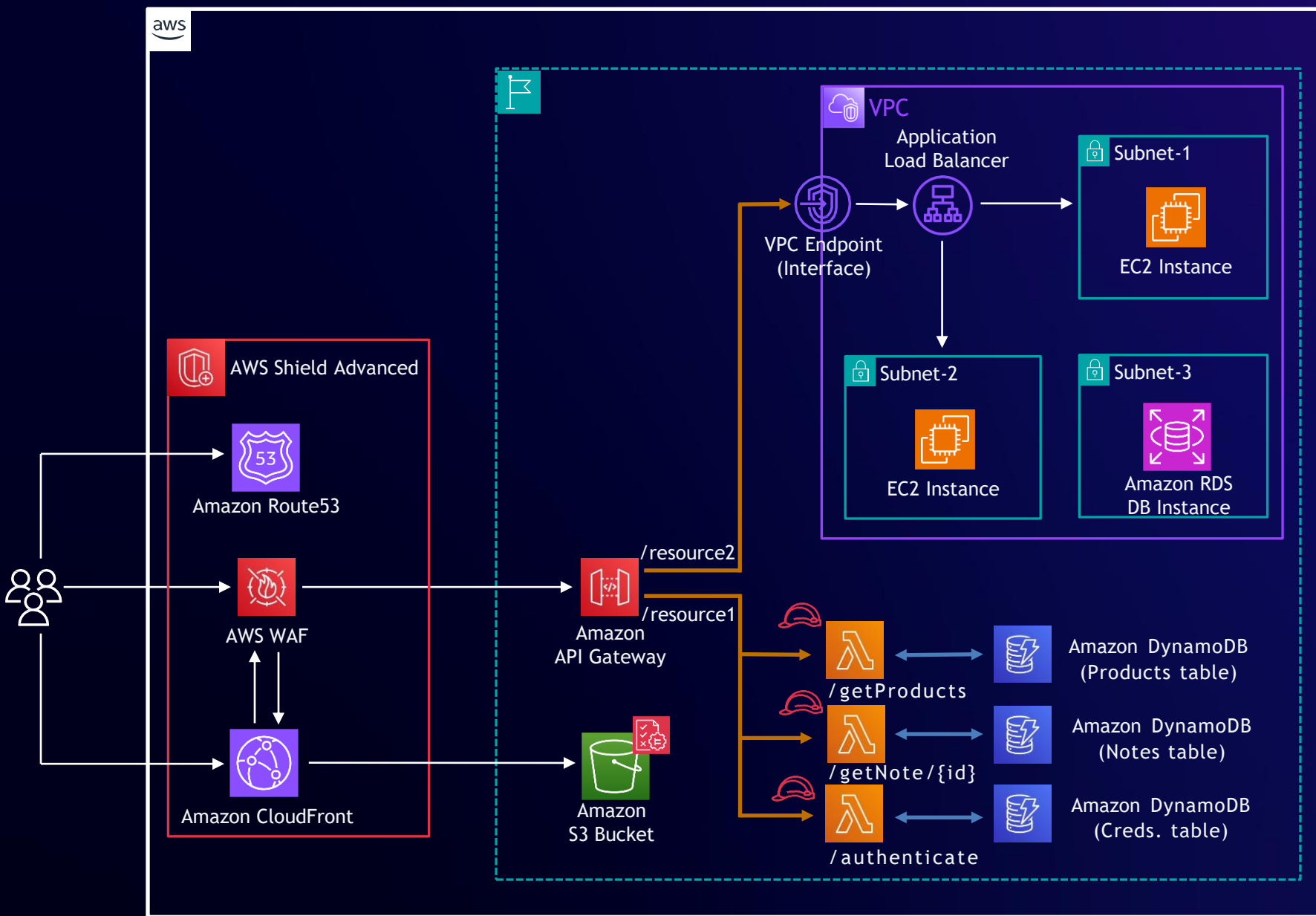
AMAZON CLOUDFRONT

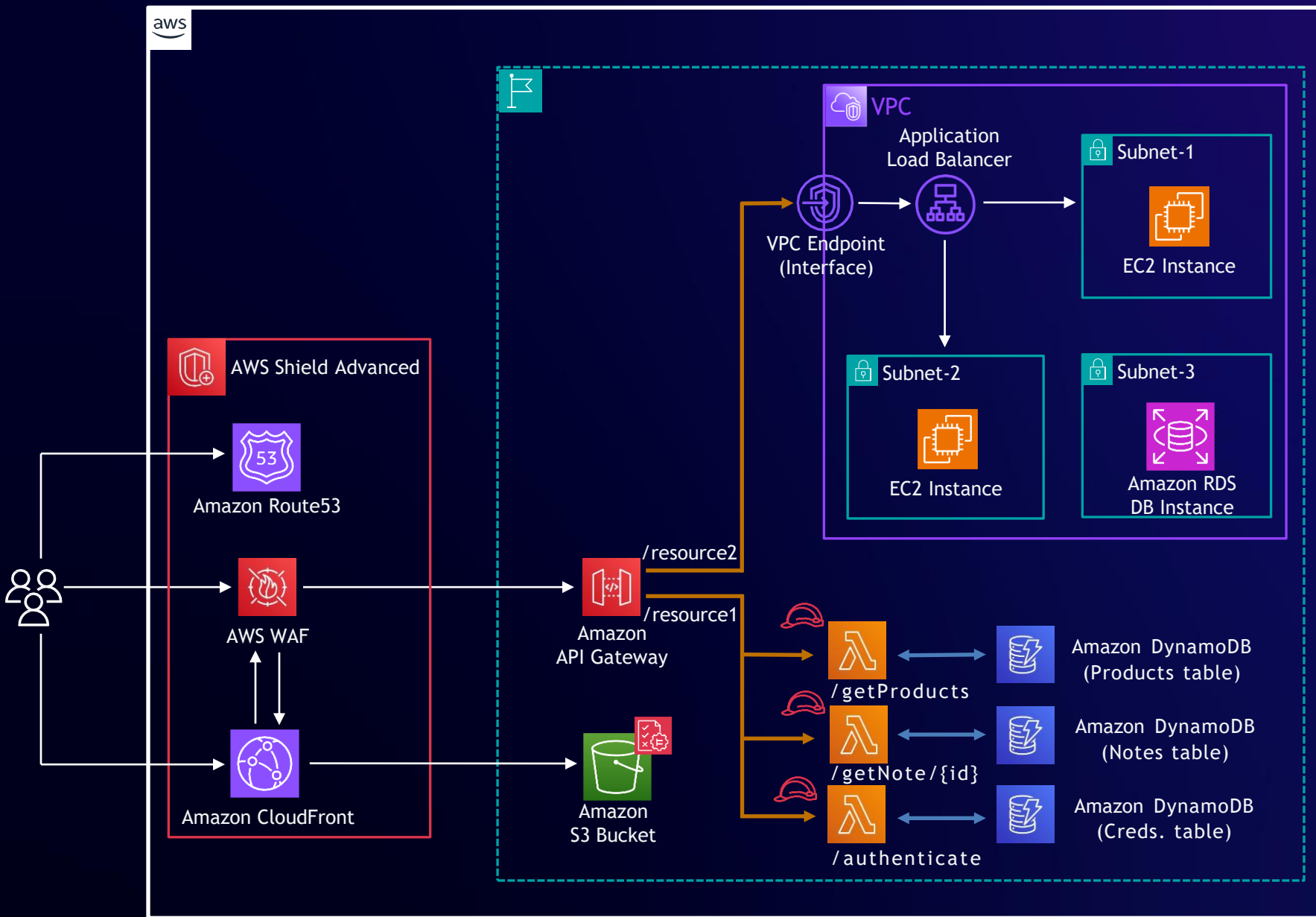
Amazon CloudFront



Amazon CloudFront

Geo restriction

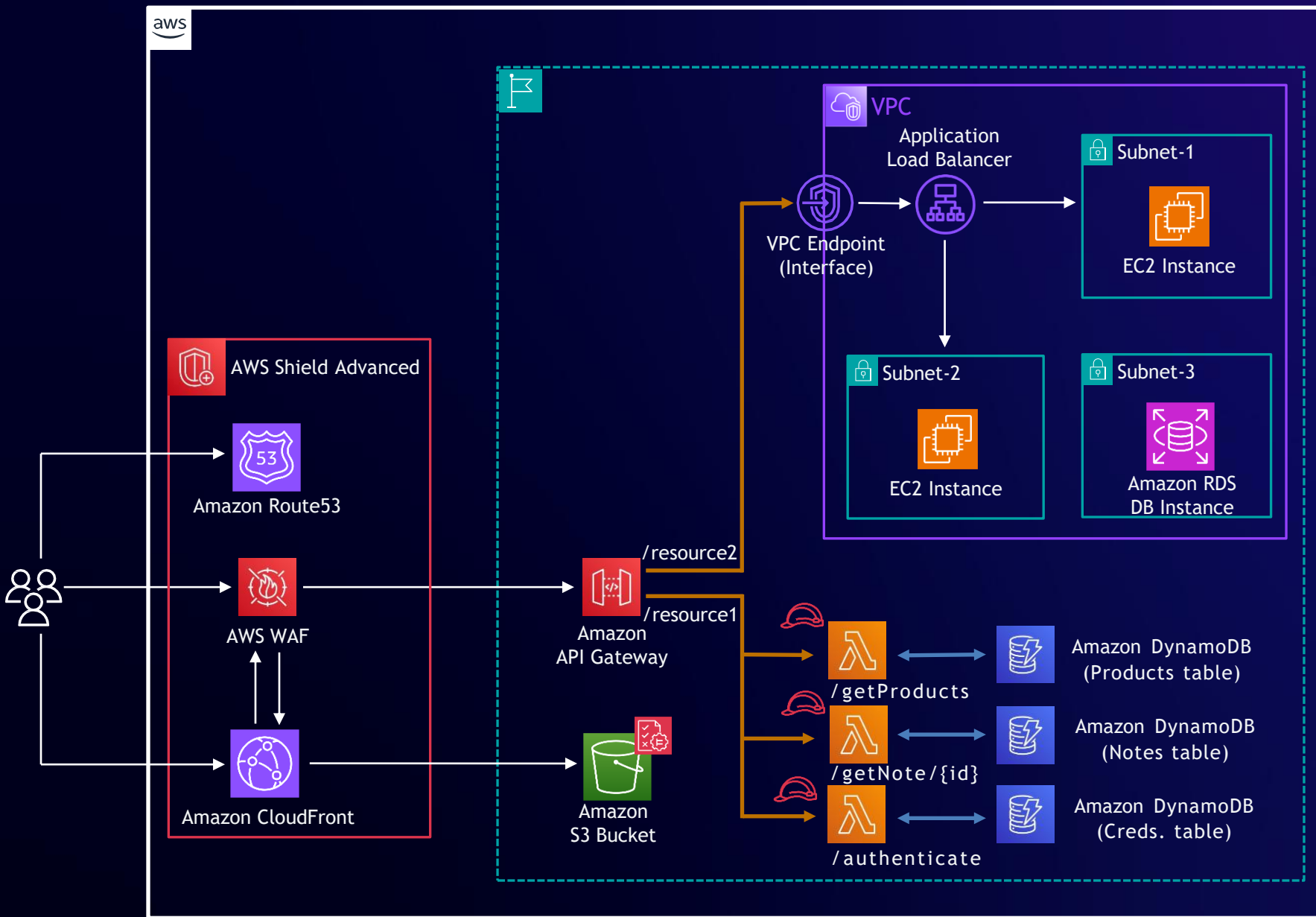




Amazon CloudFront

Geo restriction

HTTP over TLS

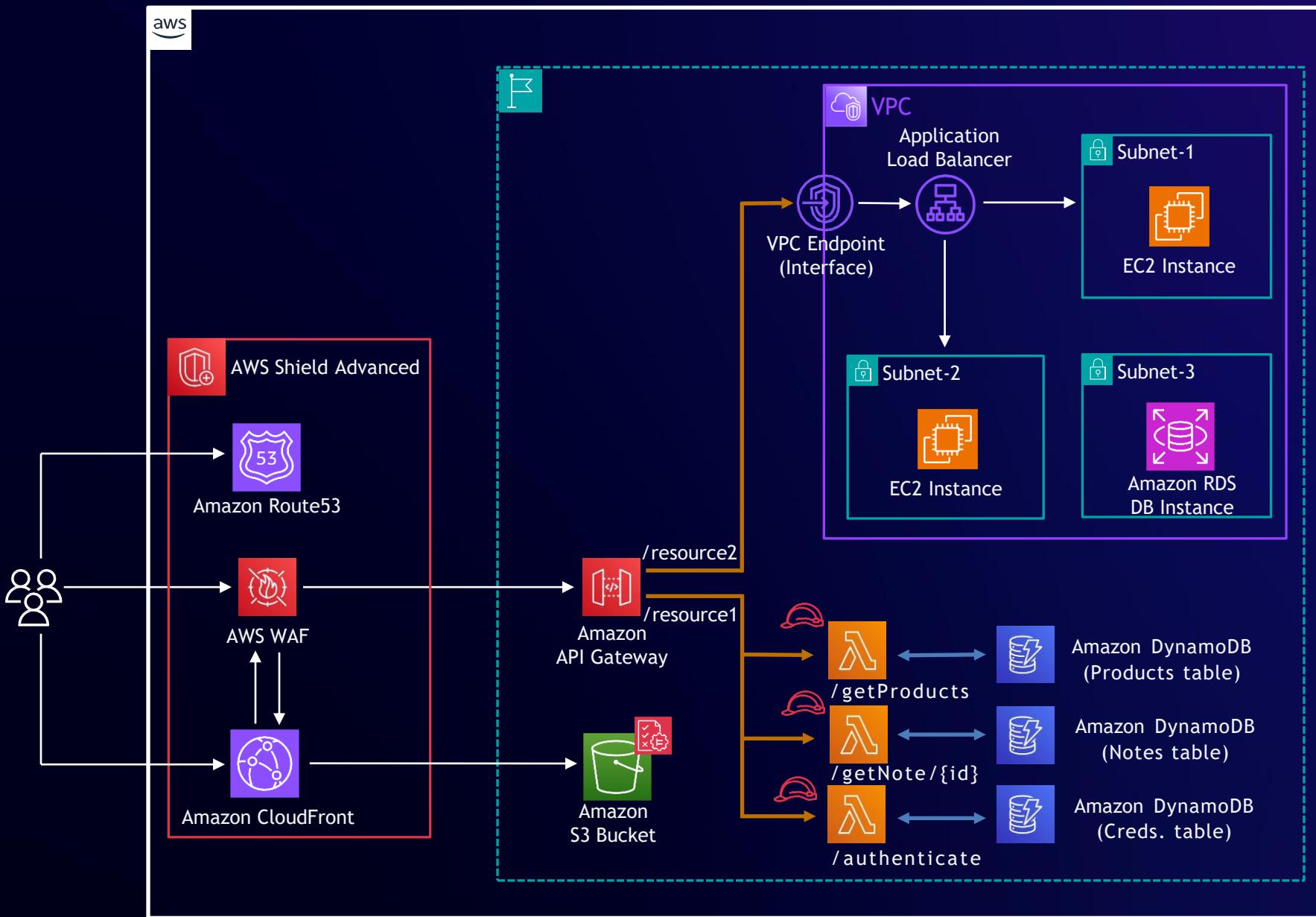


Amazon CloudFront

Geo restriction

HTTP over TLS

Field-Level Encryption



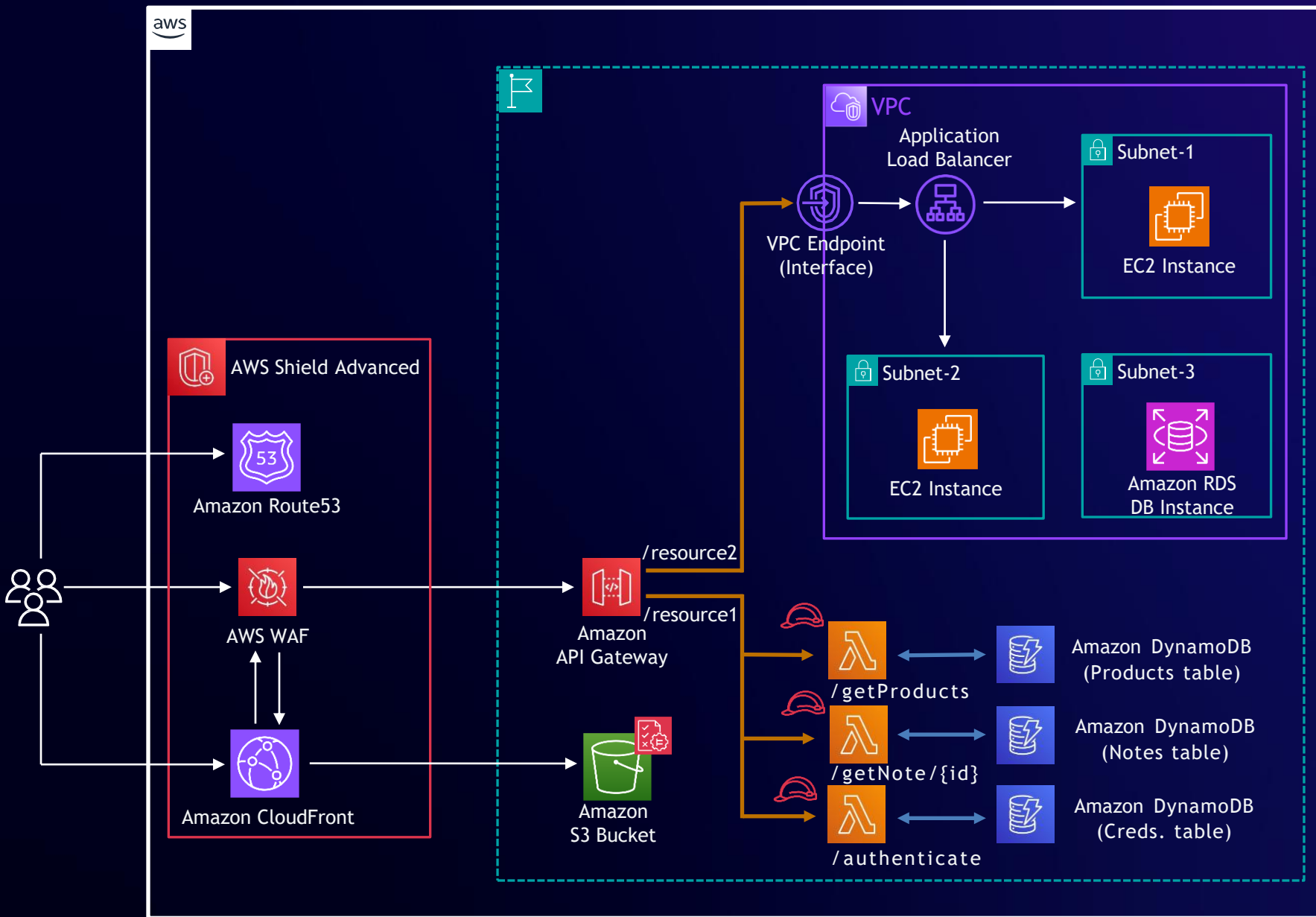
Amazon CloudFront

Geo restriction

HTTP over TLS

Field-Level Encryption

**Restrict access to S3
Bucket objects**



Amazon CloudFront

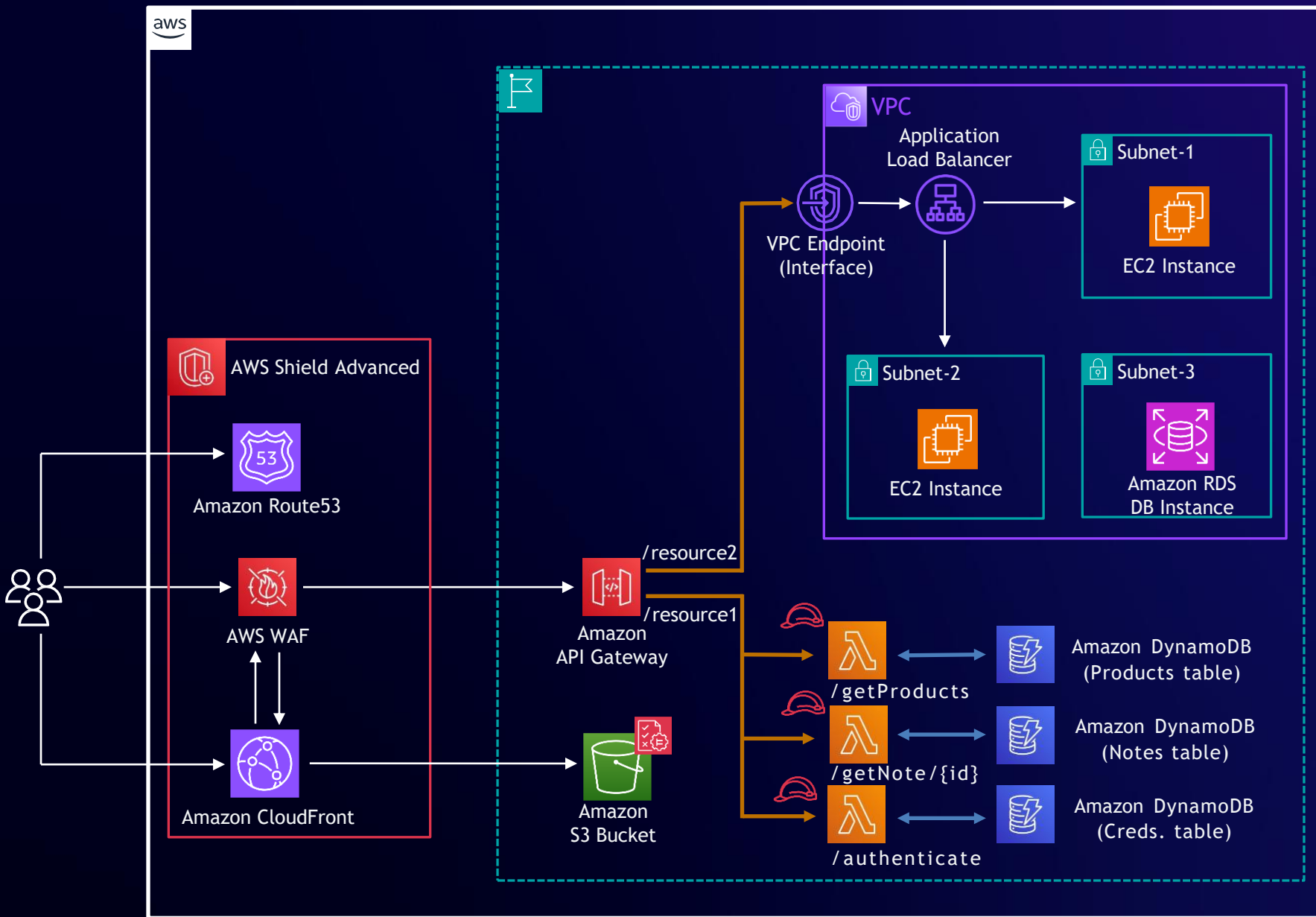
Geo restriction

HTTP over TLS

Field-Level Encryption

Restrict access to S3
Bucket objects

**Restrict access to
static contents**



Amazon CloudFront

Geo restriction

HTTP over TLS

Field-Level Encryption

Restrict access to S3
Bucket objects

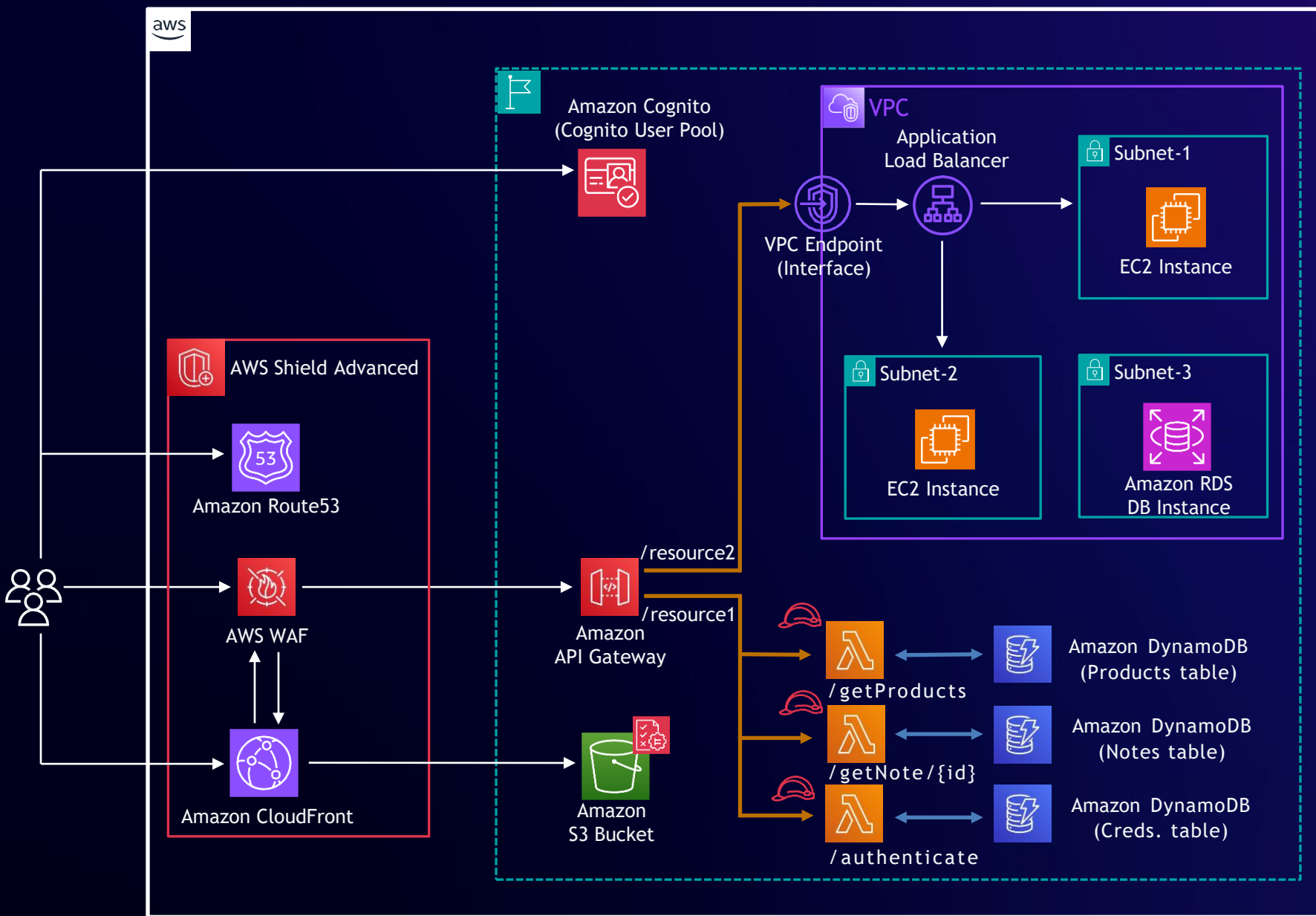
Restrict access to
static contents

Origin Shield

Q: What about secure AuthN and AuthZ?

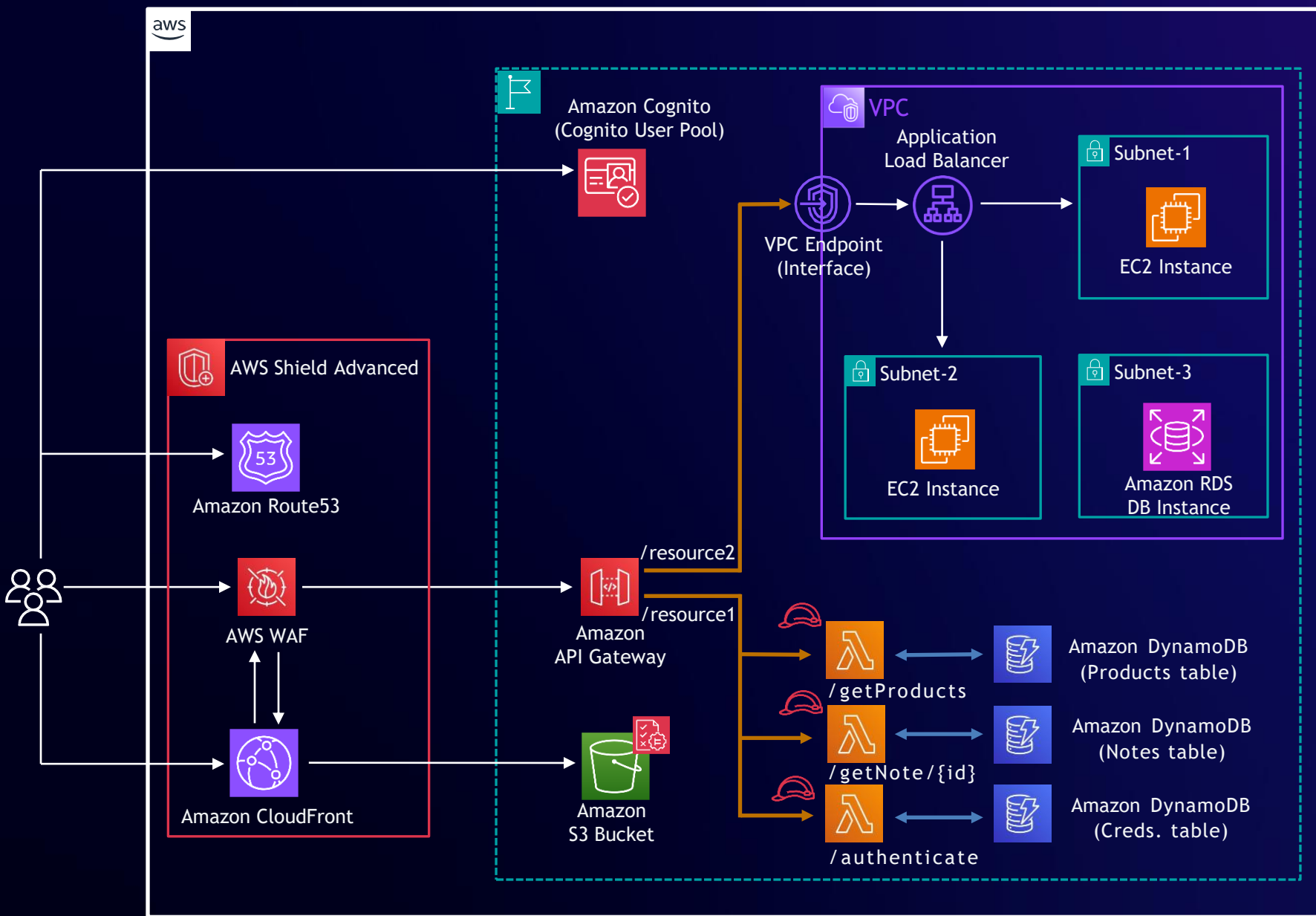
AMAZON COGNITO

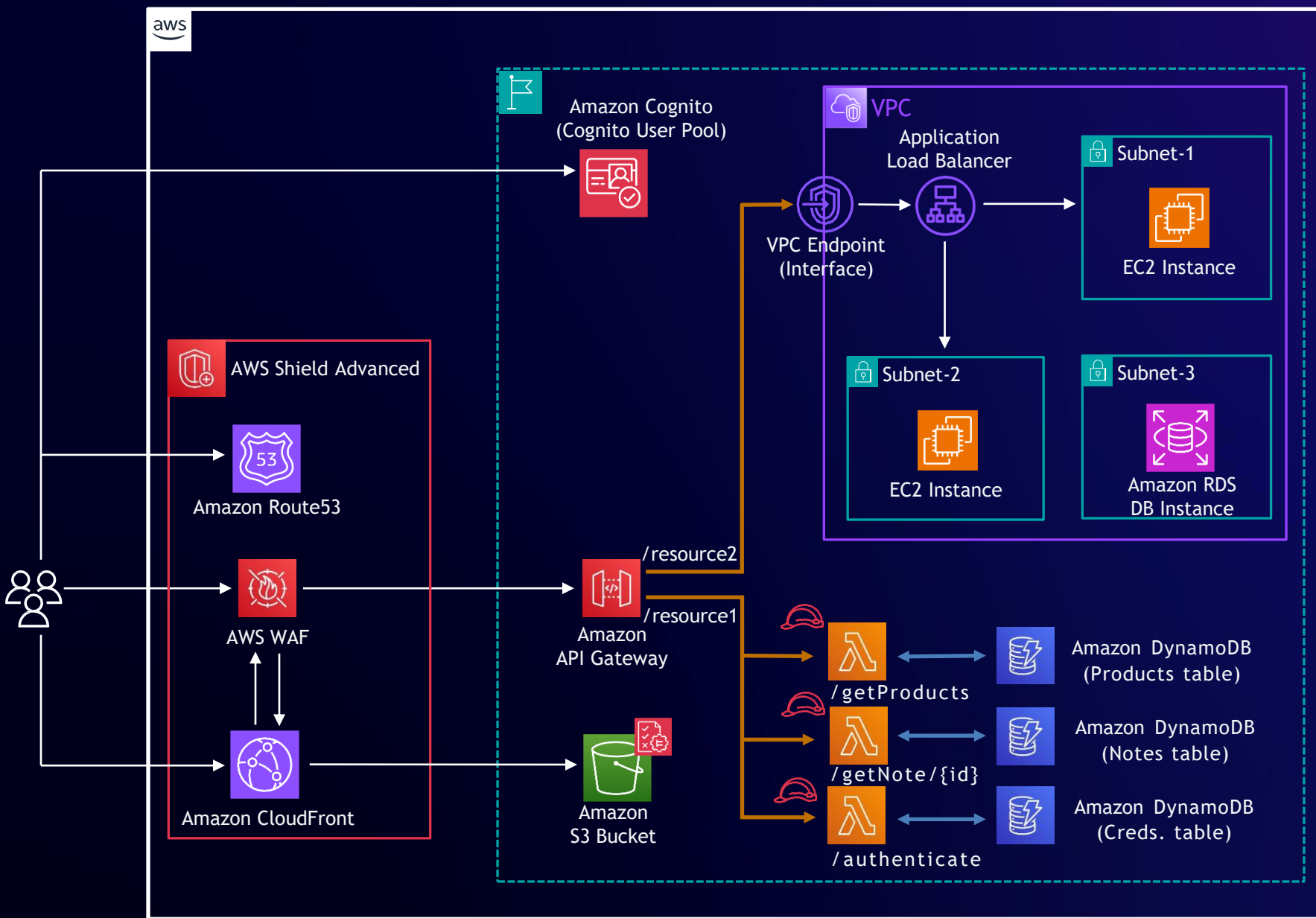
Amazon Cognito



Amazon Cognito

Secure sign-in, sign-up

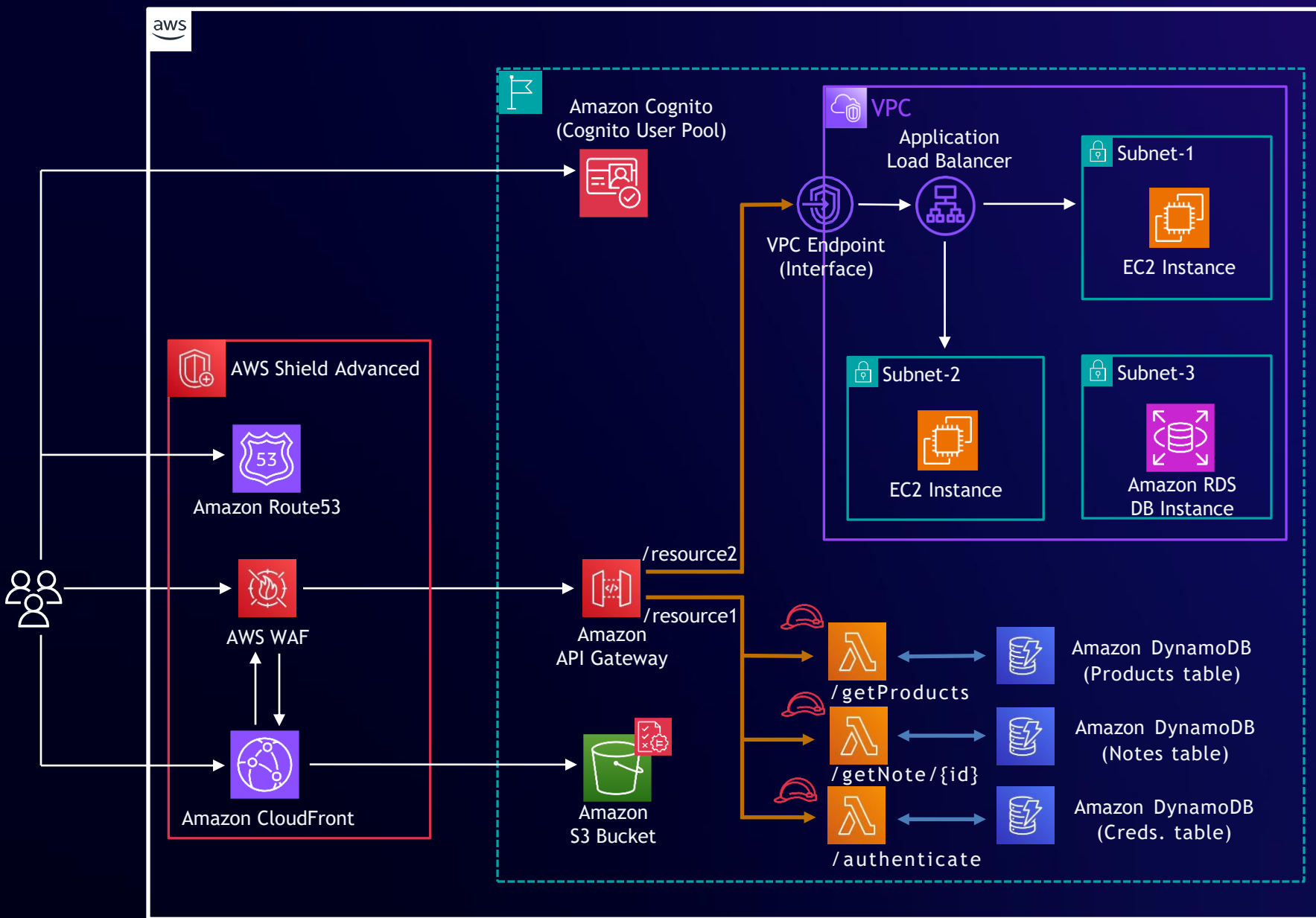




Amazon Cognito

Secure sign-in, sign-up

Various authentication

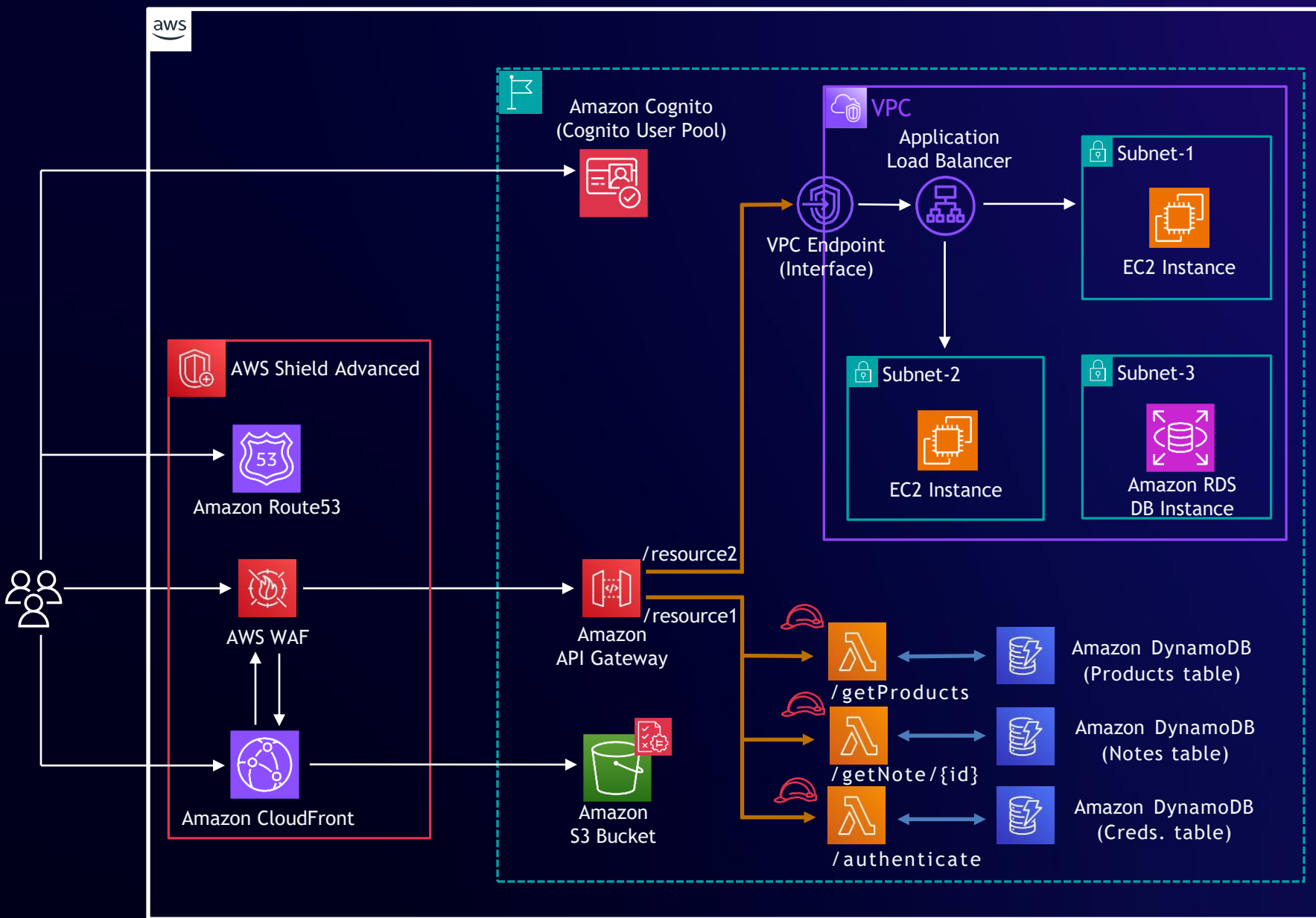


Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA

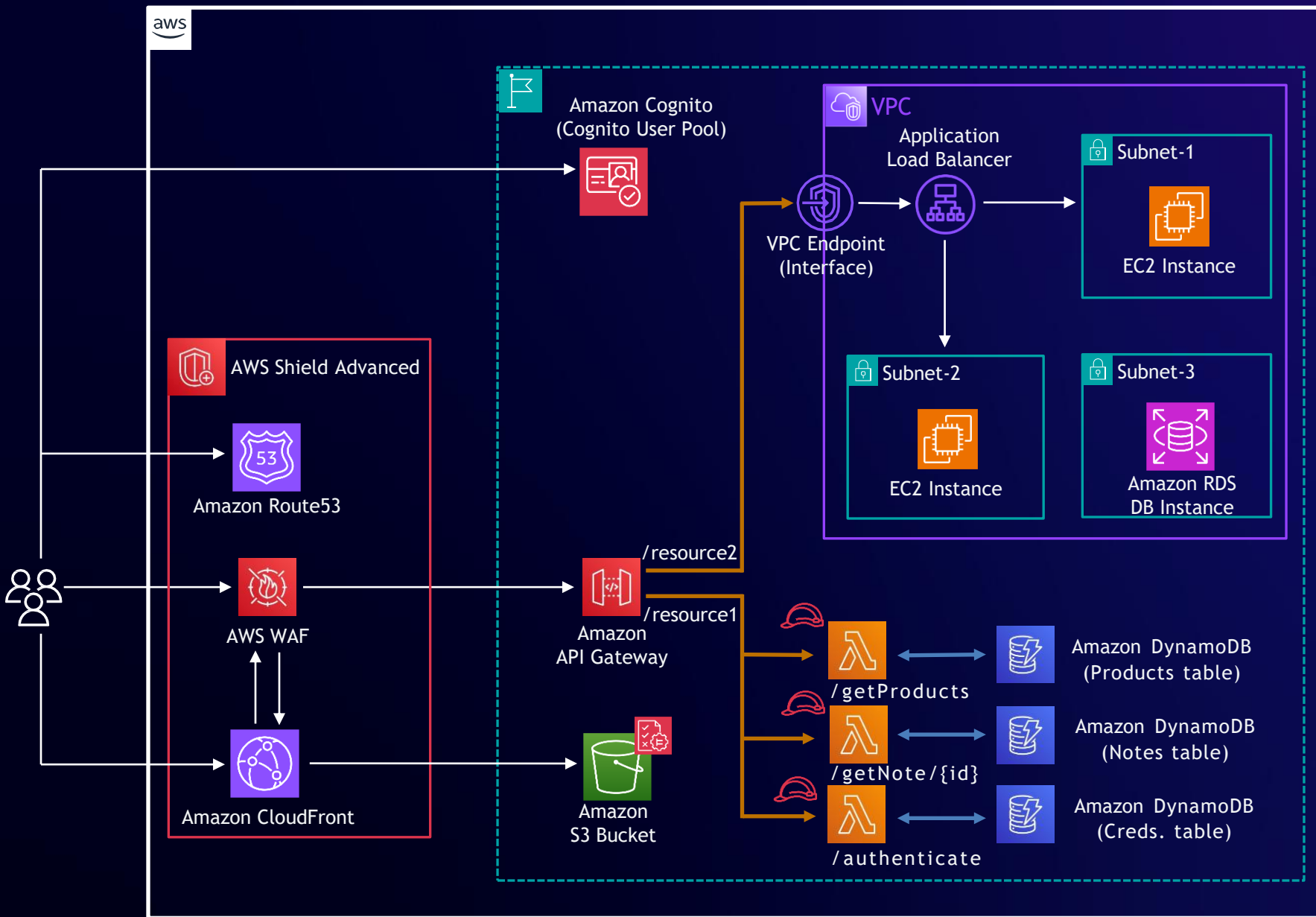


Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA
- Password Policies



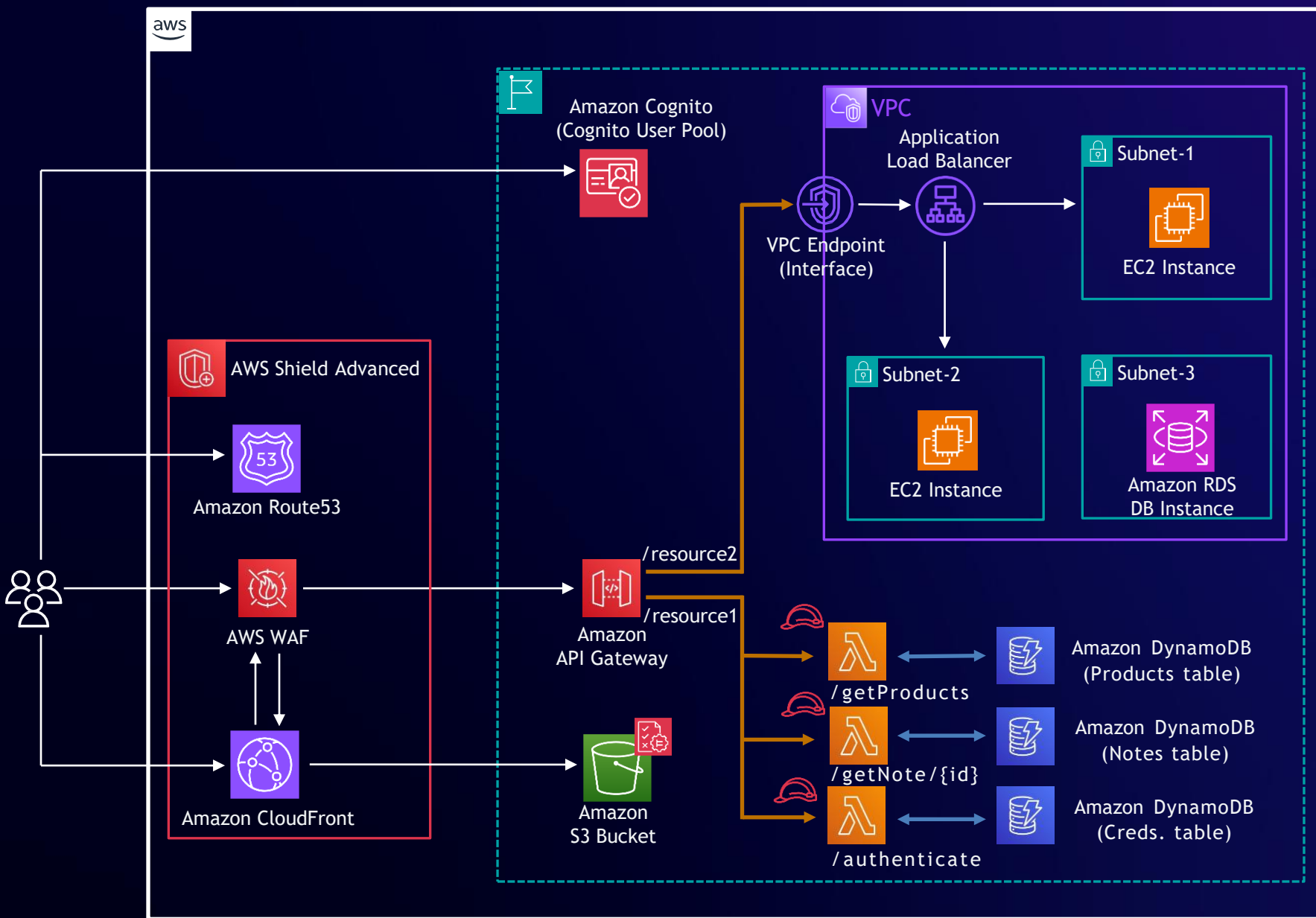
Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA
- Password Policies

Federated access



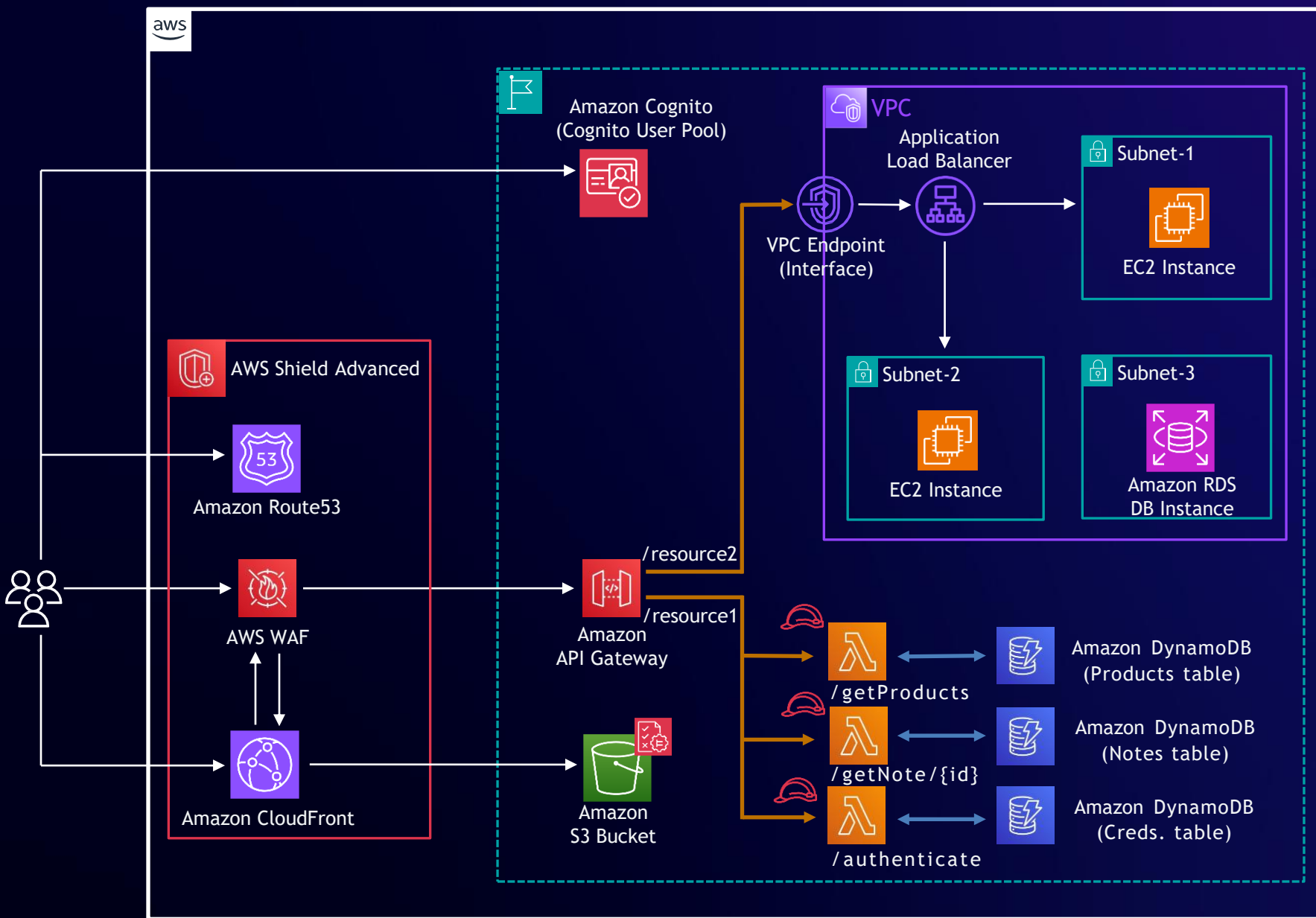
Amazon Cognito

Secure sign-in, sign-up
Various authentication

- MFA
- Password Policies

Federated access

- OpenID Connect



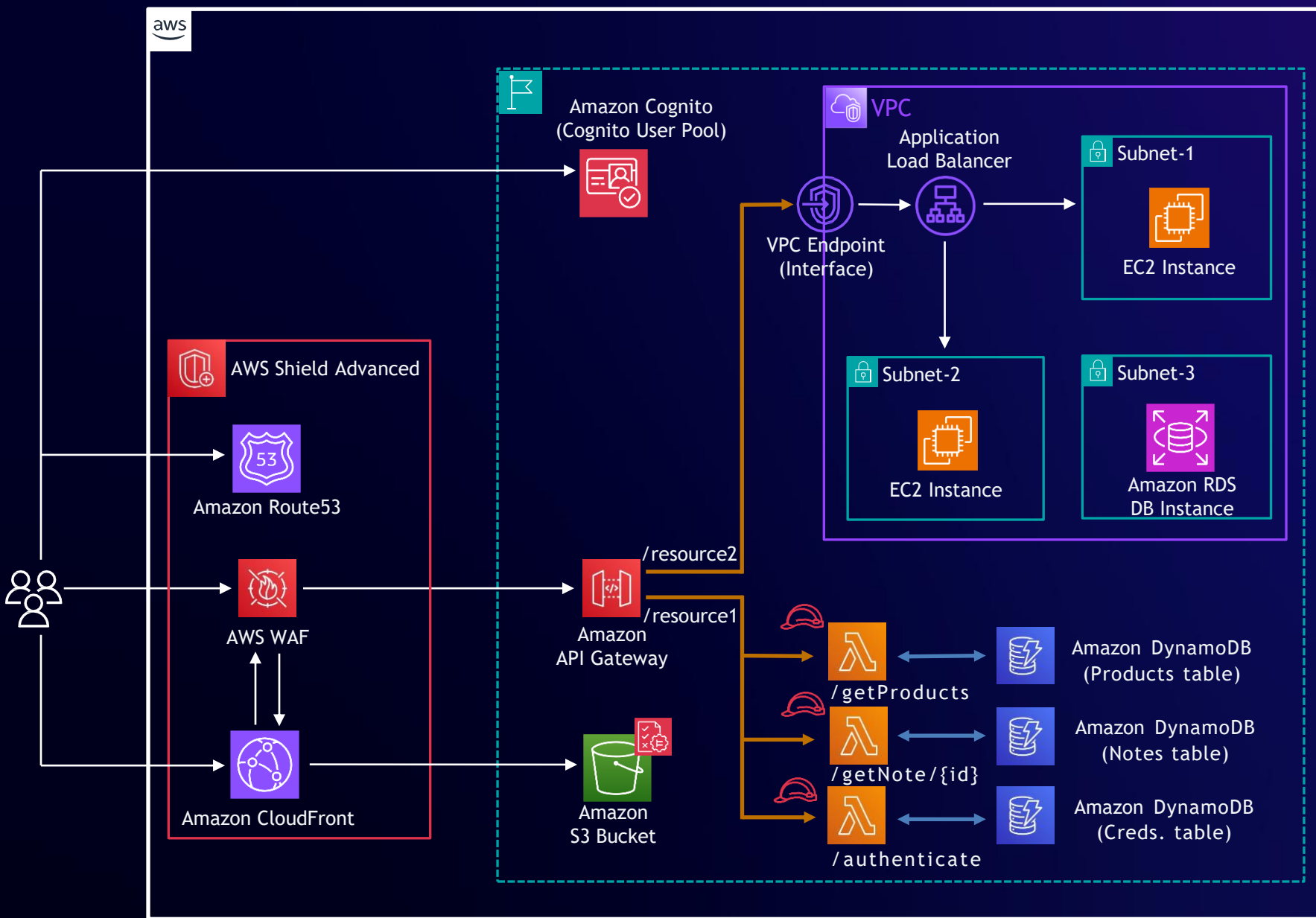
Amazon Cognito

Secure sign-in, sign-up
Various authentication

- MFA
- Password Policies

Federated access

- OpenID Connect
- OAuth 2.0 & SAML



Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA

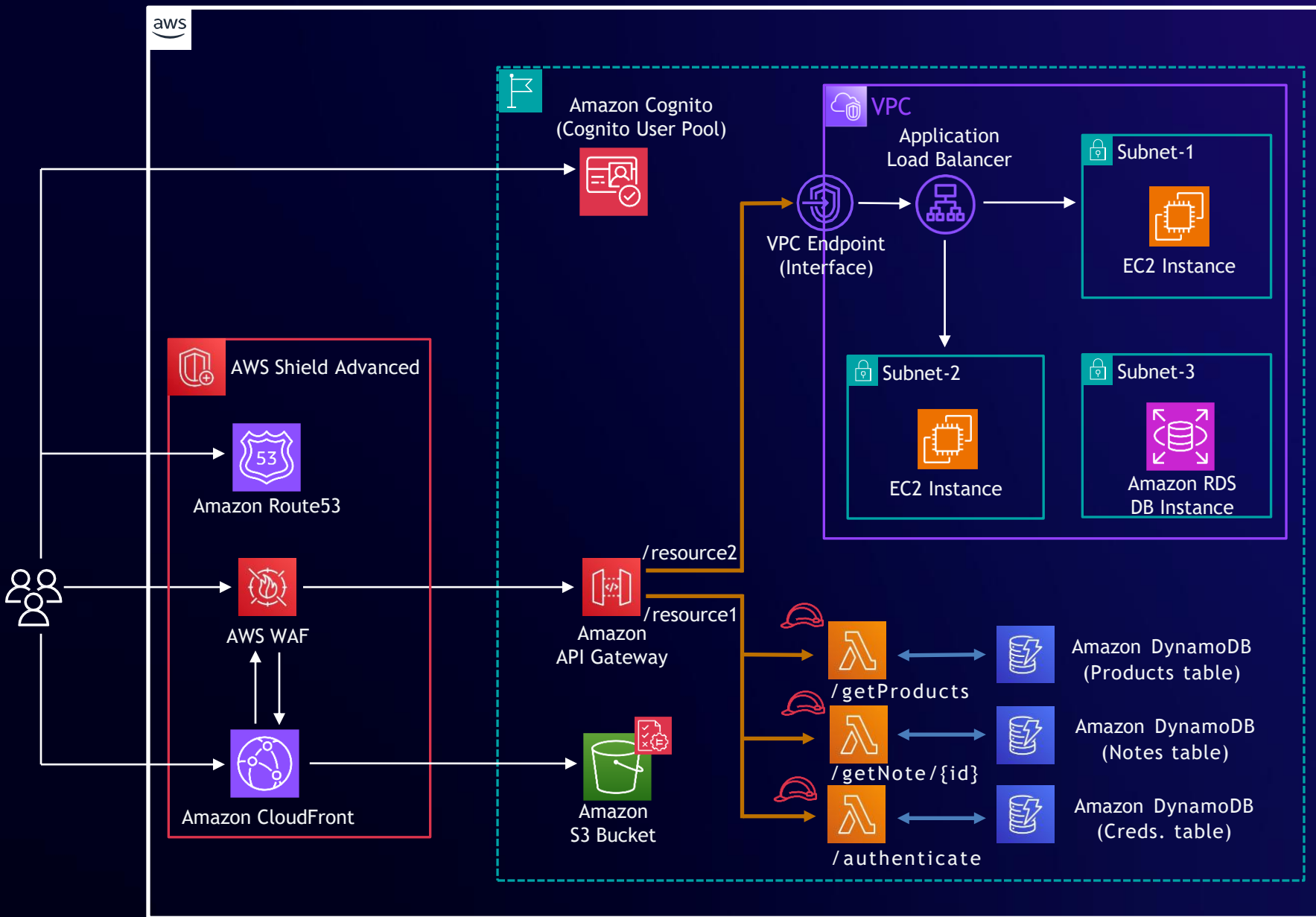
- Password Policies

Federated access

- OpenID Connect

- OAuth 2.0 & SAML

Logging and Monitoring



Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA

- Password Policies

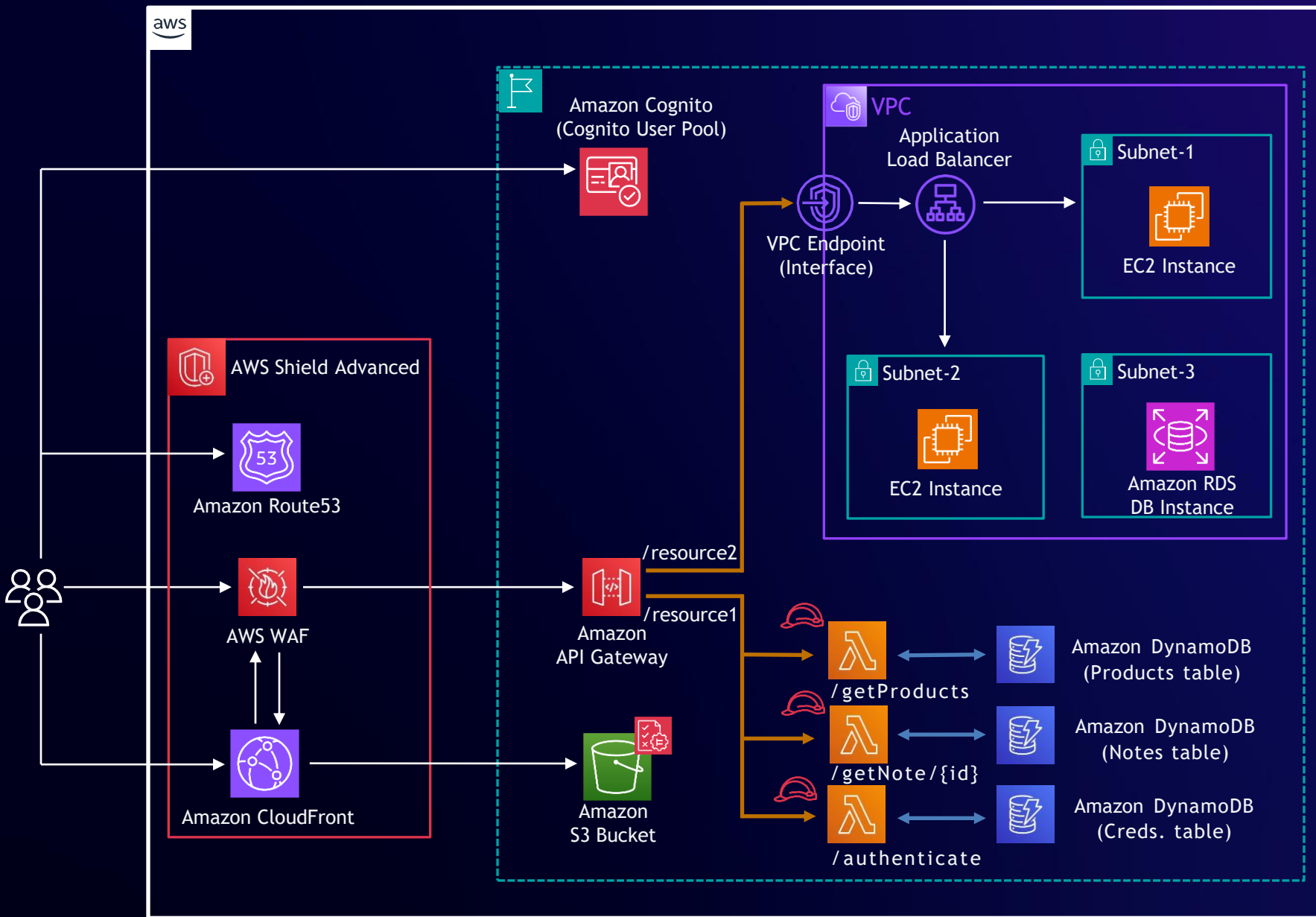
Federated access

- OpenID Connect

- OAuth 2.0 & SAML

Logging and Monitoring

- AWS CloudTrail



Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA

- Password Policies

Federated access

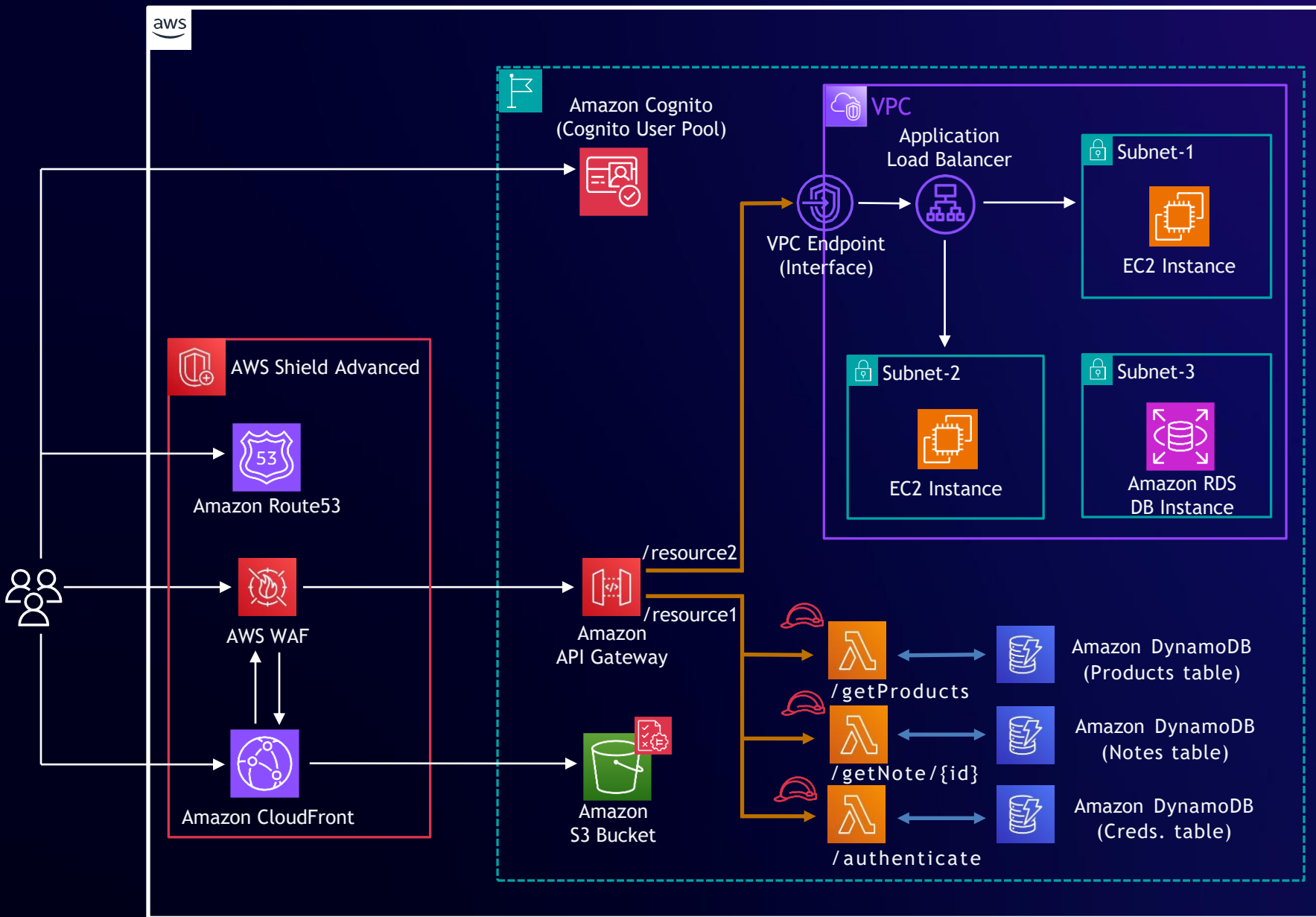
- OpenID Connect

- OAuth 2.0 & SAML

Logging and Monitoring

- AWS CloudTrail

- CloudWatch Metrics



Amazon Cognito

Secure sign-in, sign-up

Various authentication

- MFA

- Password Policies

Federated access

- OpenID Connect

- OAuth 2.0 & SAML

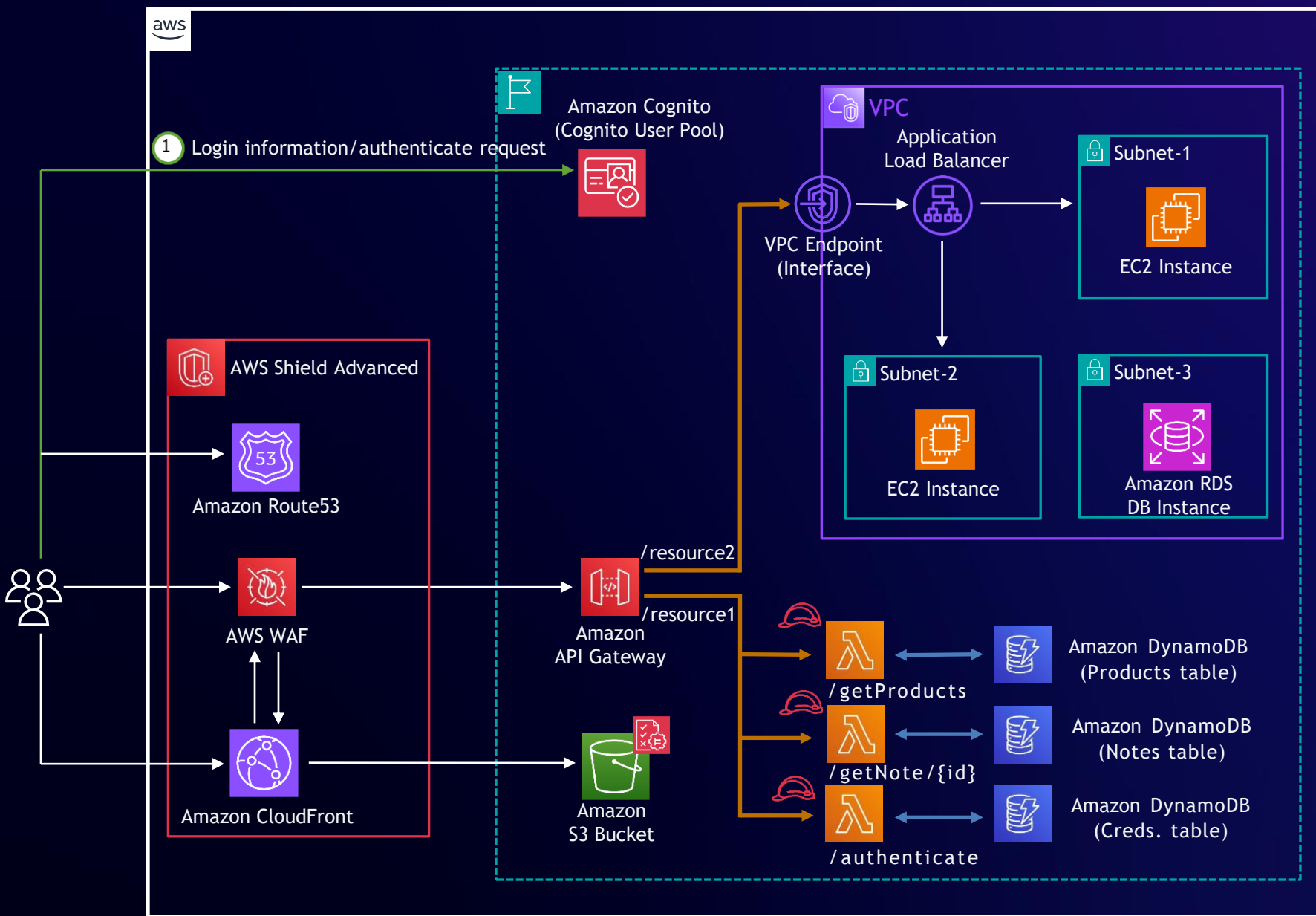
Logging and Monitoring

- AWS CloudTrail

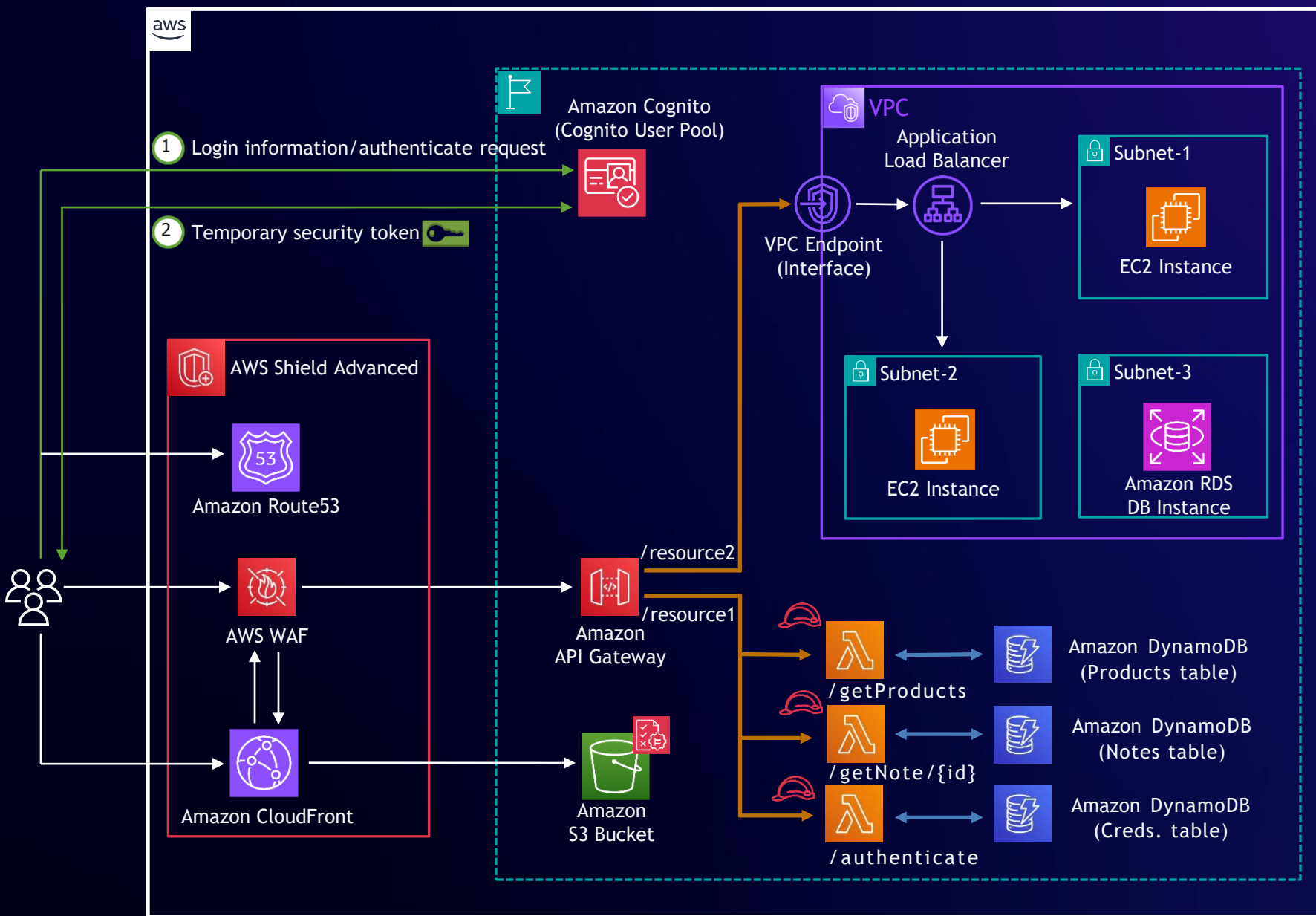
- CloudWatch Metrics

- CloudWatch Log Insights

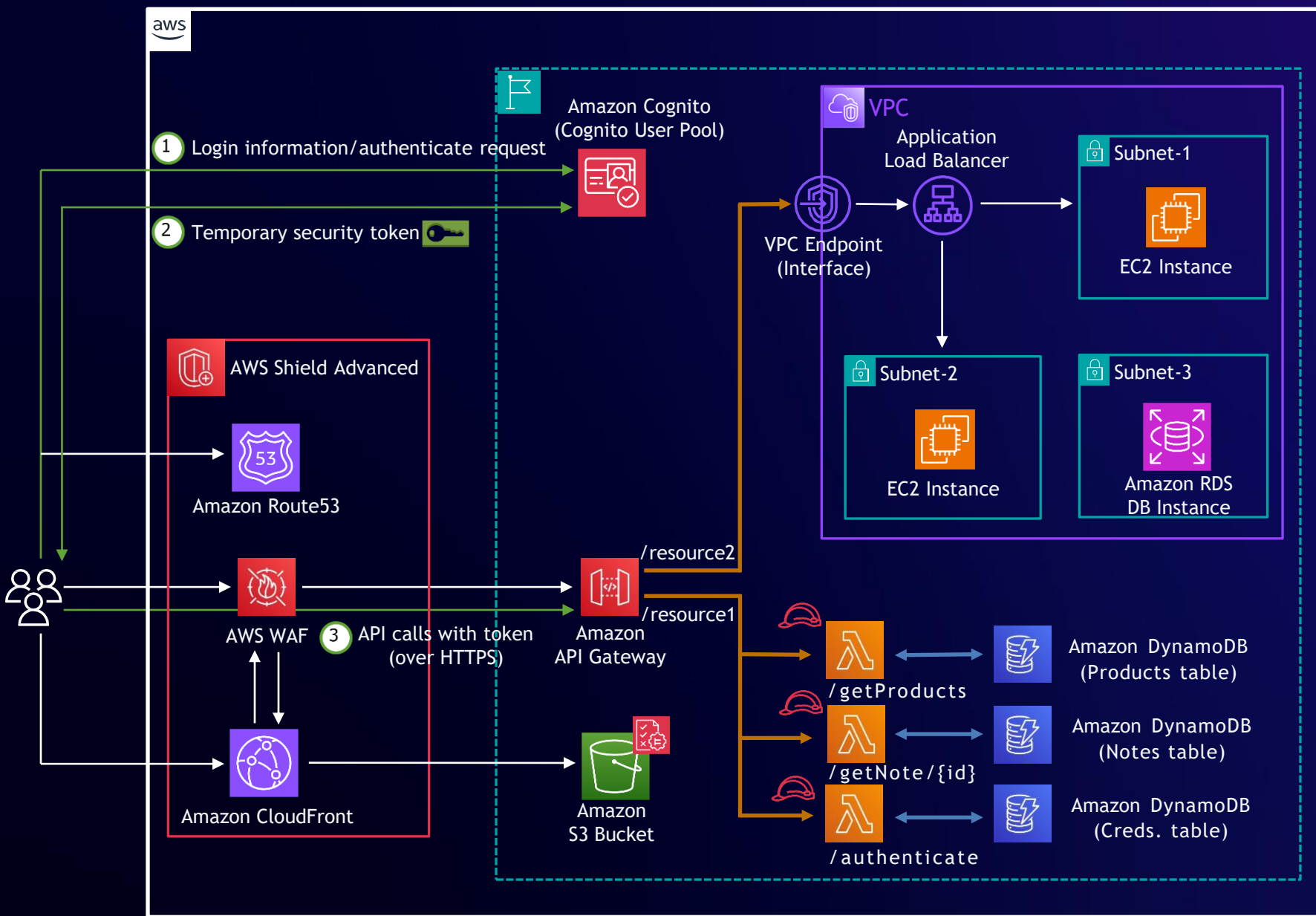
Amazon Cognito



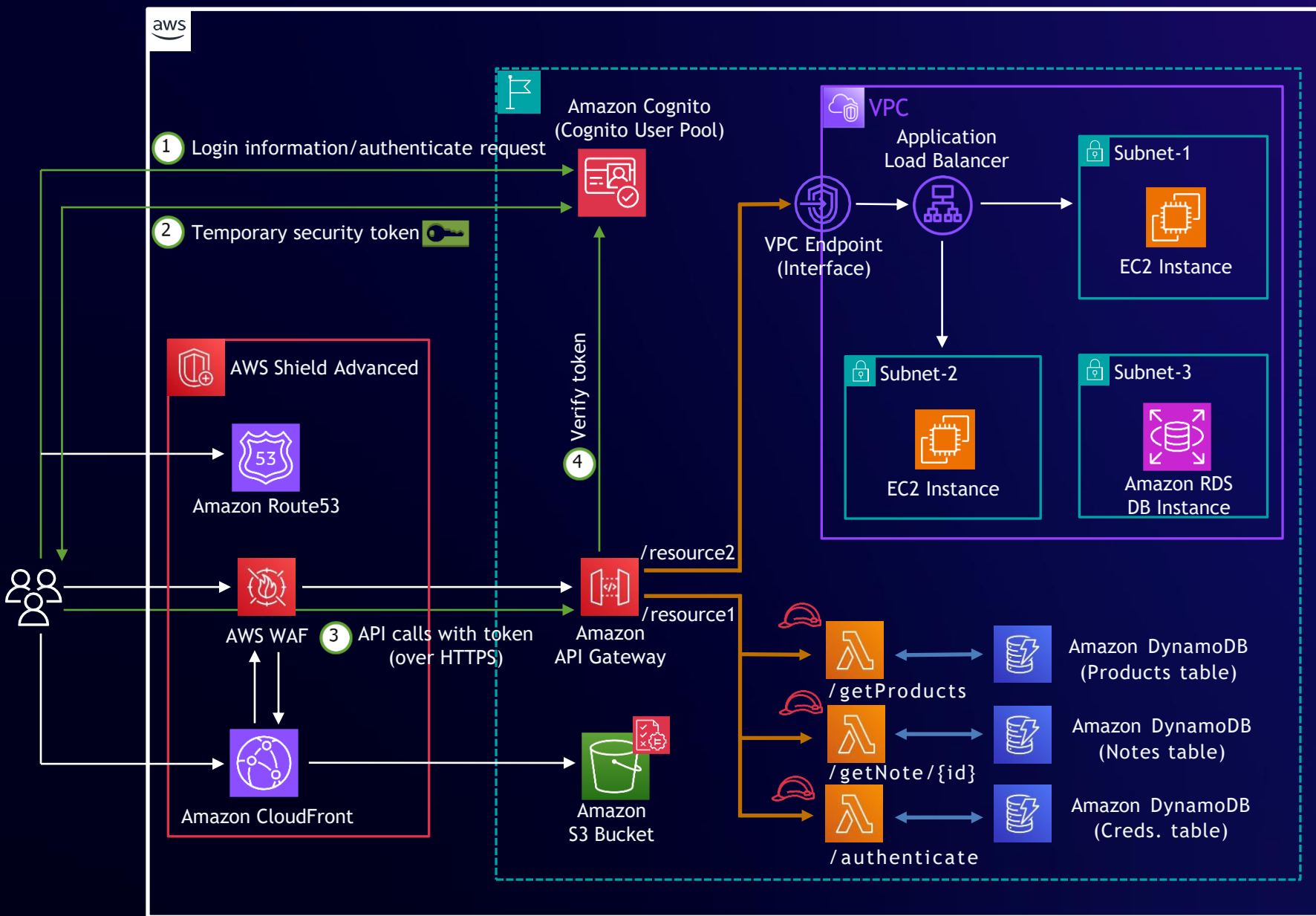
Amazon Cognito



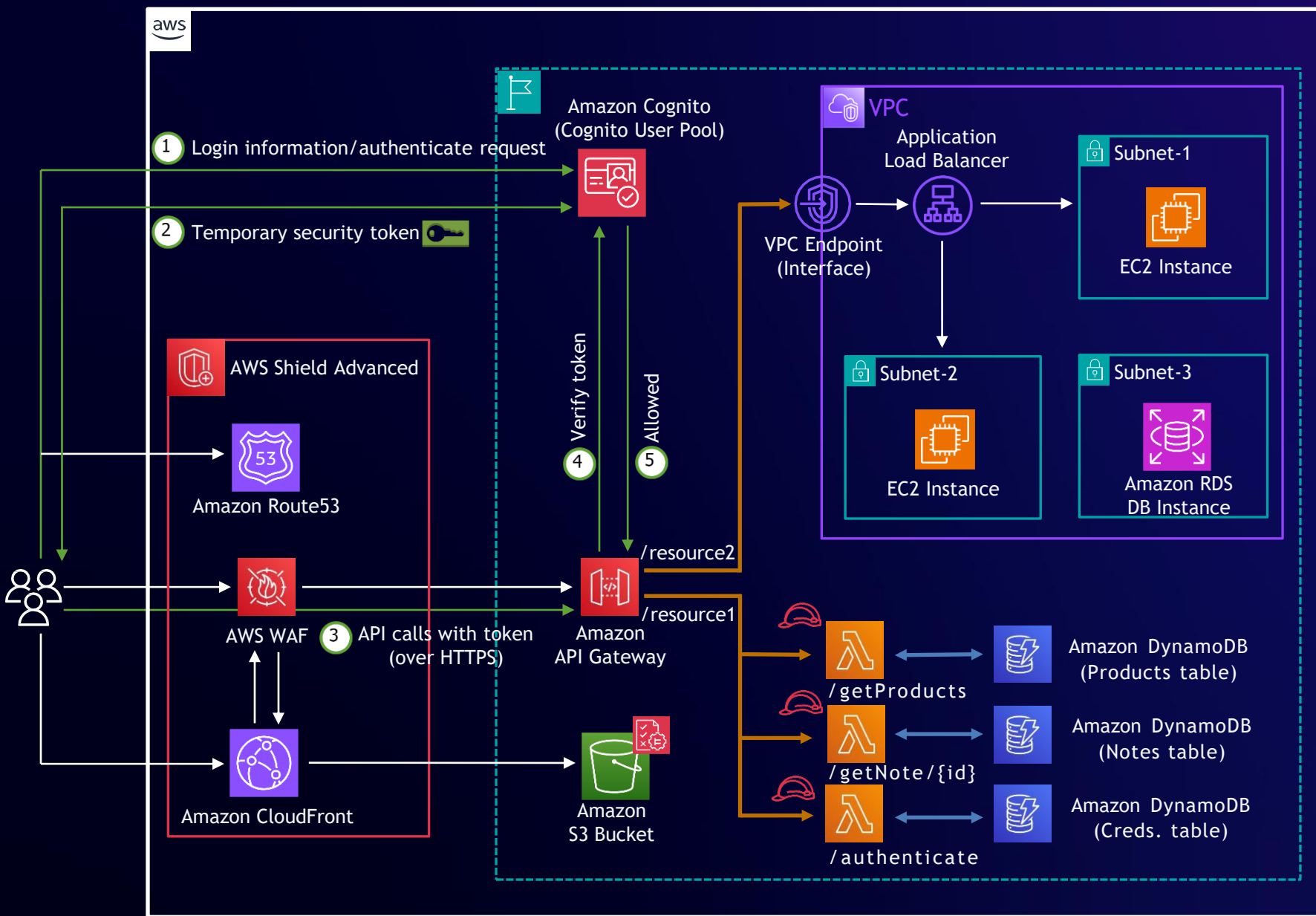
Amazon Cognito



Amazon Cognito

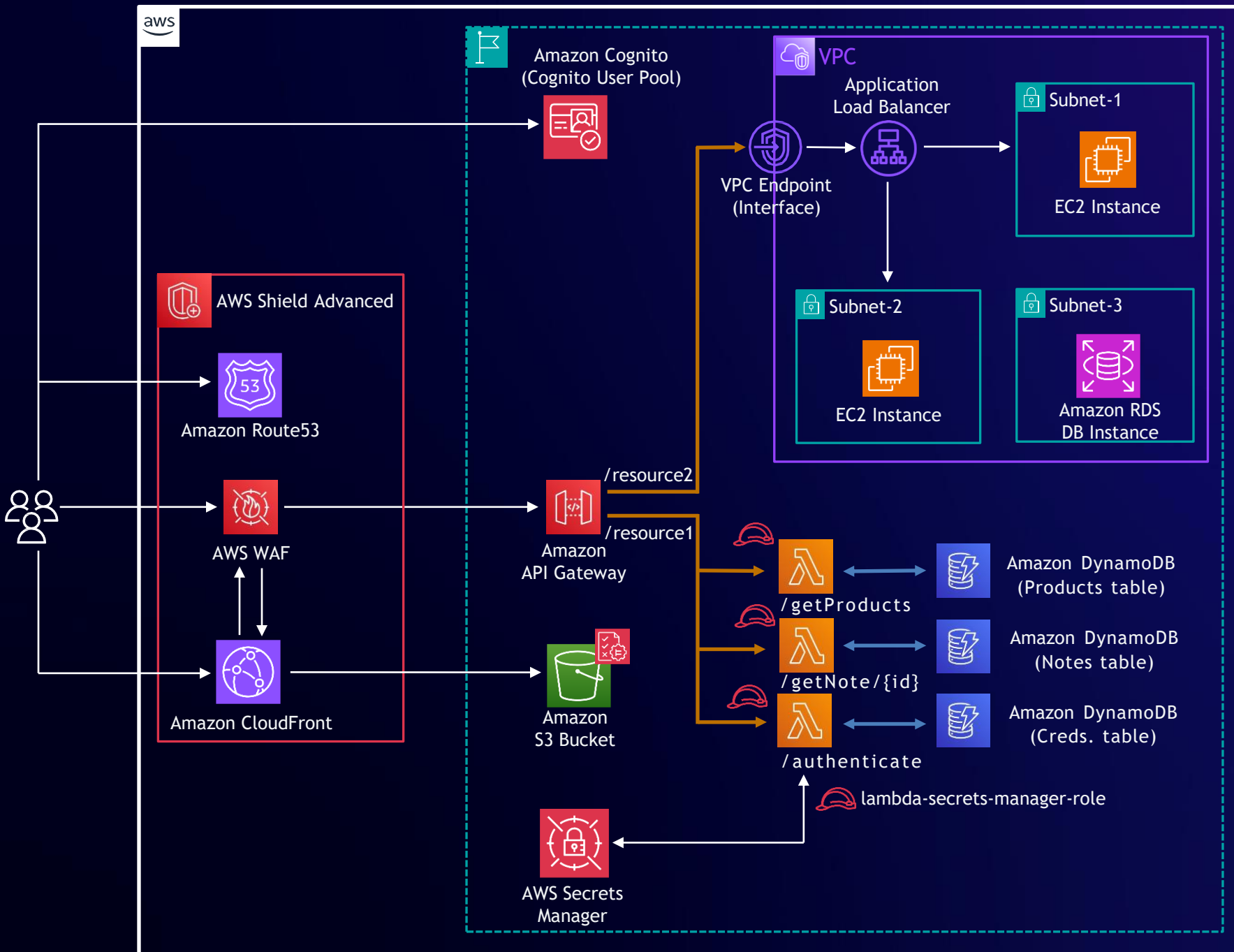


Amazon Cognito



Q: What if we want store and use secrets securely?

AWS SECRETS MANAGER



AWS Secrets Manager

Execution role (lambda-secrets-manager-role)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue"
      ],
      "Resource": [
        "arn:aws:secretsmanager:us-east-1:ACCOUNT_ID:secret:SECRET_NAME"
      ]
    }
  ]
}
```

Execution role (lambda-secrets-manager-role)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue"
      ],
      "Resource": [
        "arn:aws:secretsmanager:us-east-1:ACCOUNT_ID:secret:SECRET_NAME"
      ]
    }
  ]
}
```

Execution role (lambda-secrets-manager-role)

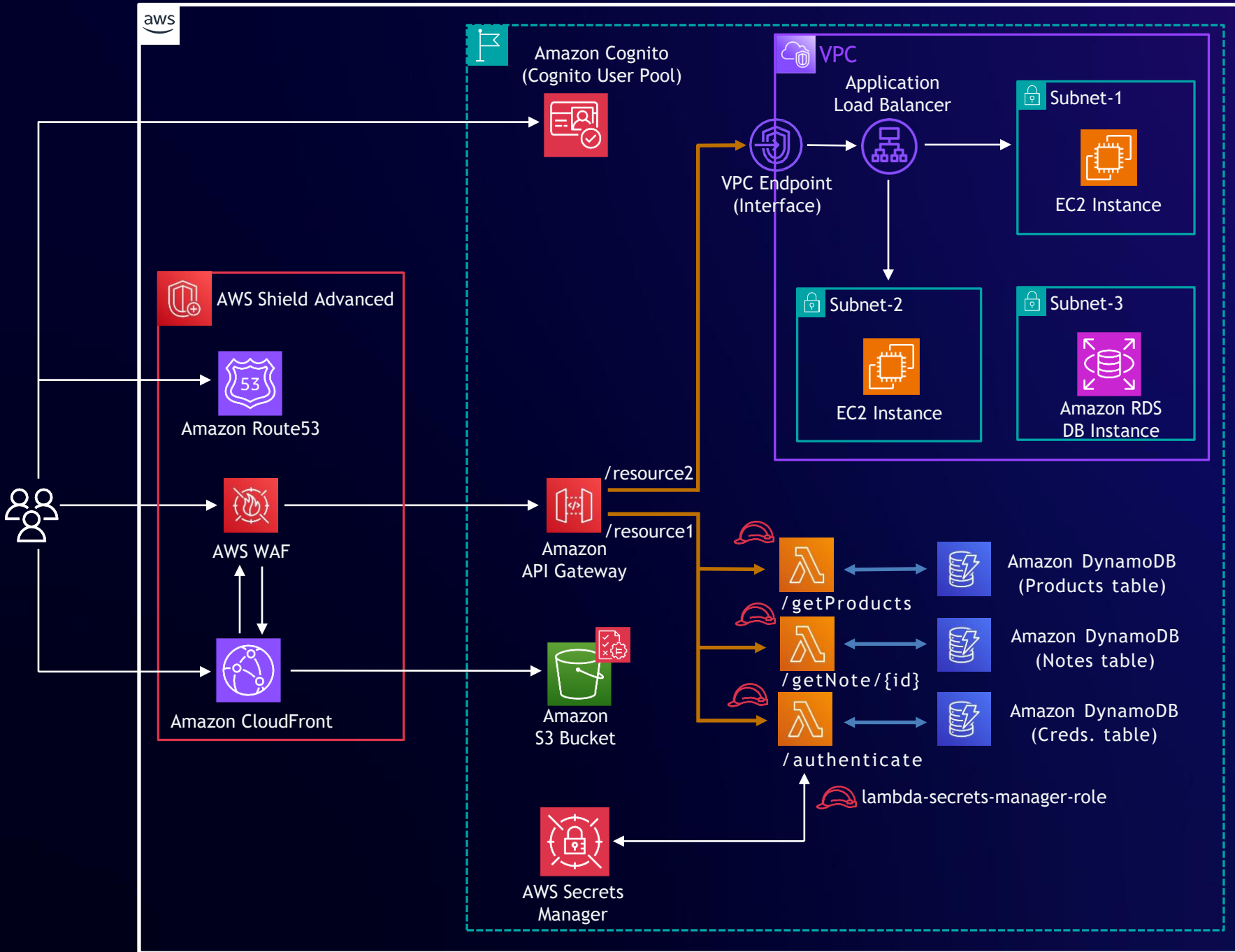
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue"
      ],
      "Resource": [
        "arn:aws:secretsmanager:us-east-1:ACCOUNT_ID:secret:SECRET_NAME"
      ]
    }
  ]
}
```

Execution role (lambda-secrets-manager-role)

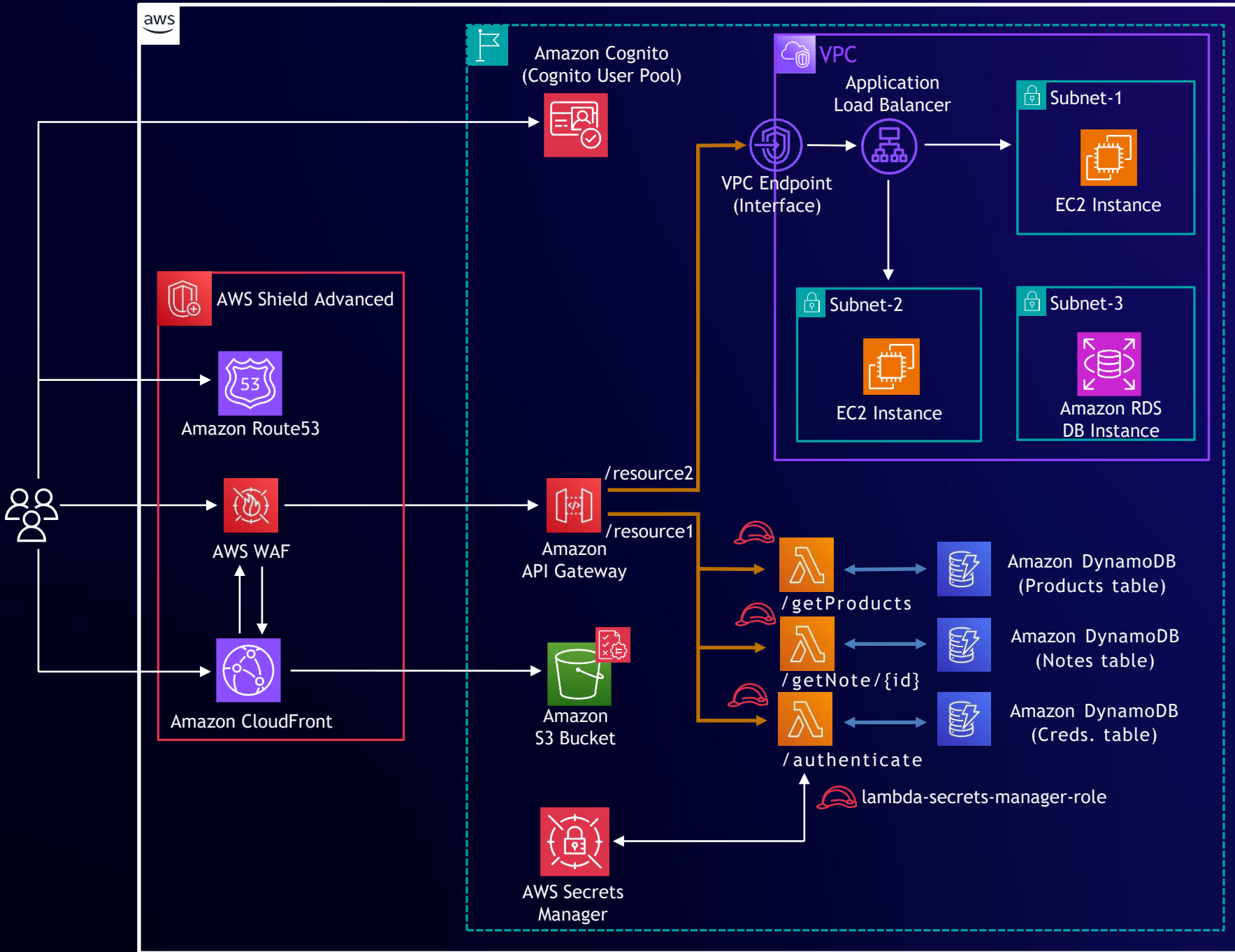
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue"
      ],
      "Resource": [
        "arn:aws:secretsmanager:us-east-1:ACCOUNT_ID:secret:SECRET_NAME"
      ]
    }
  ]
}
```

Execution role (lambda-secrets-manager-role)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue"
      ],
      "Resource": [
        "arn:aws:secretsmanager:us-east-1:ACCOUNT_ID:secret:SECRET_NAME"
      ]
    }
  ]
}
```

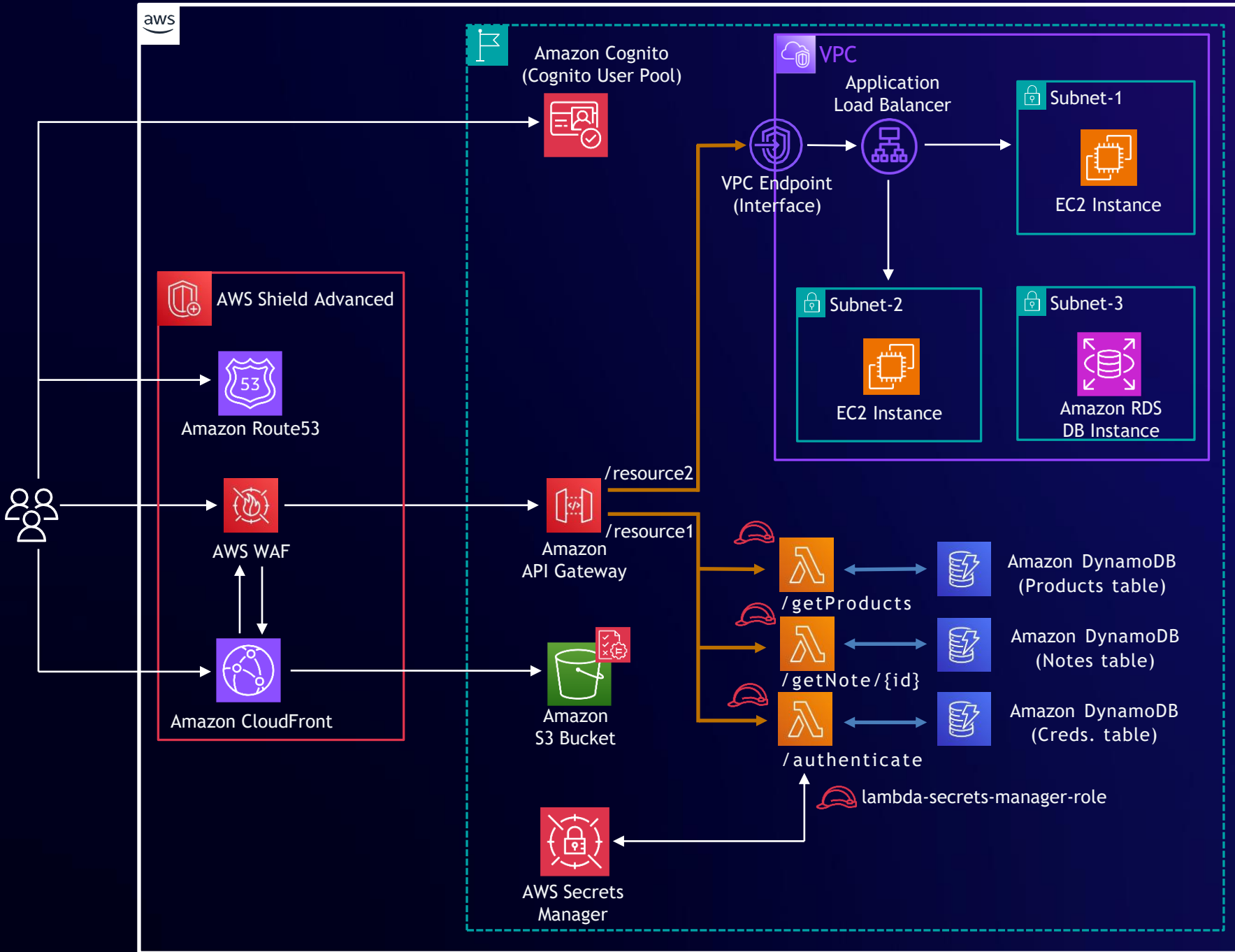


AWS Secrets Manager



AWS Secrets Manager

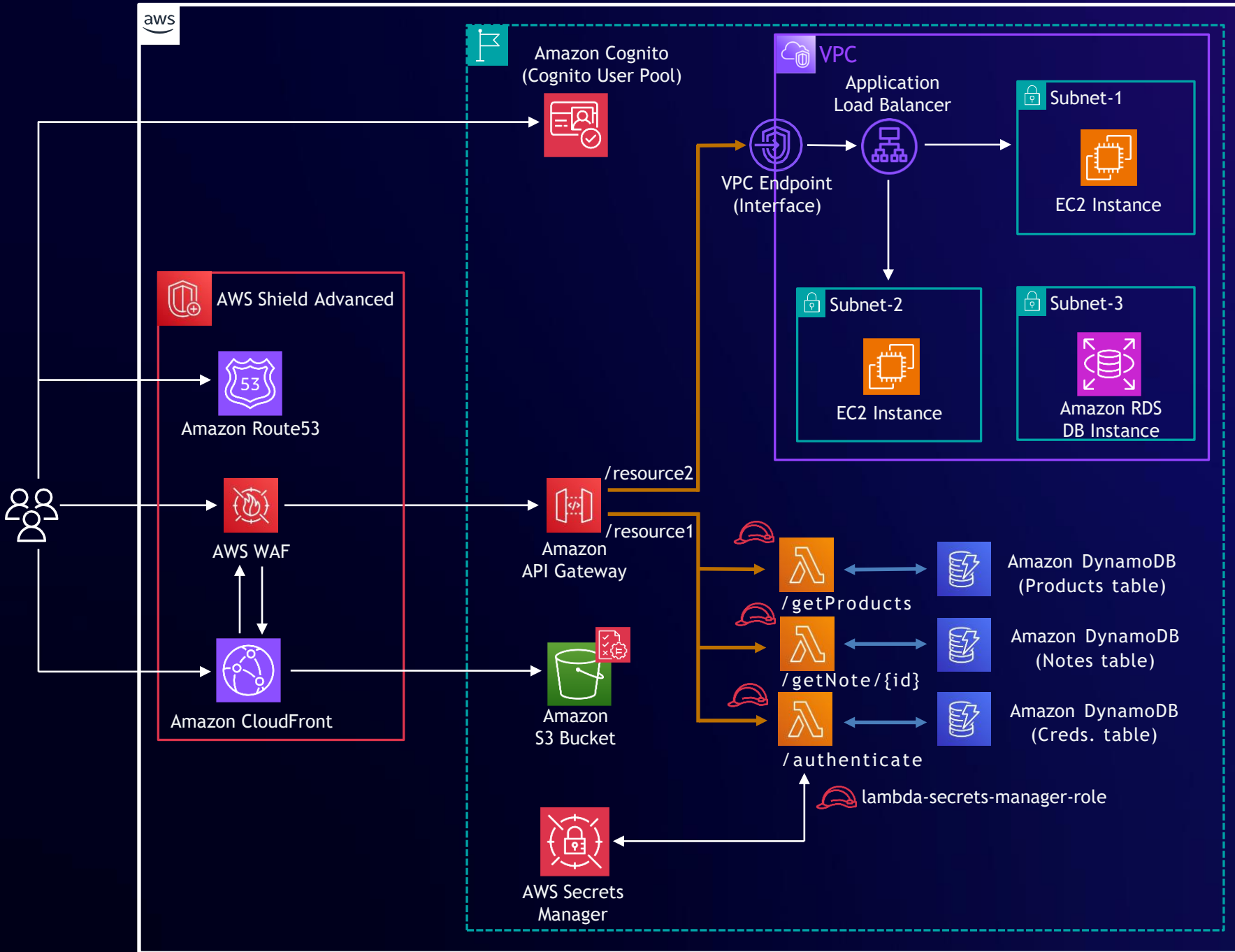
Encryption of secrets



AWS Secrets Manager

Encryption of secrets

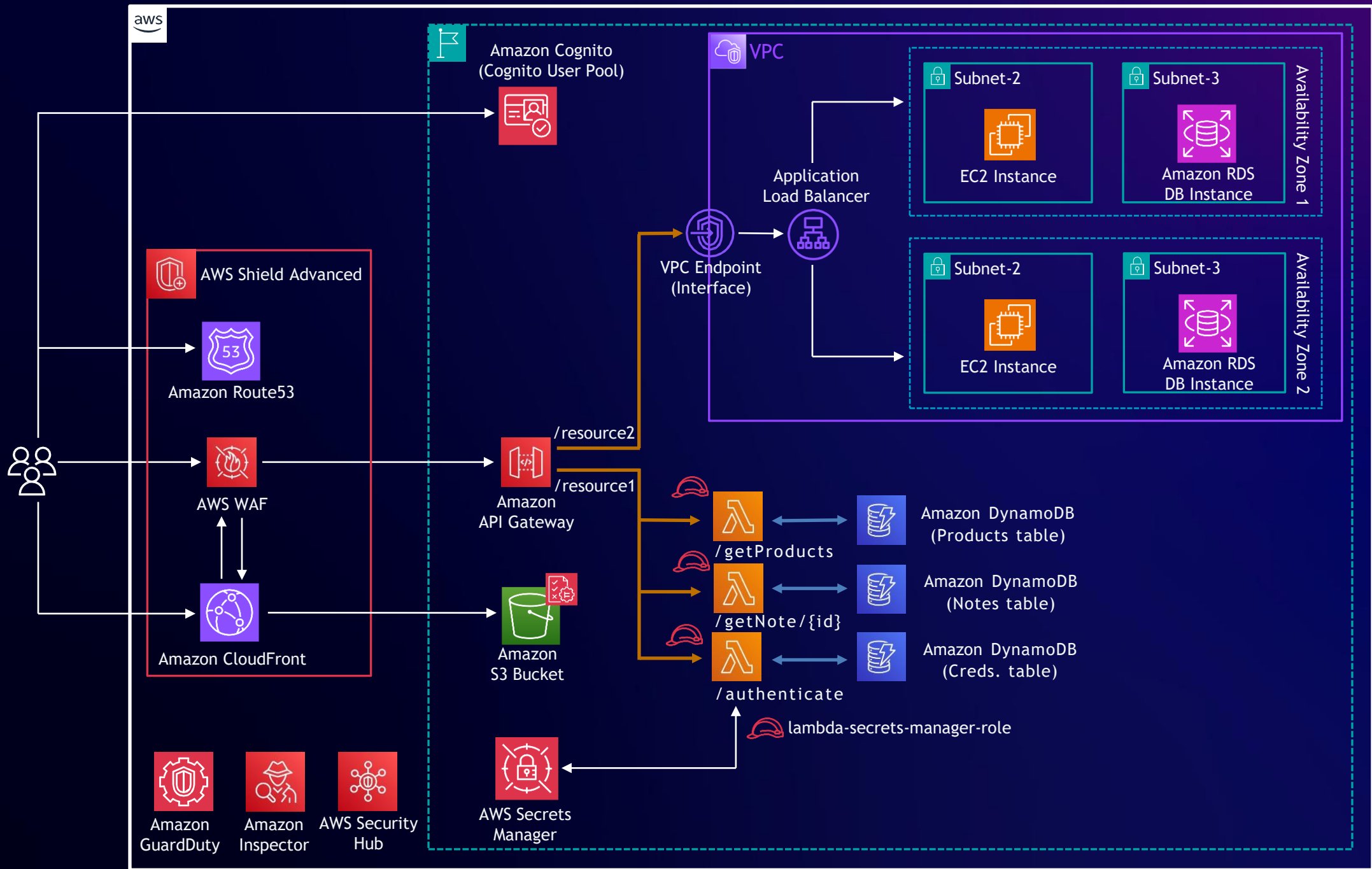
Automated secret rotation



AWS Secrets Manager

- Encryption of secrets
- Automated secret rotation
- Tracking secret access

Q: Can we fit everything on one slide?



Thank you!

Murat Aydemir

✕ @mrtydmr75

in linkedin.com/in/murataydemirr